



國立臺灣科技大學

資訊管理系

EMBA 碩士在職專班

碩士學位論文

學號：M110099008

導入雲端運算的策略與合規性

— 以臺灣金融業為例

Strategies and Compliance in
Adopting Cloud Computing - A Case Study
of Taiwan's Financial Industry

研究生：楊士岳

指導教授：查士朝博士

中華民國一十二年七月



碩士學位論文指導教授推薦書

Master's Thesis Recommendation Form



M11009908

系所：資訊管理系
Department/Graduate Institute Department of Information Management

姓名：楊士岳
Name YANG, SHIH-YEH

論文題目：導入雲端運算的策略與合規性—以臺灣金融業為例
(Thesis Title) Strategies and Compliance in Adopting Cloud Computing - A Case Study of Taiwan's Financial Industry

係由本人指導撰述，同意提付審查。

This is to certify that the thesis submitted by the student named above, has been written under my supervision. I hereby approve this thesis to be applied for examination.

指導教授簽章：
Advisor's Signature

查士岳

共同指導教授簽章（如有）：
Co-advisor's Signature (if any)

日期：
Date(yyyy/mm/dd)

2023, 7, 28



M11009908



碩士學位考試委員審定書

Qualification Form by Master's Degree Examination Committee

系所：資訊管理系
Department/Graduate Institute Department of Information Management

姓名：楊士岳
Name YANG, SHIH-YEH

論文題目：導入雲端運算的策略與合規性—以臺灣金融業為例
(Thesis Title) Strategies and Compliance in Adopting Cloud Computing - A Case Study of Taiwan's Financial Industry

經本委員會審定通過，特此證明。

This is to certify that the thesis submitted by the student named above, is qualified and approved by the Examination Committee.

學位考試委員會

Degree Examination Committee

委員簽章：

Member's Signatures

費政嘉
查士期
田元一

指導教授簽章：

Advisor's Signature

查士期

共同指導教授簽章（如有）：

Co-advisor's Signature (if any)

查士期

系所（學程）主任（所長）簽章：

Department/Study Program/Graduate Institute Chair's Signature

查士期
2023 / 7 / 28

日期：

Date(yyyy/mm/dd)

摘要

面臨金融科技（Fintech）帶來的威脅與衝擊，傳統金融機構必須進行數位化轉型，積極導入雲端運算搭配人工智慧應用，透過行動應用程式提升使用者體驗，拉近客戶關係，以滿足消費者在不同階段的需求，創造更多的金融商品和機會。

因為金融機構拉網路骨幹，在地端自建機房採用最新架構及應用程式的成本太高，因此使用雲端服務就成為一個可能的選項。多家雲端服務供應商，採取客製化彈性的服務策略，降低資訊科技前期投資大量成本，提高靈活性、業務敏捷性、可擴展性，迎合市場需求的應變能力。導入雲端運算之前，必須選擇符合國際標準規範的雲端服務供應商，實施適當的資訊安全措施，以保護敏感個人資料、避免揭露客戶的隱私。

這幾年台灣金融監督管理委員會參考國際金融服務的發展路徑，陸續提出了許多資訊安全規範，金融機構資訊安全標準作業程序規範，金融業內稽內控的營運作業安全規範，以及上市上櫃公司的法規，要求資料落地台灣，就算報部申請雲端應用卻不見得能通過審核。隨著 2023 年雲端資訊服務委外規範修訂鬆綁，金融機構如何遵守金管會的資訊安全法規，完成導入雲端運算的各項準備，塑造金融科技共同發展的雲端生態系，促進新的商業模式應用，提高金融服務的執行效率，達到更好的使用者滿意度。

本研究探討雲端運算發展、安全性規範及國際標準，搭配金管會開放雲端委外作業安全規範，說明雲端運算基礎架構設計，如何選擇雲端運算平台，以及移轉服務上雲端的步驟，依據安全基礎藍圖及國際認證標準，進行風險控管措施。導入開放銀行 API 管理平台的應用案例，說明 Google Apigee 私有雲及混合雲的高可用架構，達到金融業雲端資訊安全合規性，實務應用面可能遇到的挑戰，及未來的因應策略。

關鍵字：金融科技、資訊安全、金融監督管理委員會、國際標準規範、雲端運算、Google Apigee、私有雲、混合雲、高可用架構、風險控管、合規性。

ABSTRACT

The rapid development of financial technology (Fintech) poses both threats and impacts on traditional financial institutions. Taiwan's financial industry is undergoing digital transformation, actively adopting cloud computing in conjunction with artificial intelligence applications. Through mobile applications, they enhance user experience, strengthen customer relationships, and create more financial opportunities.

However, the cost is too high for planning new architectures and applications in on-premises data center with the establishment of their own network backbone to ISP. Using public cloud services has become a possible option. The cloud service providers are offering customized and flexible services, reducing upfront IT investment costs, and enhancing flexibility, and responsiveness to market demands.

To shape the ecosystem of cloud-based financial technology, Taiwan's Financial Supervisory Commission (FSC) has introduced various cloud service information security regulations. These efforts aim to achieve widespread and convenient financial services for the public. Considering the gradual relaxation of regulations concerning data localization in Taiwan, it becomes essential for companies to comply with the FSC's operational security standards, internal controls, and external requirements of listed companies before embracing cloud computing.

This study explores the development of cloud computing, security regulations, and international standards, complemented by the FSC's regulations on open cloud outsourcing operations. How to choose cloud computing platforms, and the steps for service migration to the cloud. The study also provides a case study on the application of an open banking API management platform, explaining Google Apigee's private and hybrid cloud architecture to achieve cloud information security compliance in the financial industry. Furthermore, it discusses potential challenges and response strategies in the future.

Keywords: Financial Industry, Banking, Financial Supervisory Commission (FSC), Security Compliance, Cloud Computing, Google Apigee, Private Cloud, Hybrid Cloud.

誌謝

首先我要向指導老師查士朝教授表達最誠摯的感謝，感謝老師在論文撰寫期間願意每周提供寶貴專業的建議，不厭其煩地指導修正研究方向、精進研究內容。同時也要感謝 EMBA 許多學長姐適時鼓勵與提醒，讓我能夠更有信心在最後關頭順利完成論文內容。還要真心感謝口試委員羅天一教授與黃政嘉教授，兩位老師在口試期間給予很多精闢的點評及改善要點，使得本研究論文修正後更加趨近完美。

工作二十多年後，還能夠回到臺灣科技大學就讀 EMBA 拿到資管碩士學位，實現年輕時未完成的夢想，真是人生中最重要的一座里程碑。除了擔任班級幹部、攝影同好社長、110 新研營資訊長，參加台北國際龍舟賽、全國 e 馬拉松、泳渡日月潭、商管聯盟鐵馬論劍單車環島，來自不同產業傑出的菁英培養革命情感，跟管理學院五系學長姐一起參加活動、共同學習做報告。特別感謝最有愛的資管 110 學長姐、新研營神七隊的佛系隊友，於背後默默支持實在很愛您們，很開心終於趕上末班車跟大家一起畢業了。

最後，要特別感謝我的爸媽，他們是支持我不斷持續學習成長最重要的動力。也要感謝我親愛的老婆君秀與三個孩子們，謝謝他們在我求學期間的包容與體諒，讓我無後顧之憂全力逐夢，同時兼顧工作、家庭及學業，能夠在時間內順利修習課業完成論文，在此獻上我最崇高的敬意與由衷的感激。

楊士岳 謹誌於

國立臺灣科技大學 EMBA 資訊管理系

中華民國 112 年 7 月

摘要 III

ABSTRACT IV

誌謝 V

圖目錄..... VII

表目錄..... I

第一章 緒論..... 1

 1.1 研究背景 1

 1.2 研究動機 1

 1.3 研究目的 2

 1.4 研究方法及流程..... 2

第二章 文獻探討 4

 2.1 雲端運算的定義與特性..... 4

 2.2 金融產業的創新科技與發展路徑..... 6

 2.3 金管會的雲端服務資訊安全監控規範 8

 2.4 資訊安全國際標準規範與合規性..... 12

 2.5 導入雲端運算對營運管理的影響..... 24

第三章 導入雲端運算架構設計 26

 3.1 雲端運算的基礎框架 26

 3.2 雲端運算平台及服務的選擇策略..... 28

 3.3 導入雲端服務的移轉方法 32

 3.4 雲端服務的安全基礎藍圖 35

 3.5 雲端運算資訊安全風險管理..... 39

第四章 個案研究與實務探討..... 47

 4.1 雲端運算平台的優勢及數位化轉型需求..... 47

 4.2 雲端創新服務應用 - 開放銀行 API 管理平台 48

 4.3 金融業資訊安全控管合規性..... 61

第五章 結論與建議..... 73

 5.1 研究結論與建議..... 73

 5.2 實務管理意涵 75

 5.3 未來展望 76

參考文獻 78

圖目錄

圖 1、研究流程圖	3
圖 2、NIST 雲端運算的特性	5
圖 3、金融科技類別樹	7
圖 4、金融資安行動方案 2.0 推動藍圖	9
圖 5、ISO 31000 風險管理原則、架構及過程的關係	18
圖 6、雲端運算模型參考架構	19
圖 7、多層次組織層級風險控管	20
圖 8、Google Cloud 雲端架構框架六個支柱	26
圖 9、雲端運算平台及服務的選擇策略	29
圖 10、應用程式遷移 AWS 雲端的七種策略	33
圖 11、Google Cloud 採安全基礎藍圖部署的合規性報告範例	38
圖 12、資訊安全風險管理循環	42
圖 13、不同類型的風險控制措施	42
圖 14、風險處理的進行及選擇	43
圖 15、資訊安全的控制層級	43
圖 16、荷蘭銀行 Apigee Developer Portal	52
圖 17、Apigee API 開發生命週期圖表化呈現	53
圖 18、使用 Apigee API 營利彈性計費的方式	54
圖 19、Apigee Edge 元件關聯圖	55
圖 20、Apigee Edge 雙備援資料中心叢集節點架構	56
圖 21、正式環境 APIM 備援與周邊系統整合架構圖	56
圖 22、Apigee Hybrid 高階架構圖	57
圖 23、Apigee Hybrid 管理平台架構圖	58
圖 24、Apigee Hybrid 客戶端運行平台架構圖	58
圖 25、Apigee Hybrid 網路分區分隔模型範例	60
圖 26、Apigee Hybrid 客戶運行平台多地區架構圖	60
圖 27、Apigee Hybrid 正式環境多地區部署模型	61
圖 28、API 治理架構及不同角色的考量	62
圖 29、API 治理的成熟度評分表範例	63
圖 30、API 治理的活動範圍	64
圖 31、Apigee 標準功能測試報告	66
圖 32、風險評鑑稽核流程圖	68
圖 33、使用 Cloud Controls Matrix 4.0 檢查雲端環境	70
圖 34、使用 CCM 4.0 稽查 ISO/IEC 27000 國際認證合規性	70
圖 35、金融科技運用於銀行核心業務之創新服務	73
圖 36、金融機構數位轉型上雲端的準備	74

表目錄

表 1、各個機構對雲端運算的定義	4
表 2、金融機構作業委託他人處理內部作業制度修正草案	10
表 3、金融機構作業委託他人處理內部作業制度調整重大性定義	10
表 4、雲端運算資安管理及國際標準規範	12
表 5、ISO/IEC 27001 資安管理作業規範控制要點	14
表 6、雲端客戶和雲端服務提供者制定政策考量的差異	15
表 7、ISMS 資訊安全風險管理與 PDCA 流程對應關聯	16
表 8、NIST 對雲端運算的安全及隱私的建議	21
表 9、Google Cloud Platform 雲端服務類型及應用優勢	30
表 10、遷移到 AWS 雲端的五種策略	34
表 11、Google Cloud 不同層次安全藍圖的優點及雲端應用範例	36
表 12、CSA 雲端威脅及風險補救控制矩陣	45
表 13、GCP 雲端運算基礎框架規劃	49
表 14、GCP 雲端運算平台服務的選擇策略	50
表 15、導入雲端服務的移轉方法	51
表 16、ISMS 控管文件範例	65
表 17、法規遵循清單範例	66
表 18、關鍵風險 CCM 雲端控制矩陣項目及國際標準合規性	71
表 19、未來銀行可能面臨的風險類型	75
表 20、本國銀行面對金融挑戰的因應策略與數位化轉型	76

第一章 緒論

本研究的主題是導入雲端運算的策略與合規性，以臺灣金融業為例說明研究背景、研究動機、研究目的、研究方法及流程。

1.1 研究背景

金融服務已經融入人們日常生活，傳統銀行需要有所改變，運用新興科技進行數位化轉型。在《Bank 4.0 金融常在，銀行不再》[1] 書中提到，在這個數位時代傳統銀行面臨著許多挑戰，如果有機會運用雲端運算科技提供全球化無遠弗屆的服務，搭配新創公司最新的（Artificial Intelligence, AI）人工智慧模型進行消費者行為分析及商品預測，就能夠強化金融商品應用提升核心競爭力。

隨著全球金融服務蓬勃發展，搭配數位化轉型提供更多元金融商品服務，透過行動應用程式提升使用者體驗拉近客戶關係。這兩年的新冠疫情 COVID-19 更加速金融機構數位轉型的發展，如何結合最新科技產生新型態的業務，搶得市場先機吸引更多客群，成為金融產業主要的戰策之一。

例如：國泰金控成立數位數據暨科技發展中心，協助全集團數位轉型，團隊包含數位行銷服務、數位體驗設計、數位平台產品開發，運用大數據、雲端運算、機器學習等科技，來協助業務拓展。玉山銀行成立資料科學團隊，分析全台灣數百家分行，根據各區域擬訂不同的經營策略，探討 ChatGPT 如何影響學術研究、產業消長、機會與風險。中國信託銀行成立數位數據暨科技研發單位，以 AI 人工智慧確保大數據的應用落地，搶攻數位金融藍海，掌控顧客不同階段的需求提供個人化服務、全通路的體驗。合作金庫銀行建置 360 度客戶視圖，期盼行內各部門能以視覺化的報表，打造資料驅動決策的基礎，制定業務發展的策略 [2]。

金融產業一直以來都面臨著嚴格的合規性要求和資料安全性挑戰，隨著雲端運算的快速發展和成熟，越來越多的金融機構開始考慮將其業務和資源轉移到雲端環境中。這是出於追求更高效率、靈活性和創新性的需求，也感受到成本優勢和擴展能力的吸引。

1.2 研究動機

根據「iThome 2016 年 CIO 大調查-企業雲端投資總論」[3]，台灣已經有 58.4% 企業選擇使用雲端運算平台，企業對於雲端服務投資占比幾乎翻了一倍達到 6.9%，其中金融業對於雲端投資成長 3 倍，每一家金融業平均投入新台幣 1,010 萬元。傳統 IT 需要不少人力維護地端機房的軟硬體設備，現在只需要請幾位雲端工程師負責系統維運，其他軟體工程師可以專注開發應用程式。雲端服務的自動擴展 Auto Scaling 機制，能夠應付突然變大的流量自動擴展，如此彈性付費的方式，讓企業能夠精準掌握開支節省成本。

但是國內企業對於資訊安全重視始終不足，2016 年 7 月第一銀行爆發大規模 ATM 遭駭客盜領的案件，主管機關開始要求金融業辦理電腦資訊安全評估，2017 年 3 月在內稽內控辦法中增訂銀行業應該設置資訊安全專責單位及主管。金融機構因為法規的要求，紛紛開始重視資訊安全，台灣金融監督管理委員會（簡稱金管會）也將資通安全管理列入年度金融檢查的重點。接著 2019 年資通安全管理辦法及子法上路，對於公務機關及非公務機關資訊安全管理，依照資通安全責任分級辦法，配置資通安全長及增加資訊安全專職人員配置。

隨著金融科技數位化轉型，雲端解決方案蓬勃發展，駭客攻擊手法持續翻新，資訊安全風險也與時俱進。針對各項風險因子建立適當的監控機制，關鍵業務委外需進行供應商的風險評估，除了建構事前防禦，強化事中維運監控，還要建立事後的應變處理機制，尋找外部顧問研擬風險導向的整體資安防護計畫，搭配定期執行內部及外部稽核，才能降低資訊安全事件可能造成的損失。

1.3 研究目的

對於金融機構來說，遷移到雲端運算平台涉及許多議題，包含：敏感客戶資料保存，還要考量金管會的法令何時鬆綁，資料必須落地在台灣的规定，如何進行資訊安全控管，符合內部稽核安全規範、以及外部上市櫃法規的要求。為了確保不同系統和雲端託管平台之間，既要適當整合又要保護資料，必須建立標準。因此，了解金融機構在導入雲端運算時的策略、實踐合規性是至關重要的。

本研究的目的是在於提供一個全面性分析，探討金融機構在導入雲端運算策略和合規性挑戰。透過深入研究相關文獻和金融機構的實務案例，期望找到最佳的實踐方法，以幫助金融機構在遷移到雲端運算，達到安全和合規性的目標。這項研究結果，將為金融機構和相關利益者提供有價值的洞察力，說明導入雲端運算的先期準備，並制定雲端運算平台的移轉策略，雲端平台上線後的維運及監控，提供指導方針、解決方案以及相關的配套措施。

1.4 研究方法及流程

「質化研究」是一種以文字和描述性形式來瞭解和解釋現象的研究方法。強調對參與者的觀點、意見和經驗的理解，通過深入訪談、觀察、文本分析等方式收集和分析資料。目標是深入瞭解現象的本質、探索和生成新的理論或假設，以及提供對於社會和人類行為的深刻洞察。

「文獻探討法」是一種系統性地收集、整理和評估現有文獻的方法，以回答特定的研究問題或瞭解特定主題的狀態和發展趨勢。包括收集相關的研究文獻、書籍、期刊文章和其他相關資料，並對這些資料進行評估和分析。目標是綜合整理現有的知識，提供對特定主題的深入理解，並確定未來研究的方向和需求。

「個案研究法」根據研究問題和目的，選擇適當的個案進行研究。個案可以

是一個組織、一個事件、一個人物或一個特定的情境。資料收集的目的是獲得豐富、深入的資訊，對收集到的資料進行整理、歸納和分析。可以使用質性分析方法，如內容分析、模式比對、主題編碼等，以提取關鍵的觀察和發現，引用相關的資料和文獻支持研究結果撰寫報告。

本研究採用質化研究搭配文獻探討、個案研究法並行的方式，研究步驟與流程內容如圖 1，各章節的內容簡要說明如下：

1. 第一章探討金融業上雲端的動機和目的，說明近年雲端運算快速發展許多新的技術，為何傳統金融業需要做數位化轉型及商品創新？
2. 第二章探討雲端運算發展、安全性規範及國際標準文獻，台灣金管會雲端委外作業安全規範，國際公認的資訊安全標準，雲端服務對營運管理影響。
3. 第三章說明雲端運算基礎架構設計，選擇雲端運算平台的考量及服務移轉上雲端的步驟，依據雲端安全基礎藍圖及國際認證資訊安全標準，針對雲端安全威脅進行風險控管的對應措施。
4. 第四章說明金融業導入雲端運算平台的優勢及數位化轉型需求，雲端創新服務應用採行開放銀行 API 管理平台，Apigee Edge 私有雲以及 Apigee Hybrid 混合雲的架構，金融業雲端資訊安全合規性及未來可能的挑戰。
5. 第五章將上述的研究整理結論與建議，說明實務管理意涵，以及未來展望。

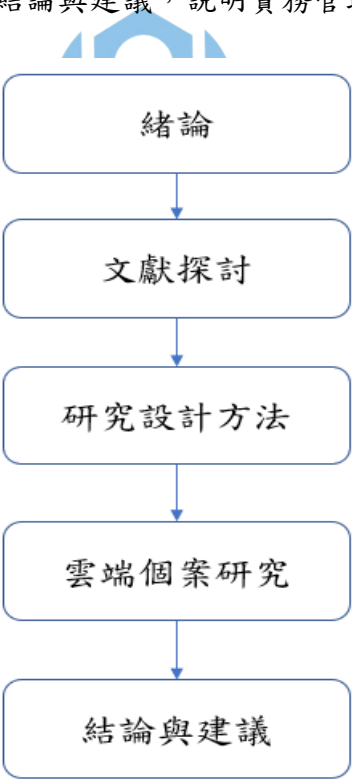


圖 1、研究流程圖

(本研究整理)

第二章 文獻探討

本章節介紹雲端運算的定義與特性，金融產業國際化的創新科技與監理政策，台灣金管會雲端資訊服務委外作業規範的修訂內容，接著說明導入雲端服務的資訊安全風險評估，組織內外稽核控管及國際化標準的合規性，再評估導入雲端運算的成功因素。

2.1 雲端運算的定義與特性

雲端運算的發展來自於各種商業服務模式，以及分散式網路技術的結合，雲端運算的應用與科技持續發展中，以下引用黃正傑 [4] 整理，不同機構對於雲端運算的定義如表 1。

表 1、各個機構對雲端運算的定義

機構	雲端運算定義
NIST	雲端運算無所不在、便利、隨選所需(On-demand)的網路資源存取模式。使用者可存取配置的共享電腦資源池(例如:網路、伺服器、儲存設備、應用程式、服務)，在最少管理成本與供應商的互動下，快速完成服務部署對外營運。
柏克萊大學	雲端運算是容易使用存取的大型虛擬資源池(例如:硬體、開發平台、服務)，這些資源可以依據負載動態調整，達到資源利用的最佳化。通常可以依據使用量的方式計價，由資訊基礎建設提供者達到不同的服務等級(Service Level Agreement)。
Gartner	一種運算型態，提供大量擴展及彈性的資訊科技能力，以服務的方式透過網際網路提供給外部顧客。
IDC	一個高度擴展、抽象的資訊基礎建設資源池，能夠讓顧客執行應用程式，依據資源消耗量計費。

(來源：黃正傑)

綜合上述的定義，雲端運算是一種網路服務的商業模式，用來實現服務的軟體稱之為雲端運算技術，關鍵在於企業或消費者隨選所需，使用服務商所提供的運算資源，服務契約以使用量計價，使用者可以彈性地調整所需的資源多寡。

2011 年美國國家科技標準機構（National Institute Standards and Technology, NIST）提出雲端運算 [5] 具備了五個重要特徵、三種服務模式，以及四種佈署方法如圖 2。這些特徵、服務模式和佈署方法提供了雲端運算的基本架構和模型，讓企業能夠根據業務需求和目標選擇運用雲端的技術。

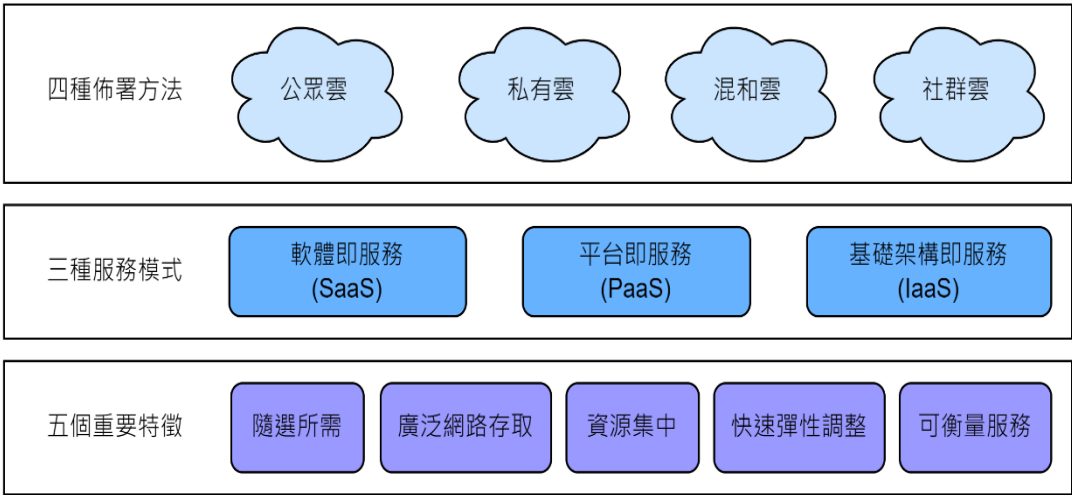


圖 2、NIST 雲端運算的特性
(來源：NIST)

NIST 雲端運算五個重要特徵，分別說明如下：

1. **自助服務**（On-demand self-service）：用戶能夠自主地根據需要使用和管理計算資源，如虛擬機器、儲存空間和應用程式，而無需與服務供應商進行人工干預。
2. **隨時隨地網路存取**（Broad network access）：用戶可以透過網路使用雲端服務，並以多種不同的裝置（例如電腦、平板電腦、手機）進行存取。
3. **資源池化**（Resource pooling）：供應商的計算資源（如虛擬機器、儲存空間、網路帶寬等）被集中管理和分配，以供多個客戶共享，實現更高效的資源利用率。
4. **快速彈性擴展**（Rapid elasticity）：用戶能夠根據需要快速擴展或縮減其使用的資源，以應對變動的工作負載需求，並按需付費。
5. **服務量測**（Measured service）：供應商能夠自動監測、控制和儲存雲端服務的使用量，以使用於計費、資源規劃、性能優化和報告等目的。

NIST 雲端運算三種服務模式，分別說明如下：

1. **基礎設施即服務**（Infrastructure as a Service，IaaS）：提供虛擬化的基礎設施資源，包括虛擬機器、儲存空間、網路和操作系統。用戶可以在供應商的基礎設施建構、管理自己的應用程式和環境。例如：Amazon Web Services EC2，GCP Compute Engine，Microsoft Azure VM，Alibaba Cloud ECS，IBM Cloud VMs/Bare Metal Servers。
2. **平台即服務**（Platform as a Service，PaaS）：提供較高層次的平台環境，包括

開發工具、資料庫和執行環境。用戶可以在供應商的平台開發、測試和部署應用程式，而不需要擔心底層的基礎設施。例如：Amazon SQS/SNS，Microsoft Azure AD/SQL Database，Google BigQuery/Cloud Storage，IBM Cloud Managed Services，Redhat OpenShift，Froce.com CRM，EMC Cloud Foundry。

3. **軟體即服務**（Software as a Service，SaaS）：提供完整的應用程式作為服務，用戶可以直接在供應商的平台運行和使用應用程式，而無需擔心底層的基礎設施和平台。例如：Microsoft Office 365，Google Workspace Gmail/Docs/Meet，Cisco Webex Meeting，Oracle NetSuite ERP，Salesforce.com CRM，Jiva ERP Software。

NIST 雲端運算四種佈署方法，分別說明如下：

1. **公有雲**（Public Cloud）：基於互聯網向公眾提供的雲端服務，由第三方供應商負責運營和管理。多個客戶可以共享這些服務。
2. **私有雲**（Private Cloud）：專為單一組織或企業設計和運營的雲端基礎設施，可以在內部資源中建立和管理，或者由第三方為特定客戶提供。
3. **社群雲**（Community Cloud）：基於共同需求的多個組織或企業共享的雲端基礎設施，以滿足特定的業務需求，例如特定行業或組織間的合作。
4. **混合雲**（Hybrid Cloud）：結合了兩個或多個不同類型（公有、私有或社群）的雲端基礎設施，允許資源和應用程式在這些環境之間移動和交互操作。這種佈署方式可以提供更大的靈活性和選擇性，以滿足不同的需求。

2.2 金融產業的創新科技與發展路徑

為了領導金融產業創新與發展、提升台灣金融市場的國際競爭力，金管會從 2015 年制定「金融科技發展與創新實驗條例」推動金融相關科技應用，開始鬆綁法令並鼓勵業者持續創新，推出多項措施同時準備測試環境，例如：監理沙盒、開放純網銀、開放銀行服務、證券型代幣、網路投保、金融科技創新園區。2020 年金管會金融科技發展與創新中心陸續完成許多訪談，包括：金融產業機構、新創團隊、投資機構、學術單位、新創園區等，參考金融產業利害關係人的觀點與建議，參考台灣金融科技專注領域的目標，提出「金融科技發展路徑圖」[6]。

參考 2020 年金融穩定學院（Financial Stability Institute, FSI）提出金融科技樹（fintech tree）的概念，區分成為三個不同的類別，定義金融產業國際化的發展趨勢說明如圖 3 [7]：

- 第一類〔樹冠〕**金融科技活動**（fintech activities），針對金融科技服務所

規範的監理政策。包含：數位銀行、融資平台、機器人理財、電子貨幣服務、數位支付服務、保險科技業務、加密資產有關金融活動等。

- 第二類〔樹幹〕**賦能技術**（enabling technologies），因應金融單位使用新興科技的應用程式，所衍生而來的管理政策。包含：應用程式介面 API、生物識別、雲端計算、分散式帳本技術、機器學習和人工智能等。
- 第三類〔樹根〕**政策輔佐**（policy enablers），為促進金融持續創新、更多商品應用服務，配合採行安全控管政策。包含：數位身分系統、資訊保護架構、資安防禦架構、開放銀行政策、創新促進措施等。

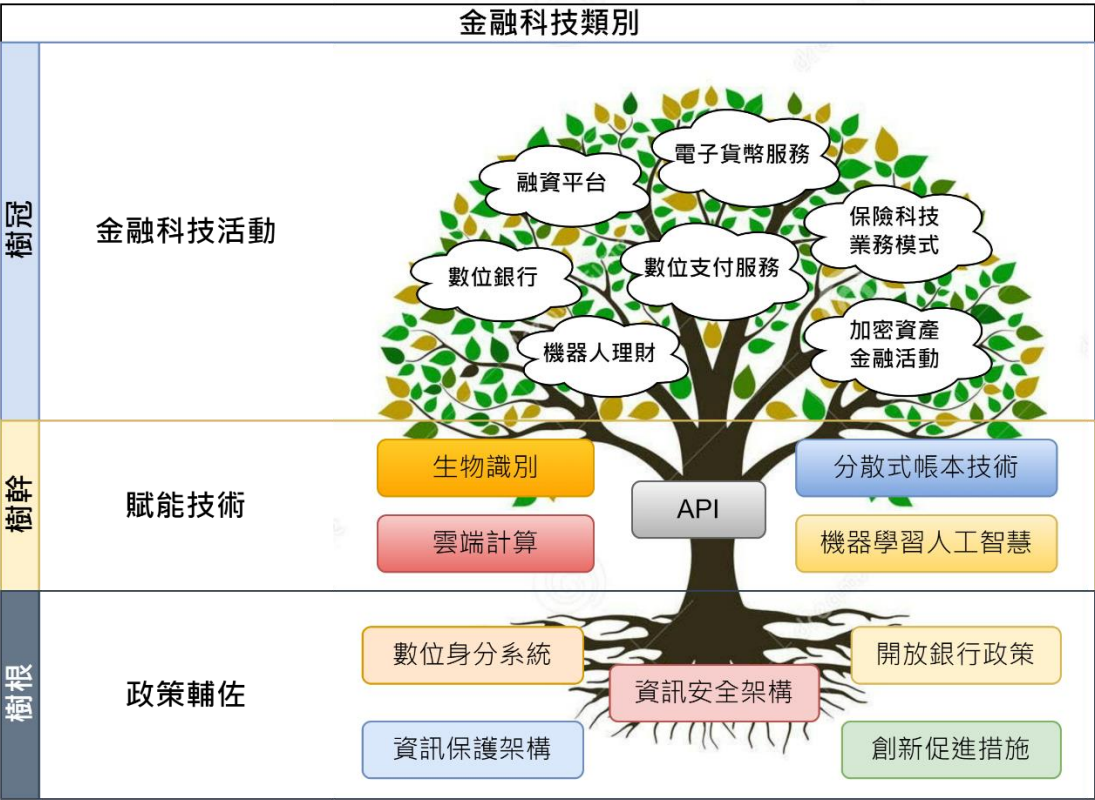


圖 3、金融科技類別樹
（來源：金管會）

金融產業正積極準備導入雲端運算服務，金融科技的發展需要保持勇於做夢的態度，以滿足消費者在不同階段和時點的需求，並創造更多的商品和服務，以延續辛苦建立的品牌。金融服務搭配新興科技的發展，不該因為宗教、種族、性別、地區或收入差異而產生歧視，只有這樣才能贏得消費者和投資者的永久信任。然而數位轉型的關鍵在於建立數位信任，必須考慮安全性、消費者隱私和資料可靠性等因素。以利他為中心的理念為基礎，重視倫理道德規範，這樣才能夠確保台灣金融科技持續穩健發展。

2.3 金管會的雲端服務資訊安全監控規範

為了塑造金融科技發展雲端的生態系，促進新的商業模式應用，提升金融服務執行效率與更好的使用品質，參考國際化金融科技服務的發展路徑，這幾年金管會陸續提出了許多雲端服務資訊安全規範，達到金融服務全民普及與便利性，鼓勵產業創新與預防風險，提升金融服務體系的韌性，善盡社會責任促進永續平衡的金融服務發展。資通安全管理法與國家標準 CNS ISO27001（同 ISO 27001）的架構與要求項目一致，在導入與驗證的過程可以用同一套流程符合兩種要求，對企業而言在建立資訊安全程序之後，就能符合國家標準可說是一舉兩得的做法。

2.3.1 台灣金管會發布金融資安行動方案 2.0

金管會於 2022 年 12 月 27 日發布了「金融資安行動方案」2.0 版 [8]，強化金融機構在雲端運算平台上的資安防護能力，確保金融系統營運的安全和不中斷，並提供民眾安心的交易環境。用以引導金融資安持續精進，針對雲端運算平台相關的控管要點如圖 4，有以下重點：

1. **擴大資安長設置，定期召開資安長聯繫會議：**金管會要求銀行和一定規模以上的金融機構設置資安長，並規劃定期召開資安長聯繫會議，以統籌資安政策推動和協調資源調度。
2. **增修訂自律規範以因應數位轉型和網路服務開放：**金管會將修訂自律規範，參考國際標準，建立網路身分驗證（eKYC）的運作機制，區分信賴等級，並將與第三方服務提供者（TSP）業務合作的風險評估和管理納入自律規範。
3. **深化核心資料保全及營運持續演練：**因應重大的資安事件和天然災害風險，金管會將鼓勵重要的金融機構強化核心資料保全機制，包括核心資料檔案、資料庫加密和分持，以及儲存於第三地或雲端備份等機制。同時，金管會也將規劃資安攻防、核心業務系統備援演練指引，以驗證金融機構在關鍵時刻的運作效能。
4. **擴大導入國際資安管理標準及建置資安監控：**金管會將推動金融機構擴大導入國際資安管理標準，強化資安監控措施，提升金融機構的資安防護能力。

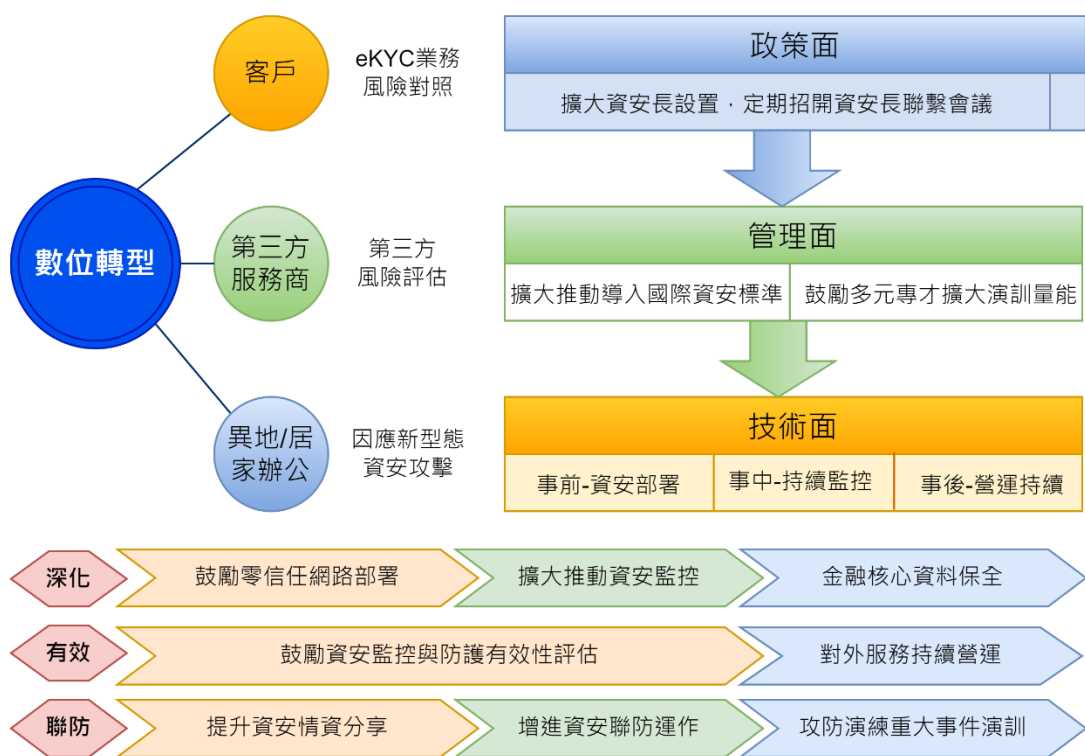


圖 4、金融資安行動方案 2.0 推動藍圖

(來源：金管會)

2.3.2 台灣金管會雲端資訊服務委外作業規範修訂

金管會於 2023 年 3 月 8 日預告召開公聽會並修正了「金融機構作業委託他人處理內部作業制度及程序辦法」[9]，考量國際監管法規趨向以風險基礎方法（Risk-Based Approach, RBA）修正，對委外作業建立完整的風險管理框架。近期金融機構積極導入新的雲端運算科技，進行數位轉型和增加金融業務的彈性。以下整理了與雲端運算平台相關的要點：

- 資料安全控管**：金管會修正的制度及程序辦法，對於金融機構在使用雲端運算平台時的資料安全控管要求，在雲端平台上採取適當的加密措施才能儲存和傳輸資料，雲端供應商不得有存取客戶資料的權限，注意敏感資料個人隱私保護，資料備份與還原程序等。
- 合約管理**：對於金融機構委託他人處理內部作業的情況，修正的制度及程序辦法中，要求金融機構與雲端運算服務供應商簽訂明確的合約，約定雙方的責任和義務，約定服務品質保證機制，包括服務可用性、故障恢復時間、服務支援等。
- 存取控制與身分認證**：金融機構在使用雲端運算平台時，確保適當的存取控制和身分認證機制，只有經授權的人員可以存取敏感資料，並使用強大的身

分認證方法，如多因素身分認證，以保護系統避免未經授權的存取，還要定期審核人員異動和更新權限設定。

4. **監控與風險評估：**金融機構在使用雲端運算平台時，進行監控和風險評估。這包括監控系統的活動，檢測任何異常行為或潛在的安全風險，並定期評估雲端服務供應商的安全性能和合規性。
5. **安全事件回應：**金融機構使用雲端運算平台時，制定適當的安全事件回應計劃，確保即時識別、報告和應對任何安全事件，以減少損害並恢復正常運營。

表 2、金融機構作業委託他人處理內部作業制度修正草案

作業項目	現行制度	修正草案
一般委外事項	免申請核准 §4	免申請核准 §4
其他經主管機關核定得委外之作業項目	應申請核准 §5	首案經本會核定後，其他金融機構逕行辦理 §5
信用卡發卡及消費性貸款之行銷	應申請核准 §11	免申請核准 §11
應收債權催收作業	應申請核准 §12	免申請核准 §12
跨境委外	應申請核准 §18	僅重大性消費金融業務資訊系統，委託至境外處理，應申請核准 §18

(來源：金管會)

表 3、金融機構作業委託他人處理內部作業制度調整重大性定義

現行規範	修法後
原重大性標準訂於§19-2 第 2 項，適用雲端委外申請案件之判斷。	修正後委外辦法採風險為基礎之委外管理框架，重大性之判斷適用各類型之委外案件，增訂於修正草案§4 第 5 項(文字酌修)。
前項所稱具重大性之作業，係指下列情形之一： 一、受託作業如無法提供服務或有資訊安全疑慮，對金融機構之業務營運有重大影響者。 二、受託作業涉及客戶資料安全事件，對金融機構或客戶權益有重大影響者。 三、其他對金融機構或客戶權益有重大影響者。	本辦法所稱之重大性，係指下列情形之一： 一、委外作業無法提供服務或有資訊安全疑慮，對金融機構之業務營運有重大影響者。 二、委外作業涉及客戶資料安全事件，對金融機構或客戶權益有重大影響者。 三、其他委外作業對金融機構或客戶權益有重大影響者。

(來源：金管會)

金管會針對金融機構業務委外辦法修正草案如表 2，調整判斷重大性委外案件的定義，規範修改前後差異說明如表 3。未來金融業者的非重大、非消金業務、非境外業務委外處理，可免除逐項事先報備申請核准。預計最快 2023 年 9 月修法後正式上路，協助金融業者加速導入雲端運算、搭配 AI 工具創新服務的商機。

2.3.3 台灣金融機構運用新興科技雲端安控規範

依照 2017 年 8 月金管會提供「金融機構運用新興科技作業規範」第二條「雲端服務安全控管」，以下整理雲端資安控管的要點 [10]：

1. **雲端資訊安全政策**：金融機構應制定明確的雲端資訊安全政策，規範相關的安全控制措施和作業程序。該政策應詳細說明雲端服務的使用範圍、資料存取權限、加密要求、風險評估和監控要求等。
2. **雲端服務供應商評估**：金融機構在選擇和使用雲端服務時，應評估供應商的資訊安全能力和可靠性，包括供應商的資訊安全政策、技術措施、數據保護措施、漏洞管理和應急回應能力等。
3. **雲端資料分類與保護**：金融機構應根據資料的敏感性和重要性，對雲端資料進行分類，並確定對應的保護措施，包括數據加密、存取控制、資料完整性驗證和備份等。
4. **資料隱私與合規性**：金融機構在使用雲端服務時應確保符合相關的資料隱私法律和合規要求，確保用戶同意、個人資料保護、跨境數據轉移的合法性和監測等。
5. **安全監控和事件回應**：金融機構應實施適當的安全監控機制，以及建立有效的事件回應計劃，包括即時監控雲端資源的使用情況、異常活動的檢測和警報、安全事件的追蹤和調查，以及適當的回應和恢復措施。
6. **安全漏洞管理**：金融機構應建立定期的安全漏洞管理機制，包括漏洞掃描、弱點評估、修補和更新管理。及時識別和修補漏洞，以減少潛在的風險。

2.4 資訊安全國際標準規範與合規性

雲端運算的特色在於雲端服務的連結，提供給廣大的使用者存取雲端服務。遵循國際化的標準，不但能使服務間的串聯更為順暢安全，還可以讓服務的使用者更為安心。以下引用黃正傑 [4] 跟黃振楠/林永修/王瑞祥 [11] 整理，雲端運算資安管理及國際標準規範說明如表 4。

表 4、雲端運算資安管理及國際標準規範

標準規範名稱	制定組織與核心內容說明
Cloud Security Alliance Guidance	雲端安全聯盟(CSA)發佈 Cloud Controls Matrix，評估和管理雲端供應商安全框架，包含一系列控制目標，和實現合規性指南
NIST SP 800-144/53	美國國家標準與技術研究院 NIST 的電腦安全資源中心 CSRC，發表一系列資訊安全相關、公眾雲隱私指引，提高企業創新及科技競爭力
ISO/IEC 27000 系列	國際標準組織(ISO)提出資訊安全標準，27001 驗證 ISMS 規範，27002 資安作業實施要點，27003 實作 ISMS 指引，27004 量測風險，27005 資訊安全風險管理指引，27006 驗證機構要求，27007 稽核指導綱要，27033 網路安全標準，27034 應用程式安全，27017 指導雲端供應商和客戶間安全控制，27018 保護公有雲資料隱私，27701 隱私資訊管理標準
ISO 22301 BCMS	國際標準組織(ISO)發表企業持續營運管理需求 Business Continuity Management System
ISO/IEC 29001	國際標準組織(ISO)針對資訊科技領域，如何保護個人資料的指引文件，適用於自然人及組織
ISO 31000	風險管理實作原則及指引，依據 AS/NZS 4360:2004 為藍本，配套標準 ISO/IEC 31010 風險管理評鑑及 ISO Guide 73 風險管理詞彙，著重在企業風險管理
BS 10012:2009 PIMS	英國標準協會(BSI)發表個人資料保護 Personal Information Management System 機制
Standard of Good Practice	資訊安全論壇(ISF)涵蓋資安治理、資訊洩漏、雲端計算主題，相容 ISO/IEC 27001、遵循 PCI DSS 及 SOX
Organization for Economic Cooperation and Development	經濟合作暨發展組織 OECD，提出隱私與個人資料保護指引，其中 Part2 國家應用八大原則，廣被各國組織納入保護個資立法內容，惟此指引文件本身並不具備法律約束力

(來源：黃正傑)(來源：黃振楠/林永修/王瑞祥)

2.4.1 ISO/IEC 27000 系列國際標準

隨著近年來資安個資外洩事件、駭客攻擊手法翻新，雲端運算使用越來越盛行，企業開始重視資訊安全及風險控管。台灣經濟部標準局依據 ISO/IEC 27001 制定 CNS 27001「資訊技術-資訊安全-資訊安全管理系統-要求事項」，依據 ISO/IEC 27002 制定國家標準 CNS 27002「資訊技術-資訊安全-資訊安全管理之作業規範標準」，分別於 2006/2007 年公告成為資安驗證的國家標準 [11]。

2.4.1.1 - ISO/IEC 27001：2013

依據國際標準組織 ISO/IEC 27001：2013 國家級資訊安全管理作業規範，具備機密性、完整性與可用性三大要素，其中附錄有 114 個控制，分為 14 群，35 個控制分類 [12]。以組織管理流程為導向，基於風險管理架構進行政策、人員、技術的資訊安全控管，搭配使用風險控制項目 A.5 至 A.18 說明如表 5。



表 5、ISO/IEC 27001 資安管理作業規範控制要點

項目	控制項目	控制措施
A5	資安政策	確定並實施雲端資訊安全政策，包括隱私保護政策和相關目標，以確保雲端資訊安全的方向和承諾。
A6	資安組織	建立組織架構和相關職責，確保雲端資訊安全的責任和權限得到明確分配和執行。
A7	人力資源安全	實施相應的措施，確保在雇用、培訓和離職等人力資源流程中考慮到雲端資訊安全的需求。
A8	資產管理	確定和評估雲端資訊資產，並確保適當的保護措施，包括分類、擁有者責任和資產追蹤
A9	存取控制	確保有效的身份驗證和授權機制，限制對雲端資源的存取和操作，並監控存取活動。
A10	加密防護	實施適當的加密措施，保護雲端資料的機密性和完整性。
A11	實體與環境安全	確保適當的實體安全措施，包括設施的選址和保護、設備的安全處理和維護。
A12	作業安全	確立和實施安全的作業程序和相應的控制，以確保雲端運算的安全性和持續性。
A13	資通安全	保護雲端資料的傳輸，包括加密和適當的網路保護措施。
A14	系統建置、開發與維護	確保雲端系統的安全設計、開發、測試和維護，並控制系統變更和漏洞管理。
A15	供應商控管	評估和管理與雲端供應商的合作關係，包括合約和服務水準協議，以確保供應商符合資訊安全要求。
A16	資安事件管理	確立相應的資安事故管理程序，包括事件檢測、報告、調查和應變。
A17	資安控管服務維持計劃	建立和執行適當的營運持續管理計畫，以應對雲端資訊安全事件和緊急情況。
A18	法規遵循性	確保遵守相關的法規、合約和內部政策，並定期進行合規性審核和評估。

(資料來源：ISO/IEC 27001)

2.4.1.2 - ISO/IEC 27017：2015

使用 ISO/IEC 27017:2015 國際標準，考量雲端供應商和雲端客戶之間關係，做為選取雲端服務資訊安全性控制的規範，基於 ISO/IEC 27002 雲端特定實作指導方針，提供額外七個新的雲端控管機制如下 [13]。

- 在雲端計算環境中共享角色和責任
- 在合約終止時將雲端服務客戶的資產移除並歸還

- 保護和分離客戶虛擬環境與其他客戶的環境
- 符合業務需求的虛擬機器硬化要求
- 雲端計算環境的管理操作程序
- 讓客戶能夠監視雲端計算環境中的相關活動
- 對虛擬和實體網絡實施安全管理的一致性

ISO/IEC 27017 的控制項目，針對雲端服務客戶和雲端服務提供者提出建議，有些是兩者共通項目，雲端客戶和雲端服務提供者制定政策考量的差異如表 6。

表 6、雲端客戶和雲端服務提供者制定政策考量的差異

雲端服務客戶	雲端服務提供者
雲端客戶應該針對雲端運算規範資訊安全的政策，包含資訊與其他資產可接受安全風險等級，制定政策考量： ➢ 儲存於雲端運算環境，而可能被雲端服務提供者存取與管理的資訊。 ➢ 如應用程式等可以在雲端運算環境維護的資訊資產。 ➢ 可以在多租戶雲端環境執行的程序 ➢ 使用雲端服務的情境 ➢ 客戶端具有特權的管理者 ➢ 客戶資料的地理位置分布	雲端提供者應該加入雲端服務提供的資安控管內容，制定政策考量： ➢ 設計與實作雲端服務的基礎資訊安全需求 ➢ 內部授權人員的風險 ➢ 多租戶與雲端服務客戶之隔離 ➢ 雲端服務提供者員工對於雲端服務客戶的資訊資產之存取情況，以及存取控制程序 ➢ 在變更時通知客戶 ➢ 對於服務客戶帳號的生命週期管理對於客戶資料的保護 ➢ 協助調查與鑑識的事件資訊提供與分享

(本研究整理)

2.4.1.3 - ISO/IEC 27018：2019

國際標準 ISO/IEC 27018:2019 是一項針對公有雲環境下保護個人可識別資訊（PII）的安全標準，其重點在於確立公有雲端運算環境中的隱私原則，提供常用的控制目標、控制措施和實施要點 [14]。

(1) 控制目標：

ISO/IEC 27018 的主要目標是保護公有雲環境下的個人可識別資訊（PII）的隱私權。它強調了公有雲端服務提供者在處理 PII 時應遵循的控制和標準，以確保個人資訊的安全性和隱私。

(2) 控制措施：

ISO/IEC 27018 包含一系列控制措施，以確保公有雲端服務提供者對 PII 的適當保護。這些控制措施涵蓋了多個方面，包括資訊安全政策、資訊安全事件管理、供

應商管理、使用者存取控制、資料儲存與處理、資料傳輸保護等。

(3) 實施要點：

- 建立適當的資訊安全政策和隱私政策，明確界定對 PII 的保護措施，並向相關利害關係人進行溝通和教育。
- 建立資訊安全事件管理流程，及時應對可能導致 PII 洩露或損害的事件，並進行相應的調查和回應。
- 確保供應商的合規性，監督並管理供應商 PII 處理活動，是否符合標準要求。
- 實施使用者存取控制，確保只有授權人員才能存取 PII，限制權限及存取範圍。
- 儲存和處理 PII 時採取適當的安全措施，包括數據加密、身份驗證、鑑別控制等，以防止未經授權的訪問和洩露。
- 在 PII 傳輸過程中使用加密技術，確保 PII 在傳輸過程中的保密性和完整性。
- 定期進行資訊安全審查和測試，確保標準的實施和運作有效性。
- 向客戶提供清晰明確的隱私通知，告知 PII 處理的目的、範圍和條件，並尊重客戶的隱私權。

2.4.1.4 - ISO/IEC 27005：2022

國際標準 ISO/IEC 27005:2022 提供資訊安全、網路安全與隱私保護-對管理資訊安全風險的指引 [15]，但是不提供任何特定風險管理的方法論。企業應該依據（Information Security Management System, ISMS）的範圍、組織的全景、營運的特性及目標等因素，選擇適合的風險管理方法。ISO/IEC 27005 是 ISO/IEC 27001 跟 ISO/IEC 27002 的配套標準，支持 ISO/IEC 27001 的 ISMS 需求，以風險管理的基礎完整實現資訊安全的要求。

ISO/IEC 27005 的流程遵循「規劃 Plan、執行 Do、查核 Check、改善 Act」的 PDCA 模型。黃振楠/林永修/王瑞祥 [11] 將資訊安全風險管理搭配各個階段活動與 ISMS 流程互相校準，整理 ISMS 資訊安全風險管理與 PDCA 流程對應關聯如表 7。

表 7、ISMS 資訊安全風險管理與 PDCA 流程對應關聯

PDCA 流程	資訊安全風險管理活動
規劃（Plan）	全景建立 風險評鑑 風險處理計畫 風險接受
執行（Do）	執行風險處理計畫
查核（Check）	持續監督及審查風險因子
改善（Act）	維護與改善資訊安全風險管理流程

(來源：ISO/IEC 27005)

2.4.1.5 - ISO 31000:2018

國際標準 ISO 31000:2018 [16] 為風險管理指引 (Risk management- guidelines)，是 ISO 國際標準組織公告的標準，目的是提供風險管理的原則及通用指引，適用於各類型不同規模的組織，例如：公部門、企業、協會、團體、甚至個人，都可以參考此標準來管理整體組織的風險，或是個別專案流程、產品服務、或特定資產之風險。ISO 31000 採用 PDCA 的流程循環，定義了 11 項基本原則。

1. **全球觀**：風險管理應該融入組織的所有層面和活動，並與組織的目標和策略相一致。
2. **參與和共識**：風險管理應該涉及所有相關的利益相關者，並確保他們的參與和共識。
3. **簡便性**：風險管理應該是一個簡單、有效的過程，避免過度複雜化。
4. **自訂**：風險管理應該根據組織的需求和上下文進行定制，避免盲目套用模板。
5. **客觀性**：風險管理應該基於客觀的證據和分析，而不是主觀的意見或偏見。
6. **連續性**：風險管理應該是一個持續不斷的過程，以應對不斷變化的風險環境。
7. **確定性**：風險管理應該識別和評估潛在的風險，並確定可能的結果。
8. **透明度**：風險管理的過程和結果應該是透明的，向相關利益相關者進行溝通。
9. **審核和改進**：風險管理應該進行定期審核和改進，以確保其有效性和適切性。
10. **綜合**：風險管理應該與組織的治理、策略、計劃和流程相整合，並形成一個統一的框架。
11. **共鳴**：風險管理應該能與其他相關的風險管理進行協調整合，確保整體效果。

依據風險管理的 11 項原則，進行宣誓與承諾，開始管理風險架構的設計，實施風險管理架構，然後進行監測與審查，針對風險管理架構持續改進。風險管理的過程，經過溝通與諮詢，建立組織全景前後環節，開始進行風險評鑑，包含風險鑑別、風險分析、風險評估，接著進行風險處理，然後將風險監控與嚴重性審查，回饋給組織全景，持續修正風險管理過程。以下參考蘇江村 [17] 資安風險評鑑標準，說明 ISO 31000 風險管理原則、架構及過程的關係如圖 5。

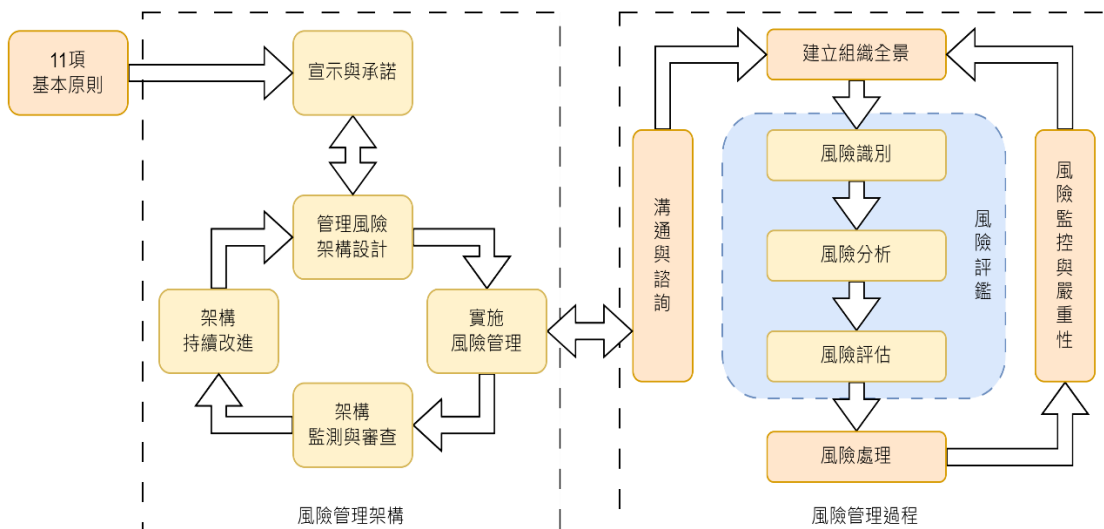


圖 5、ISO 31000 風險管理原則、架構及過程的關係
(來源：蘇江村)

2.4.2 NIST SP 500/800 系列國際標準

依照美國國家標準暨技術研究院（National Institute of Standard and Technology, NIST）的官方定義，雲端運算是一種模型，普遍方便使用，依據所需存取網路可配置計算資源及資源共享池，以最少的管理工作量能夠快速配置和釋放資源。雲端運算服務應當具備五種基礎特性 [18]：

- 用戶可以自助式佈建各種雲端服務，只需為實際使用的資源付費。
- 廣泛的網路存取範圍遍及全球，將服務放在接近其服務對象的地理位置。
- 雲端服務資源集中多用戶共享（multitenant），但是環境是隔離的，沒機會接觸到其他雲端用戶的資料。
- 雲端服務如果流量突然增加，能自動增加網頁伺服器來因應，在流量回歸正常模式時將多餘的伺服器自動刪除，快速有彈性容易調節。
- 雲端業者根據需求提供服務，客戶可自行評估、隨時調整需要付費的資源容量。

2.4.2.1 - NIST SP 500-292

依據 NIST SP 500-292 提出的雲端運算模型參考架構如圖 6，定義五種雲端角色說明如下 [19]。

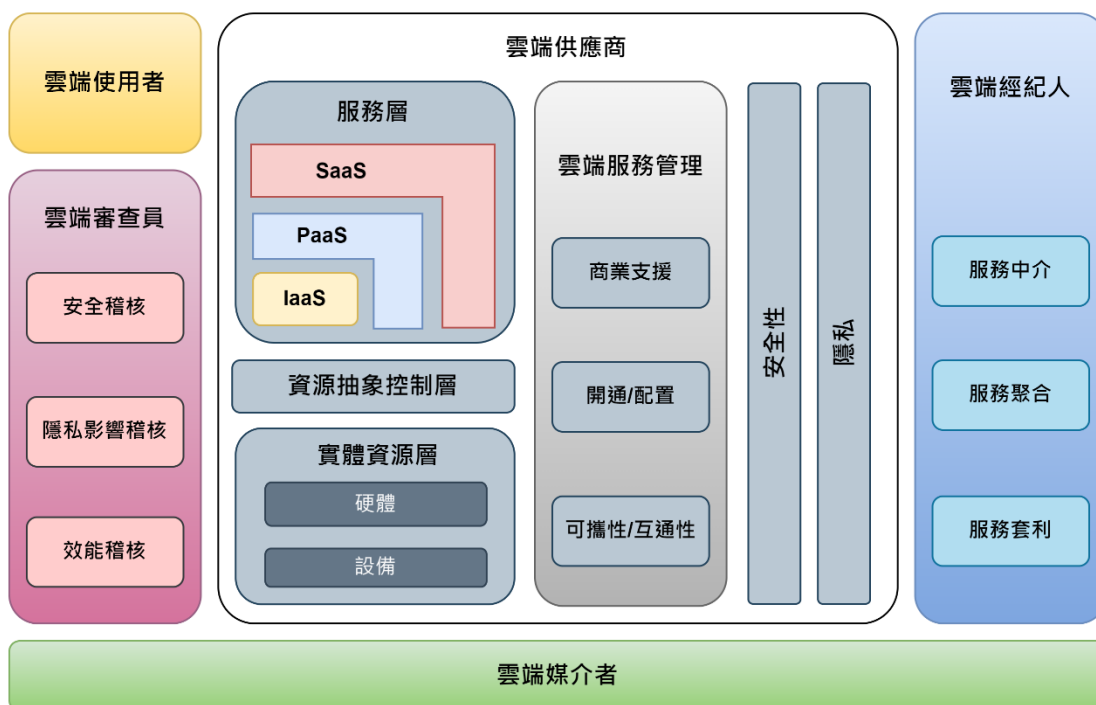


圖 6、雲端運算模型參考架構
(來源：NIST SP 500-292)

1. **雲端使用者 (Cloud Consumer)：**雲端使用者是指使用雲端服務提供的資源和應用程式的個人或組織。他們是最終的服務使用者，可以根據自己的需求選擇合適的雲端服務。
2. **雲端服務供應商 (Cloud Provider)：**雲端服務供應商是提供雲端基礎設施、平台或軟體服務的組織。他們負責管理和維護雲端基礎設施，並向雲端使用者提供可按需使用的服務。核心角色雲端供應商，提供下列服務：
 - 提供虛擬化的基礎設施、平台或軟體服務。
 - 確保雲端服務的可用性、可擴展性和安全性。
 - 監控和管理雲端基礎設施的運作。
 - 與雲端使用者協商並簽訂服務合約。
3. **雲端審查員 (Cloud Auditor)：**雲端審查員是獨立的實體，負責評估和驗證雲端服務供應商的安全和合規性。他們對雲端環境進行監察和稽核，以確保合規性和風險管理。
4. **雲端經紀人 (Cloud Broker)：**雲端經紀人是充當雲端服務使用者和雲端服務供應商之間的中介機構。他們提供雲端服務的選擇、協調和整合，以滿足使用者的需求。
5. **雲端媒介者 (Cloud Carrier)：**雲端媒介者是提供與雲端服務相關的網絡連接和通信基礎設施的組織。他們負責連接不同的雲端服務供應商和雲端使用者，

實現數據和應用程序的可靠傳輸。

2.4.2.2 - NIST SP 800-39

NIST SP 800-39 是美國國家標準與技術研究院（NIST）發布的一項特別出版物，名為《管理信息安全風險：組織、使命和信息系統視圖》（Managing Information Security Risk: Organization, Mission, and Information System View）。該項特別出版物的目的是提供一個統一的、整體性的指導，用於管理聯邦信息系統的運營和使用所帶來的對組織運營（即使命、職能、形象和聲譽）、組織資產、個人、其他組織以及國家的信息安全風險，本出版物所描述的信息安全風險管理指導是對更全面的企業風險管理（ERM）計劃的補充 [20]。

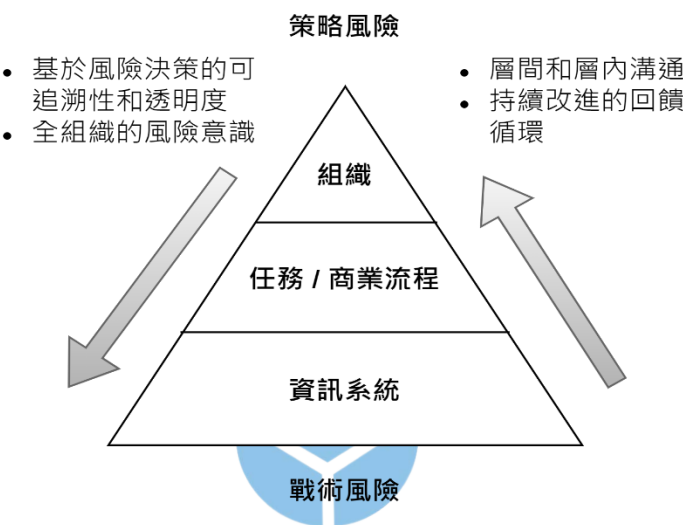


圖 7、多層次組織層級風險控管

圖 7 (來源：NIST SP 800-39) 提供多層次組織層級風險控管架構，以下說明風險管理的要點：

1. **綜合性風險管理方案：**NIST SP 800-39 旨在提供一個綜合性的風險管理方案，用於管理聯邦資訊系統運營，和使用所帶來的對組織營運（即使命、職能、形象和聲譽）、組織資產、個人及其他組織的影響，甚至於整個國家的資訊安全風險。
2. **組織範圍：**該方案涵蓋整個組織，包括其使命、職能和業務操作。風險管理要點考慮了組織內部和外部的多個利益相關者，以確保資訊安全風險管理的綜合性和全面性。
3. **風險評估：**方案強調風險評估的重要性。風險評估是識別和評估可能影響組織目標的威脅、弱點和風險的過程。它包括對資訊系統的安全性和敏感性進行評估，並確定潛在的風險和漏洞。
4. **風險回應和監控：**NIST SP 800-39 提供針對已識別風險的回應和監控的指導。這包括制定和實施相應的風險緩解措施、安全控制和持續監控機制，以減輕風險並及時應對新的風險。

5. **組織的責任和角色：**明確說明組織在風險管理中的責任和角色。它強調了領導層的關鍵作用，包括制定資訊安全風險管理策略、分配資源、建立風險意識和培訓員工。

2.4.2.3 - NIST SP 800-144

雲端安全和隱私是持續性的工作，NIST SP 800-144 主要討論《公有雲端運算的安全及隱私指南》Guidelines on Security and Privacy in Public Cloud Computing [11]，組織應評估和調整相對的控制措施，因應不斷變化的威脅和風險。說明各個不同領域的控制要點及注意事項如表 8。

表 8、NIST 對雲端運算的安全及隱私的建議

領域	控制要點事項
治理	建立明確的雲端治理策略和流程，包括資產管理、風險管理、供應商評估和合規性監控。了解雲端供應商的責任和義務，以及雲端運營的風險和應對計劃。
法規遵循	雲端服務遵循適用的法規、法律和標準，包括資料隱私、個人訊息保護和敏感資料處理。審查雲端供應商明訂合約需求，瞭解供應商的法律責任，監控合規性要求。
信任	選擇信任的雲端供應商，包括評估其安全性、穩定性和可視性。查詢雲端供應商的安全認證，增強對供應商的信任，實施最佳安全控管。
架構	確保雲端架構設計安全，包括網路隔離、存取控制和身分驗證機制。考慮多層防禦和安全分割架構，最小化潛在攻擊。
身分存取管理	實施強固的身分驗證和授權措施，限制使用者和應用程式的權限。定期評估使用者權限，僅授予必要的存取權限。
軟體區隔	確保雲端環境中不同的軟體實例之間做適當的隔離，以防止跨實例的攻擊。結合容器化或虛擬化技術，提高軟體區隔的安全性。
資料保護	加密敏感資料，確保資料在傳輸和儲存過程中的安全性。敏感資料的處理和儲存，遵循最佳實踐讓資料受到保護。
可用性	與雲端供應商協定服務級別（SLA），定義可用性目標和故障恢復措施。確保雲端關鍵服務的高可用性，防止服務中斷和故障，能夠在預期時間內恢復運作。
事件應變	建立完善的雲端事件應變計劃，包括事故監控、漏洞管理和應急回應。定期進行演練和測試，確保應變計劃的有效性和及時性。

(來源：NIST SP 800-144)

2.4.2.4 - NIST SP 800-53

NIST SP 800-53 是一項名為《信息系統和組織的安全與隱私控制》（Security and Privacy Controls for Information Systems and Organizations）的指南。該指南提

供了一系列安全和隱私控制，用於保護聯邦信息系統和組織的機密性、完整性和可用性 [21]。

常見的控制單元和對應的控制要點如下：

- **存取控制 (Access Control)**：身份驗證和認證要求、授權要求、存取控制策略和流程。
- **系統和通信保護 (System and Communications Protection)**：加密要求、安全配置管理、網路隔離和分段要求。
- **風險評估 (Risk Assessment)**：風險評估策略和過程、資訊系統和組織的脆弱性評估要求、風險管理計畫和措施。
- **安全意識培訓 (Security Awareness Training)**：安全意識培訓計畫和資源、安全意識培訓的監控和評估。

NIST SP 800-53 安全跟隱私階層式控制的概念，說明如下：

- **控制單元 (Control Family)**：將安全控制分組為不同的控制單元。每個控制單元代表了一組相關的控制，旨在保護特定的資源或實現特定的安全目標。例如："資訊保護策略和程序"是一個控制單元，其中包含多個與制定和實施組織內部資訊保護政策和程序相關的控制。
- **控制目標 (Control Objective)**：每個控制單元都有一個或多個控制目標。控制目標描述了該控制單元旨在實現的具體安全目標。例如：與"資訊保護策略和程序"控制單元，其中一個控制目標是確保組織內部資訊保護政策的制定和實施。
- **控制要點 (Control Requirement)**：每個控制目標都有相應的控制要點。控制要點提供了實現控制目標所需的具體要求和措施。它們描述了組織應該如何實施和操作相關的安全控制。例如：與"資訊保護策略和程序"單元內相關的控制目標，其中一個控制要點是確保組織內部資訊保護政策的內容，涵蓋適用的法律、法規和合約要求。

2.4.2.5 - NIST SP 800-125

依據 SP 800-125 完全虛擬化技術安全指南(Security Recommendations for Server-based Hypervisor Platforms)，說明虛擬機器隔離性、虛擬機器監控、鏡像和快照的管理，從 Hypervisor 安全、虛擬機器安全、虛擬化基礎設施安全和桌面虛擬化安全分析，提供執行計畫和落地步驟參考。說明控制目標、控制項目及控制要點說明如下[22]：

(1) 控制目標 (Objective)：

- **安全性**：確保雲端運算環境中的虛擬化技術具備適當的安全性，以保護雲服

務和資料的機密性、完整性和可用性。

- 隱私保護：確保雲端運算環境中的虛擬化技術能夠妥善處理使用者隱私資訊，並遵守相關的隱私法規和政策。

(2) 控制項目 (Control Areas)：

- 虛擬化管理：涉及虛擬機器管理、資源配置和存取控制等控制措施，以確保虛擬化環境的安全性和穩定性。
- 虛擬機器安全：包括虛擬機器的安全配置、虛擬機器映射的安全性、虛擬機器間隔離和虛擬機器快照的保護等，以確保虛擬機器的安全性和隔離性。
- 虛擬網路安全：涉及虛擬網路的安全配置、隔離和保護，以確保虛擬網路的安全性和可用性。
- 虛擬存儲安全：包括虛擬存儲的安全配置、存取控制和資料保護，以確保虛擬存儲的安全性和可靠性。
- 虛擬化安全管理：涉及虛擬化環境的安全管理和監控，包括日誌記錄、審計和事件回應等，以確保對虛擬化環境進行適當的管理和保護。

(3) 控制要點 (Control Objectives)：

- 虛擬機器隔離：確保虛擬機器之間的適當隔離，以防止惡意虛擬機器對其他虛擬機器造成的干擾或攻擊。
- 虛擬機器映射驗證：驗證虛擬機器映射的完整性和合法性，以確保僅可信的映射被載入和運行。
- 虛擬網路安全隔離：確保虛擬網路之間的適當隔離，以防止未經授權的訪問和惡意行為。
- 存儲存取控制：實施適當的存取控制措施，以保護虛擬化環境中存儲資源的機密性和完整性。
- 安全監控和審計：建立有效的安全監控和審計機制，以檢測和回應虛擬化環境中的安全事件和威脅。

2.4.3 PCI DSS 4.0 國際標準

如果在雲端運算服務處理信用卡資料，需要特別注意訊息安全和隱私，因此符合 PCI-DSS (“信用卡行業 - 資料安全標準”) 標準特別重要。標準安全委員會(SSC)針對雲端環境中的支付操作指南，發布“信息補充：PCI DSS 雲端運算指南”(Information Supplement: Cloud Computing Guidelines 3.0) [23]，指南文件說明雲端運算概述，雲端供應商 (CSP) 與客戶之間的關係，雲端供應商及其客戶需要共同承擔責任，客戶有義務確保持卡人的資料得到適當保護。

PCI DSS 雲端供應商蒐集客戶環境調查表，蒐集客戶環境前需要考慮的事項：

- 所收集的資訊類型應與客戶的業務需求以及供應商相關。
- 所收集的詳細程度應適當，以便雙方對所涉及的組件、其使用情況以及管理/安全性負責的人必須清楚地了解。

PCI-DSS 提醒注意事項和要求範圍，可能遇到的挑戰，例如：範圍涉及的組件的識別、特定的 PCI-DSS 控制職責、評估分佈式環境及其複雜性、資料的精確位置、存取資料的人員控管等。雲端環境最小化 PCI-DSS 合規範圍最簡單的方法是：

- 不透過雲端運算保存或處理信用卡資料
- 建立專用於雲端環境的實體基礎設施
- 最大限度地減少在保護信用卡資料方面對供應商的依賴

PCI-DSS 支付卡行業框架，資料安全標準架構如下：

- 建立和維護安全網路和系統
- 保護帳戶資料
- 維護漏洞管理計畫
- 實施強而有力的存取控制措施
- 定期監控和測試網路
- 維護資訊安全政策

2.5 導入雲端運算對營運管理的影響

雲端運算盛行的原因為規模經濟、簡化軟體操作，對企業管理最大的好處是財務面，依據用戶使用量計費(Pay-as-you-go)的商業模式，導入雲端運算對企業營運管理的影響，主要有下列幾個面向 [24]：

1. **成本效益**：雲端運算模式根據實際使用量計費，企業能夠根據需求彈性調整資源、避免高昂的固定成本。仰賴雲端供應商的規模和支援效率，可以降低資源運營和管理的成本。
2. **彈性和可擴展性**：雲端運算提供靈活的資源配置和可擴展性，使企業能夠根據需求快速調整和擴展資源，使得企業容易應付經常變動的工作負載，並提供更好的服務品質。
3. **管理簡化**：雲端供應商負責底層基礎設施的管理和維護，包括硬體更新、軟體安裝和系統監控等。能夠減輕企業的管理負擔，資訊人員能夠專注於核心業務和服務創新。
4. **高可用性和災難恢復**：雲端平台通常具有高可用性和災難復原功能，能夠提供持續的服務和資料保護，有助於企業降低服務中斷的風險，確保業務運營連續性。
5. **全球擴展能力**：雲端平台具有全球的資料中心和服務，使企業能夠快速擴展到不同地區和市場，提供更多的機會和彈性，以擴大業務規模並服務更廣泛的客戶群。
6. **協作和遠端工作能力**：提供雲端協作工具、共享資源和遠端執行能力，對

於跨國公司分散團隊和遠端工作人員來說很重要，能夠促進團隊成員之間的協作和溝通，並提高工作效率。

7. **創新和敏捷性：**雲端運算為企業提供了更大的敏捷性和創新能力。企業可以更快地推出新產品和服務，進行實驗和測試，快速回應市場需求和變化。

導入雲端運算也帶來了新的挑戰，需要注意資訊安全風險、數據隱私和供應商依賴性等。企業在導入雲端運算時應監控維運及管理風險，與雲端供應商建立良好的關係，了解如何開立 7x24 技術支援案件，才能確保不間斷的運營和服務。



第三章 導入雲端運算架構設計

說明雲端運算的基礎框架設計，雲端運算平台及服務的選擇策略，導入雲端服務的移轉方法，以及雲端服務資安政策及風險控管，最後說明雲端服務維運監控與災難復原演練的做法。

3.1 雲端運算的基礎框架

以 Google Cloud Platform 雲端架構基礎框架為例，包含跨職能專家團隊給的建議，提供基礎框架設計和最佳實踐做法，幫助架構師、開發人員、管理員進行設計、高效部署、營運安全、高可靠負載、成本優化、彈性化調整的雲端拓撲架構。該架構框架設計指南，適用於雲端部署應用程式，從本地端遷移到 Google Cloud 的工作負載、混合雲部署和多雲環境，說明 GCP 擴展功能、行業最佳實踐、社群知識和使用者回饋。以下提供參考 Google Cloud Architecture Framework [25] 整理，雲端架構框架分為六類（稱為六個支柱），如圖 8 所示。



圖 8、Google Cloud 雲端架構框架六個支柱
(來源：Google Cloud Architecture)

Google Cloud 雲端架構框架六個支柱，分別說明如下：

1. 系統設計 (System Design)：提供設計建議並描述最佳實踐和原則，可幫助定義雲平台上的架構、組件、模塊、接口和數據，以滿足系統需求，考量的內容：
- 應用系統設計的核心原則
 - 就近選擇地理區域支持業務應用程式
 - 管理雲端資源
 - 選擇和管理計算實例
 - 設計網路基礎設施

- 選擇並實施雲端儲存策略
- 優化雲端資料庫
- 分析雲端資料
- 實施機器學習
- 設計雲端工作負載以實現可持續性

2. 卓越營運 (Operational Excellence)：瞭解如何運行高效運營服務，管理和監控提供業務價值的系統，設定可觀察性、自動化和可擴展性等，使用卓越運營的原則奠定可靠性的基礎，考量的內容：

- 自動化部署
- 設定監控警報和日誌紀錄
- 建立雲端技術支援和升級流程
- 管理容量和配額
- 控管高流量和發布活動
- 建立自動化文化

3. 安全、隱私和合規性 (Security, Privacy, Compliance)：描述最佳實踐，提供實施建議，並解釋一些可用的產品和服務，將工作負載轉移到 Google Cloud，需要評估業務要求、風險、合規義務和安全控制，考量的內容：

- 了解安全原則
- 利用控制管理風險
- 管理資產設備
- 管理身分和存取權
- 實施虛擬主機和容器安全
- 保護網路安全
- 部署應用程式安全
- 管理合規性義務
- 資料保存期及營運主權
- 隱私安全要求
- 日誌記錄和檢測控制



4. 可靠性 (Reliability)：在雲平台設計和操作彈性且高度可用的服務，例如：開發、產品管理、運營和站點可靠性工程 (SRE) 團隊。每個人都必須負責並了解其應用程式的可靠性目標、風險和錯誤預估，考量的內容：

- 了解核心可靠性原則
- 定義可靠性目標
- 監控基礎設施和應用程式服務
- 容錯及高可用性設計
- 設計可靠的營運流程
- 建立有效率的警報
- 定義事件管理流程。

5. 成本最佳化 (Cost Optimization)：提供設計建議並描述最佳實踐，以幫助架構

師、開發人員、管理員和其他雲從業者優化 Google Cloud 中的工作負載成本。控管雲端投資成本並提高商業價值，考量的內容：

- 資源影響成本策略 FinOps
- 監控工具管制成本
- 特定服務成本優化(計算、容器化、無服務器)
- 雲端儲存成本優化
- 資料庫智能分析成本優化
- 網路資源成本優化
- 監控雲端營運成本優化

6. 效能最佳化 (Performance Optimization)：設計和優化雲端工作負載的效能，幫助組織高效營運、提高客戶滿意度、增加收入並降低成本。用戶會體驗到更快的響應時間，可以帶來更高的用戶保留率和更多收入，考量的內容：

- 效能優化流程
- 監控和分析效能
- 運算能力優化
- 儲存空間優化
- 網路傳輸優化
- 資料庫執行計畫優化
- 資料查詢分析優化



3.2 雲端運算平台及服務的選擇策略

如何挑選合適的雲端運算平台及服務類型，評估雲端相關的附加價值、掌握市場的脈動，把握機會適當的時間點將系統遷移上雲端。參考 Jerry [26] 提供「企業上雲端前五大評估要點整理」，彙整雲端運算平台及服務的選擇策略如圖 9，各階段的策略及考量分別說明如下。

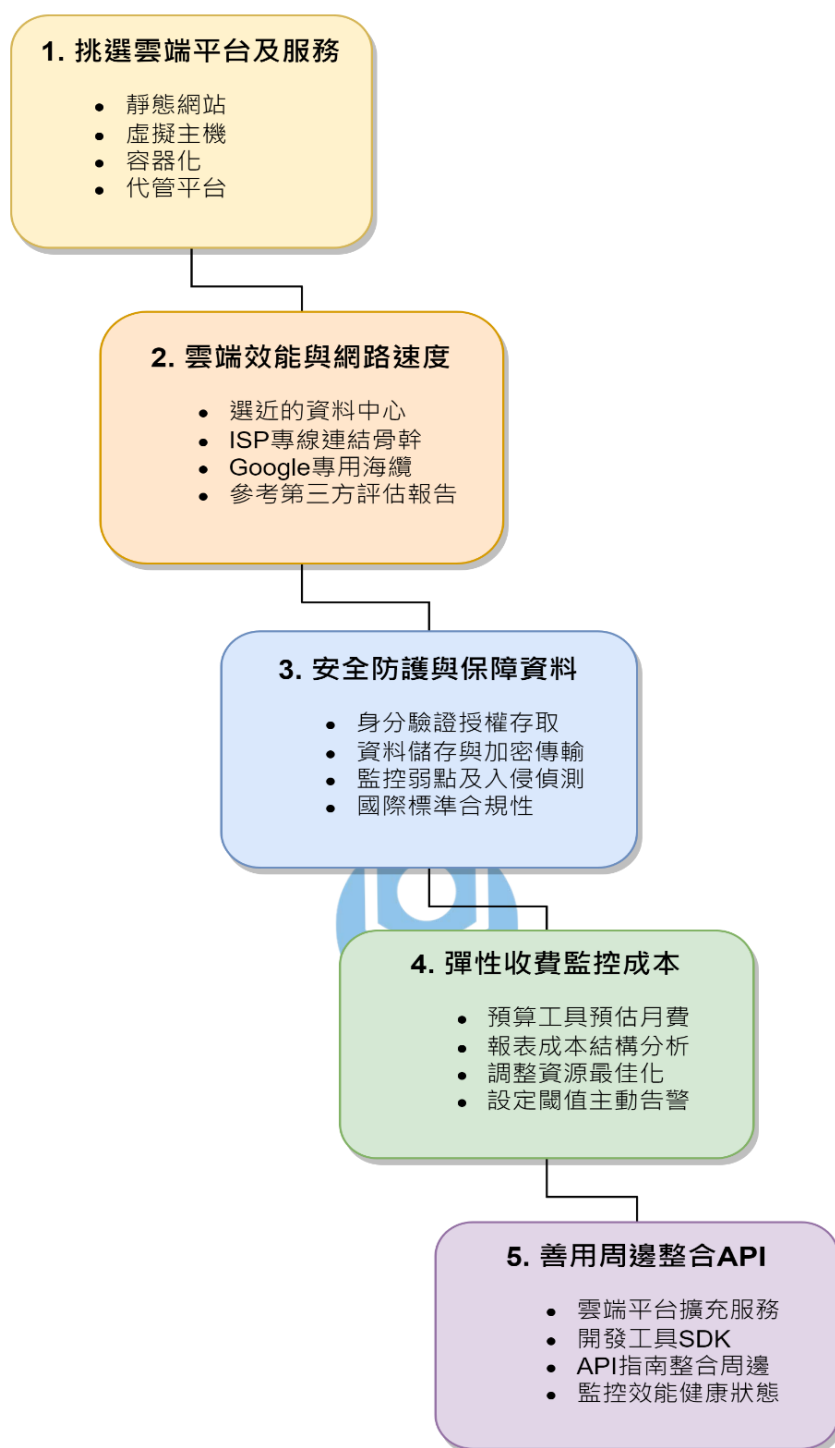


圖 9、雲端運算平台及服務的選擇策略
(本研究整理)

1. 挑選合適的雲端運算平台及服務類型

表 9、Google Cloud Platform 雲端服務類型及應用優勢

服務類型	GCP 對應服務	應用優勢
靜態網站	Google Cloud Storage (GCS)	無限雲端儲存空間，全球各地都能存取，託管靜態網站或圖片庫
虛擬主機	Google Compute Engine (GCE)	快速架設虛擬主機執行個體，提供彈性雲端運算服務及資源配置
容器化	Google Kubernetes Engine (GKE)	Google 開源 K8S 技術，管理大規模容器化服務，不用擔心版本相依性問題
代管平台	Google App Engine (GAE)	提供無伺服器應用程式代管平台，無論複雜的 Web 應用程式，或靜態個人網站都能夠部署

(本研究整理)

客戶選擇 GCP 雲端平台，不同服務的使用情境及優勢說明如表 9。

- 新創公司：使用虛擬主機 GCE 讓開發者有更彈性的開發環境，不會受到雲端 PaaS 平台特定的規格限制，可以自行安裝作業系統版本、第三方應用軟體、管理網路存取設定。
- 遊戲公司：使用容器化技術 GKE，將計算資源的使用效率極大化、服務輕量化，應用程式具備可移植性 Portability，不會被特定廠商綁定容易搬遷，對於突然暴衝或減少的流量，可以彈性地調動資源。
- 人氣餐廳：使用代管平台 GAE 架設專屬餐廳網站，透過 GitLab CI 進行應用程式部署，結合內容管理系統例如 WordPress 快速建立網頁內容，再串接 Google Analytics 分析客戶的年齡層及喜好。

2. 雲端平台的效能與網路速度

各個雲端提供者的資料中心可能有不同的網路連線速度，可以參考供應商的官方文件、網站或相關資源，以了解其網路基礎設施的速度和能力。選擇與您的目標使用者或服務接近的雲端資料中心，以減少網路延遲和提高存取速度。例如：專營東南亞地區的電商網站，可考慮將雲端運算服務開在鄰近的新加坡資料中心。

在地的金融業者可考慮地理區域選擇台灣資料中心，就近服務本地的使用者。透過中華電信或是方電訊，全球骨幹節點直連 Google 雲端資料中心，使用 Google Cloud Interconnect 的私人連線服務，提供更佳的連線可靠性與遞送率，穩定的低延遲連線（POP to POP）。2016/07/01 Google 正式啟用全球最長的 9000 公里超級海纜「Faster」，跨太平洋連結美國、日本、台灣三地，每秒傳輸速度達 60 TBit/s [27]。

參考獨立機構或第三方機構，針對不同雲端提供者的效能評估和報告。這些評估通常會測試不同的應用場景和工作負載，並提供性能和效能的比較數據，使用測試工具和基準測試服務，例如：Apache Bench、Gatling、Loader.io 等，來評估不同雲端平台的效能。還可以模擬不同的負載情境，例如：同時上線的使用者數量、發出請求等，並觀察不同平台雲端資料中心的回應時間和效能。查看其他使用者的使用心得、回饋和意見，例如：在技術論壇、社群網站和社交媒體上的討論，可以提供實際使用情境下的執行效能、網路存取速度的測試結果。

3. 評估安全防護與保障資料

只有經過身份驗證的用戶和授權的服務帳號能夠存取、操作數據和資源，包括多因素身份驗證、存取權限管理、適當的身份和存取控制工具。例如：AWS IAM、GCP Identity and Access Management、Azure Active Directory 等。還要確保資料儲存和傳輸過程中得到適當的加密保護，包括使用 TLS/SSL 協議進行資料傳輸加密，以及提供資料加密和解密服務。例如：AWS KMS、GCP Cloud Key Management Service、Azure Key Vault 等。

搭配適當的防火牆和網路安全措施，以保護資料和資源免受未經授權的存取和網路攻擊。這包括網路分段、入侵檢測和防禦系統、DDoS 攻擊防護等功能。評估供應商是否提供額外的安全服務和工具，例如：網站弱點掃描、安全配置評估、漏洞修補管理等，加強您的安全防護措施。供應商是否能提供安全監控和日誌管理功能，偵測和回應潛在的安全事件和威脅。包括：即時監控、事件記錄和警報、日誌管理和分析工具等。

確保雲端平台符合相關的安全合規性要求，例如：GDPR、HIPAA、PCI DSS 等。最好能夠擁有獨立的第三方國際標準認證和定期審核，例如：通過 ISO 27001，可以提供雲端運算平台安全性的保證。雲端平台是否提供合適的客戶資料保護和隱私措施。包括：明確的資料隱私政策、資料刪除和銷毀策略、遵循個人資料保護法規等。

4. 掌握彈性收費隨時監控成本

使用雲端服務應該制定預算計畫、掌控彈性的計費，獲得最大利益、避免不必要的浪費。AWS、GCP 和 Azure 都提供費用計算器工具，可以根據預估的使用情況評估成本，估算每月用量並挑選合適的付費模式。某些雲端平台允許您透過預留執行個體或預留容量計劃來獲得折扣，這些計劃允許您在預先支付一定費用後以較低的價格使用資源。

雲端平台提供成本監控和報表工具，進行即時監控和分析使用成本。您可以檢視各項服務的費用、用量和趨勢，並生成報表來幫助了解成本結構和優化策略。並透過流量使用記錄，追蹤超出用量的原因並修正使用方式，持續讓效益最大化。建議定期審查相關資源的配置，確保它們符合實際需求。根據工作負載和使用情況，調整資源的大小、容量或數量，以節省成本。

當特定的使用成本超過或接近預設閾值可發出警報通知，或使用自動化工具和腳本來管理資源的啟動和關閉。雲端平台主動透過 Email 郵件或傳送簡訊等方式，通知系統管理者與決策者做開銷控管，以減少不必要的費用。還有一些第三

方工具和服務，例如：CloudHealth、Cloudability 和 Azure Cost Management，可以定期監控和評估，提供更全面的成本管理和優化功能，幫助您更好地監控和控制使用成本。

5. 善用雲端擴充整合周邊 API

現在的雲端平台不是只提供儲存空間或計算資源，舉凡 GCP、AWS、Azure、IBM Bluemix 等雲端服務廠商，都提供琳瑯滿目的 API，各個雲端平台所提供的擴充服務，例如：AWS 的 Lambda、GCP 的 Cloud Functions 和 Microsoft 的 Azure Functions，根據開發者的需求，選擇最適合的服務進行擴充。

熟悉各個平台提供的 API 文件和開發指南，文件詳細描述如何使用、整合各項 API，包括：身份驗證、請求和回應格式、參數和調用方式等。在整合週邊 API 須確保適當的安全性措施，包括適當的身份驗證和授權機制，例如：使用 API 金鑰、OAuth、JWT 等，確保只有經過授權的用戶可以存取 API。採用適當的工具和方法來整合週邊 API，包括使用 RESTful API、SOAP API、Webhooks 等，根據開發者的需求，選擇最適合的整合方式，使用相關 SDK 和開發工具包。

確保正確地整合週邊 API，並處理相關的請求和回應，使用測試工具和日誌分析工具，監視和驗證整合結果的正確性。在整合過程中，設定監控和日誌記錄來追蹤整合的運行狀態和問題。使用適當的監控工具和服務，例如：AWS CloudWatch、GCP Stack Driver 和 Azure Monitor，來即時監控整合的性能和健康狀態。



3.3 導入雲端服務的移轉方法

從本地端遷移到雲端的過程稱為“雲遷移”，將資料、程序、IT 流程從本地資料中心遷移到雲端資料中心，跟實體搬家的過程很類似。為組織的遷移規劃提供了更大的靈活性，使得企業能夠平衡雲端運算的優勢，與保持對關鍵系統的控制和遵守監管要求的需要。基於 Gartner Research 於 2021 年發表應用程式遷移到雲端的 6Rs 策略 [28]，Amazon 在 Gartner 推出的模型基礎上，推出 7Rs 策略路徑擴展模型圖，以下提供 Allen [29] 整理，如何將本地應用程式遷移 AWS 雲端的七種策略如圖 10 所示。

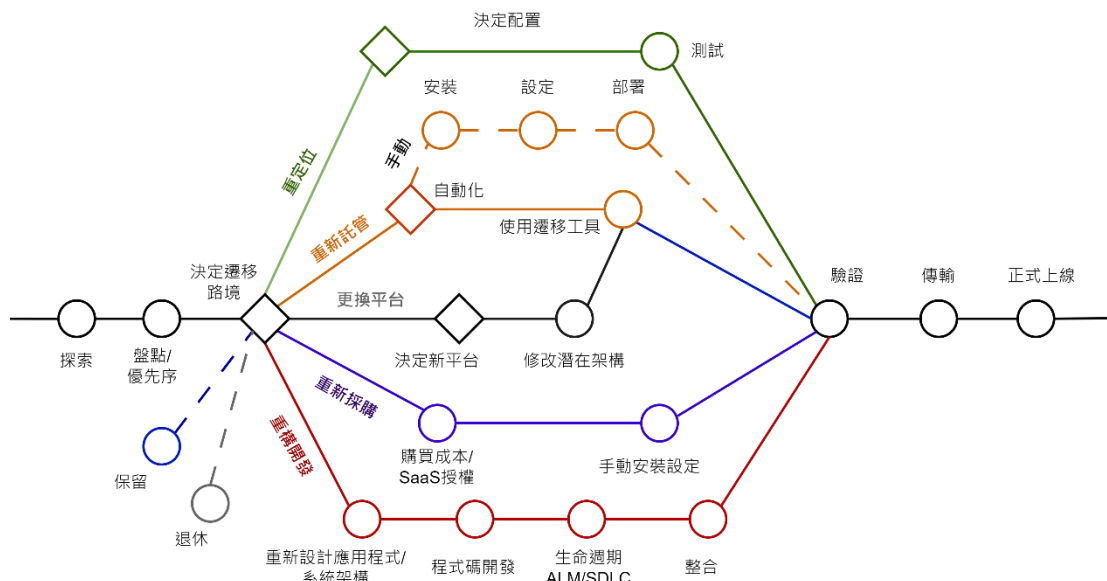


圖 10、應用程式遷移 AWS 雲端的七種策略
(來源：Jonathan Allen, AWS)

將應用程式遷移到雲端的 7Rs 做法是一種評估和決策框架 [30]，用於指導應用程式遷移的不同策略，分別說明如下：

1. 退休 (Retired) 不適用遷移上雲：該應用程式已經過時不再需要，可以完全移除或停用來節省資源，適用於多餘的應用程式或老舊系統。
2. 保留 (Retain) 不適用遷移上雲：該應用程式要保留在現有環境中不打算進行遷移，可能是由於合規性要求、安全性需求或其他特殊原因，需要將應用程式留在地端資料中心。
3. 重定位 (Relocate)：將應用程式移動到不同的雲端環境或基礎設施，考慮將應用程式遷移到不同的雲端供應商，或將地端基礎設施移至雲端環境。
4. 重新託管 (Rehost)：將應用程式不做任何修改的方式移至雲端環境，這種遷移策略通常快速且低風險，但未充分利用雲端提供的功能和優勢。
5. 更換平台 (Replatform)：在遷移過程中，對應用程式進行輕微的修改或重新配置，以最大程度地利用雲端平台的特點，包括對應用程式進行調整、升級或優化，以提高性能和可靠性。
6. 重新採購 (Repurchase)：放棄原有的應用程式，購買新的應用程式系統，或是直接使用雲端提供的服務，可能因為雲端市場已有更成熟、更現代化的解決方案來取代。
7. 重構開發 (Refactor)：對應用程式進行全面的重新設計和重新開發，最大程度地適應雲端環境，可能考慮將應用程式進行微服務化、容器化或使用雲端原生技術，以實現更高的可擴展性和彈性。

參考應用程式遷移到 AWS 雲端的 7Rs 策略，提供 NetApp 資深顧問 Sengupta & Danan [31] 建議，整理不同應用情境及優缺點比較如表 10。

表 10、遷移到 AWS 雲端的五種策略

遷移策略	應用情境	優點	缺點
重定位 Relocate (Hypervisor-Level Lift and Shift)	主要適用於 VMWare 伺服器，和本地佈署 Kubernetes 運行的應用程式	◎最快的遷移策略 ◎遷移的工作負載不須變更作業流程 ◎降低資料中心運營成本 ◎最少的員工培訓	◎限制雲原生功能的數量 ◎PaaS 服務可能很昂貴 ◎幾乎不可能降級實例來節省成本
重新託管 Rehost (Lift and Shift)	希望以少部分成本加速遷移上雲，希望未來還能調整的組織	◎無需昂貴的升級即可提高可靠性和彈性 ◎老舊工作負載能完整移轉 ◎最少的轉移風險	◎導入操作和技術若不相容，影響用戶端體驗 ◎雲原生功能有限
更換平台 Replatform (Lift and Reshape)	考慮遷移上雲，擔心一次性全面遷移老舊應用程式有風險的組織	◎選擇特定功能以獲得最大投資回報率的能力 ◎無需大量培訓 ◎遷移更多工作負載前，IT 能夠查看雲原生功能有效性	◎改變成本高昂且耗時 ◎遷移過程中可能會導致應用程式可用性降低
重新採購 Repurchase (Drop and Shop)	希望利用雲原生功能，不需要從頭開始設計系統的組織	◎快速採用雲原生功能 ◎彈性模式隨用量付費 ◎提供升級功能以實現成本效益	◎由於基礎成本較高，對於低可用性應用程式成本高昂 ◎按照供應商的節奏執行更新和發布
重構開發 Refactor (Rearchitect)	最適合具有高可用性、業務性能需加強優化的複雜應用程式案例，還適合因應法規遵循或外在威脅改變，需要重構應用程式	◎組織能夠實現架構良好的端到端雲原生功能 ◎確保業務連續性 ◎提供個性化級別的自動化、擴展和高可用性	◎需要周密的規劃、預算和執行 ◎依靠廣泛的員工培訓和雲專業知識 ◎需要持續監控以優化成本 ◎管理複雜 ◎不建議在單一虛擬主機遷移大量應用程式

(本研究整理)

3.4 雲端服務的安全基礎藍圖

雲端的採購持續加速進行中，越來越多的企業從公有雲基礎設施調查，開始轉向將正式環境移轉到公有雲的環境內。公有雲的產品從基礎設施即服務（IaaS）、平台即服務（PaaS）到軟體即服務（SaaS），傳統責任界限會跟著客戶選擇的服務範圍而變化，考量關鍵重要的安全主題項目，不同於客戶既有的 On-prem 地端基礎設施自行控管方式，雲端供應商和客戶之間存在著不同比例的共同安全責任範圍。參考 Google Cloud 安全基礎藍圖 [32]，雲端供應商及客戶對工作負載，傳統共享安全責任說明如下：

- **基礎設施即服務（IaaS）**：雲端供應商負責基礎設施，如伺服器、網路和儲存設備；客戶負責管理伺服器及監控日誌，設定防火牆控管裝置存取。
- **平台即服務（PaaS）**：雲端供應商負責平台基礎設施，作業系統及身分驗證；客戶負責管理應用程式安全性，存取記錄、漏洞管理和資料保護。
- **軟體即服務（SaaS）**：雲端供應商負責平台基礎設施維運，提供完整的應用程式服務及監控；客戶負責管理使用者帳戶，用政策控管存取內容。

各家公有雲產品的目錄持續快速地增長，雲端供應商須公開並提供更多的配置條件及控制項目，讓客戶可以依據不同需求自行定義以滿足不同的業務及安全方面的需求。客戶與其雲端供應商，從共同承擔責任轉而成為生命共同體，雲端供應商有責任提出安全基礎藍圖，搭配風險保護計畫及最佳實踐法，透過安全諮詢、威脅情報、測試驗證、託管防禦服務提供進一步協助。

雲端安全不同於本地安全，具有以下特點：

- 基礎設施、產品和服務中的安全性、可見性和控制點存在差異。
- 新的雲原生開發方法有差異，例如：容器化、DevSecOps。
- 新的雲產品和多樣性服務及不同的使用方式，持續快速發展。
- 組織部署、管理和操作系統方式，導致文化跟著轉變。
- 了解客戶和雲端供應商之間的風險，並進行責任分配。

Google Cloud 安全最佳實踐的產品和藍圖組合，提供配置、部署和操作特定服務集的功能、架構和指南。參考 Google Cloud 安全基礎藍圖 Security Foundations Blueprint [32]，建構不同層次安全藍圖的優點及雲端應用範例如表 11。

表 11、Google Cloud 不同層次安全藍圖的優點及雲端應用範例

安全層級	優點說明	雲端應用範例
安全解決方案	解決以下問題： 1.確保特定應用程序、流程或服務的安全性。 2.滿足特定需求的監管和合規性要求（例如：Anthos 的 HIPAA）	1.Web App 和 API 2.保護自主安全操作 3.安全和彈性框架 4.風險與合規即代碼
工作負載安全藍圖和特定服務藍圖	1.工作負載藍圖:確保特定工作負載、應用程序、流程或服務的適當安全狀態。 2.特定服務的藍圖:特定服務的配置、直接安全性和補償控制提供指導。	1.企業雲端儲存體 2.安全資料倉庫藍圖 3.AI Platform Notebook 安全藍圖 4.Anthos 安全藍圖 5.安全的無伺服器藍圖
安全基礎藍圖	為基礎設施、資源、組織策略、身份存取、網路、日誌記錄和檢測提供了安全基線著陸區，使客戶能在安全的基礎建構案例。	1.指導方針 2.儲存庫 3.展示組織
預設安全產品	安全層已預先配置可供使用，安全的設計並且符合各種法規。	1.Security Command Center 進階層 2.保證的工作負載 3. BigQuery+DLP 自動防止遺失保護
核心基礎設施安全	該安全層已預先配置可供使用，是安全的設計且符合各種法規。	1.Google 基礎安全設計 2.BeyondCorp 產品 3.預設靜態加密

（本研究整理）

如何使用安全基礎藍圖 Security Foundations Blueprint，在組織中擔任一個或多個角色的說明：

- **安全領導者**：需了解 Google 雲端安全關鍵原則，及如何應用和實施原則來保護組織的部署。
- **安全從業者**：需了解如何應用安全最佳實踐來設置、配置、部署和操作以安全為中心的基礎設施登陸區的詳細說明，該登陸區可部署工作負載和應用程序。
- **安全工程師**：需要了解如何配置和操作多個不同的安全控制，以便它們能夠正確地相互交互。
- **業務領導者**：需要團隊加快學習和理解 Google Cloud 所需的高級技能，還需要與風險和合規團隊共享 Google 安全參考文件。
- **風險與合規官**：需了解 Google Cloud 可用的控制措施，及如何自動部署這些控制措施，還需要了解控制漂移以及需要額外關注的領域，以滿足業務監管的需求。

參考 Google Cloud 安全基礎藍圖 Security Foundations Blueprint [32]，部署的範例項目及預設的合規性報告如圖 11 所展示，與各種框架進行了比較。其中大多數評估的合規性控制措施都可以作為藍圖的一部分，用來作為監管單位合規性的證明。部分缺少的控制項目需要用戶輸入，才能正確設定日誌記錄，配置相關的 control 項目及報表產出。

3.5 雲端運算資訊安全風險管理

因應金融數位化轉型導入雲端運算服務，來自網際網路的威脅及駭客攻擊手法持續翻新，面對雲端服務平台可能會遭遇幾種挑戰，例如：不熟悉雲端服務運作架構、雲端資安設備與傳統控管架構不同、既有的資安政策無法套用到複雜雲端網路設定、營運模式須配合調整才能搭配新的雲端服務、雲端個人資料與隱私保護的問題、人為設定失誤可能影響對外服務、雲端服務供應商人員異動的權限控管等，都會衍生新的資訊風險需要持續監控並加以防範 [33]。

3.5.1 雲端運算威脅與資安知識及解決方案

2013 年雲端安全聯盟（Cloud Security Alliance, CSA）發表雲端運算服務中最常見的 9 項安全威脅 [34]，分別說明如下。

1. **資料洩漏和資料遺失：**指數據在雲端環境中被洩漏、丟失或受損的風險。這可能是由於不當的資料保護措施、不當的存取權限、技術故障或人為錯誤所引起。
2. **不當使用和存取：**包括未經授權的使用者存取、使用服務超越合法用途的風險。這可能導致資源濫用、數據竊取或系統遭受惡意攻擊。
3. **不當的身份和存取管理：**指使用者身份認證、授權和存取管理的不當或不完整，可能導致未經授權的使用者存取敏感資源。
4. **虛擬化安全漏洞：**指基於虛擬化技術的雲端環境中存在的安全漏洞，可能導致虛擬機器的隔離性遭受破壞，從而影響其他虛擬機器的安全性。
5. **不當配置管理：**包括雲端資源和服務配置錯誤、弱勢設置、未修補的漏洞等，可能導致系統容易受到攻擊或資源不受適當保護。
6. **虛擬機器和服務的惡意使用：**指惡意程式碼或攻擊者在虛擬機器或雲端服務中執行惡意活動的風險。這可能導致數據洩漏、系統崩潰或其他安全事件。
7. **虛擬化基礎設施的共享風險：**指多個租戶共享虛擬化基礎設施可能引起的安全問題。一個租戶的安全漏洞可能影響其他租戶的資源和數據。
8. **不當的刪除管理：**指在移除虛擬機器、儲存空間或其他雲端資源時，不完全或不正確地執行數據的刪除和清除程序，可能導致敏感資料的殘留和潛在的數據洩漏風險。
9. **雲端服務供應商的安全能力：**指雲端服務供應商在安全性方面的能力和實踐，包括安全控制、合規性、可信度和數據保護措施。企業應評估雲端服務供應商的安全能力，確保其符合所需的安全標準和要求。

依據 2017 年雲端安全聯盟所發佈 Security Guidance for Critical Areas of Focus in Cloud Computing v4.0，雲端運算需要考量的 14 個資安相關知識領域 [35]

，分別說明如下：

1. **雲端運算概念和架構** (Cloud Computing Concepts and Architecture)：討論雲端運算的核心概念、架構和部署模型，包括公有雲、私有雲和混合雲。探討雲端服務模型（例如 IaaS、PaaS、SaaS）的安全考量和設計原則。
2. **治理和企業風險管理** (Governance and Enterprise Risk Management)：強調在雲端環境中建立有效的治理結構和風險管理策略。包括風險評估、合規性要求、供應鏈管理和第三方風險。
3. **法律問題、合約和電子查核** (Legal Issues, Contracts, and Electronic Discovery)：關注與雲端運算相關的法律和合約問題，包括隱私權、數據保護、智慧財產權和法律責任。探討在雲端環境中進行電子發現的挑戰和最佳實踐。
4. **合規性和稽核管理** (Compliance and Audit Management)：強調在雲端環境中確保合規性和實施有效的審計控制。包括合規性要求、數據隱私、數據保留和監控。
5. **資訊治理** (Information Governance)：涉及管理和保護雲端環境中的資訊資產和數據的策略和程序。包括資料分類、數據所有權、數據生命週期管理和數據存儲。
6. **管理層面和業務連續性** (Management Plane and Business Continuity)：探討在雲端環境中管理和監控雲端服務的最佳實踐。包括身份和存取管理、日誌管理、事件回應和業務連續性計劃。
7. **基礎設施安全** (Infrastructure Security)：關注保護雲端基礎設施免受威脅和攻擊的措施。包括網絡安全、主機安全、儲存安全和漏洞管理。
8. **虛擬化和容器化** (Virtualization and Containers)：討論在虛擬化和容器化環境中實施安全控制的策略。包括虛擬機器安全、容器安全和虛擬化管理。
9. **事件反應、通知和修正** (Incident Response, Notification and Remediation)：強調在雲端環境中建立有效的事件回應計劃和流程。包括事件檢測、警報、回應和漏洞修復。
10. **應用程式安全** (Application Security)：關注在雲端環境中開發和保護應用程式的安全性。包括安全開發生命週期、軟體供應鏈安全和應用程式漏洞管理。
11. **資料安全和加密** (Data Security and Encryption)：探討在雲端環境中保護數據安全的措施。包括加密技術、數據保護、數據隱私和數據分離。
12. **身份、權限和存取管理** (Identity, Entitlement and Access Management)：強調在雲端環境中有效管理和控制用戶身份和存取權限的重要性。包括身份驗證、授權、多因素身份驗證和存取控制。
13. **安全性作為服務** (Security as a Service)：討論在雲端環境中提供安全服務的最佳實踐，例如遠距威脅檢測、日誌管理和安全監控。
14. **雲端相關技術** (Related Technologies)：涉及與雲端運算相關的新興技術和趨

勢，例如人工智能、物聯網和區塊鏈，以及這些技術帶來的安全挑戰和解決方案。

隨著新的安全性威脅出現，雲端安全機制跟著不斷地進化與調整，因此現在市面上出現許多不同類型的雲端安全性解決方案。以下提供 Google Cloud 雲端安全四種類型的解決方案 [36]。

- **身分與存取權管理 (Identity and access management)：** IAM 服務和工具可讓管理員集中管理及控管哪些人員可存取特定雲端和地端部署資源。IAM 能讓您主動監控及限制使用者與服務互動的方式，然後在整個機構中強制執行政策。
- **資料遺失防護 (Data loss prevention)：** DLP 資料遺失防護功能提供針對受管制的雲端資料，自動進行探索、分類和去識別化的功能，能幫助您清楚掌握自己儲存和處理的資料。
- **安全性資訊和事件管理 (Security information and event management)：** SIEM 解決方案結合安全性資訊和安全性事件管理，能自動監控與偵測雲端環境中的威脅，並提供事件回應。SIEM 工具運用 AI 與機器學習技術，可讓您查看及分析應用程式和網路裝置上所產生的記錄檔資料，並在偵測到潛在威脅時迅速採取行動。
- **公開金鑰基礎架構 (Public key infrastructure)：** PKI 這個架構的用途為透過數位憑證管理安全的加密資訊交換作業。PKI 解決方案通常會為應用程式提供驗證服務，並確認資料在傳輸過程中不會遭駭，也沒有外洩的風險。雲端式 PKI 服務可讓機構管理及部署數位憑證，用於驗證使用者、裝置和服務。

3.5.2 風險管理原則控制措施及解決方案

參考蘇江村 [17] 提出資安風險評鑑標準，依據風險管理原則 (Objective, Risk, Control, and Alignment, ORCA)，採用新方案的改變帶來機會及正面影響，但是創新同時也具備一定風險的負面影響。應該先有明確的目標設定，使得風險管理成為實現企業目標的重要活動。通過識別和評估風險，能夠制定適當的管理控制措施，及減輕風險的影響。保持一致性能夠確保風險管理活動，與企業的整體策略方向相同，並將風險管理融入企業的日常運作決策當中。從四個面向說明風險管理進行的方式：

- **目標 (Objectives)：** 明確定義創造組織價值、資訊管理相關的策略目標，這些目標應該與業務策略和使命相關，並能夠指導風險管理的方向。
- **風險 (Risk)：** 辨認無法達成目標之風險因素，識別和評估可能對企業目標實現的不確定性和威脅，包括對潛在風險的辨識、風險的評估及優先順序、風險的量化和定性評估等。
- **控制 (Control)：** 管理資訊安全、降低或消除風險的控制，包括制定政策和程序、實施控制措施、建立監測和審核機制等，以確保風險得到適當的管理和控制。

- **一致性 (Alignment)**：確認目標/指標、資訊安全風險及控制的一致性，包括將風險管理納入企業的治理結構、與業務部門合作、建立風險文化和意識等。

為了有效管理可能發生的事件及不利影響，以下提供蘇江村 [17] 整理執行資訊安全風險管理循環的四個步驟包含：辨識風險、評估風險、處理風險、監視評估，如圖 12 所示。

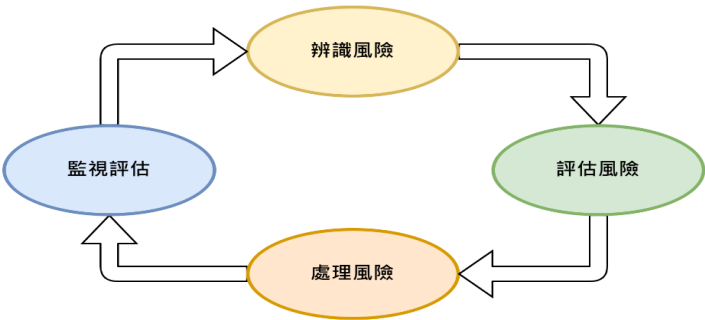


圖 12、資訊安全風險管理循環
(來源：蘇江村)

針對各種可能遇到的攻擊、威脅、弱點及衝擊關聯，提供蘇江村 [17] 所整理不同類型的風險控制措施如圖 13 所示，考慮採用幾種不同的控制措施類型分別說明如下：

- **遏阻型控制**：降低被攻擊的可能性。
- **偵測型控制**：提早發現攻擊、觸發預防型控制。
- **預防型控制**：保護弱點、降低衝擊。
- **矯正型控制**：減少衝擊。

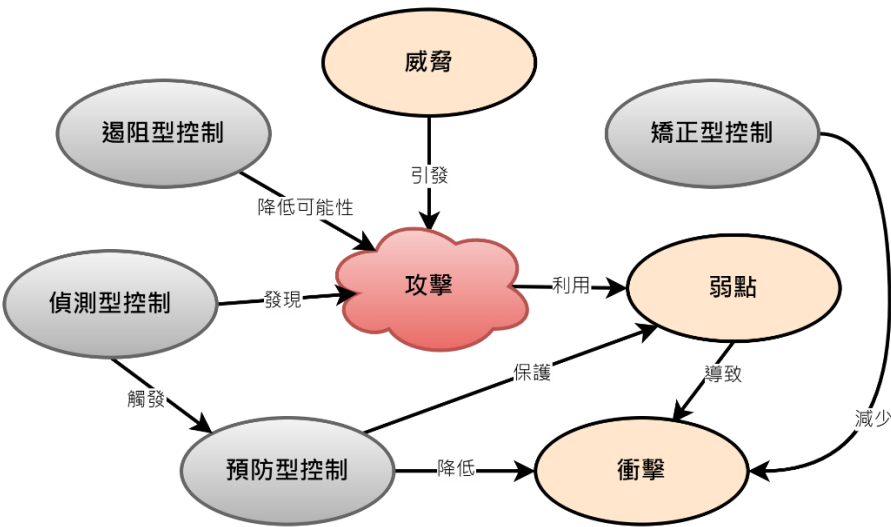


圖 13、不同類型的風險控制措施
(來源：蘇江村)

關於風險處理主要有兩個決策點：評鑑結果及處理結果是否令人滿意？風險處理有四種方式，包括風險修改、風險保留、風險避免、風險分擔等，以下提供蘇江村 [17] 風險處理的進行及選擇流程，如圖 14。

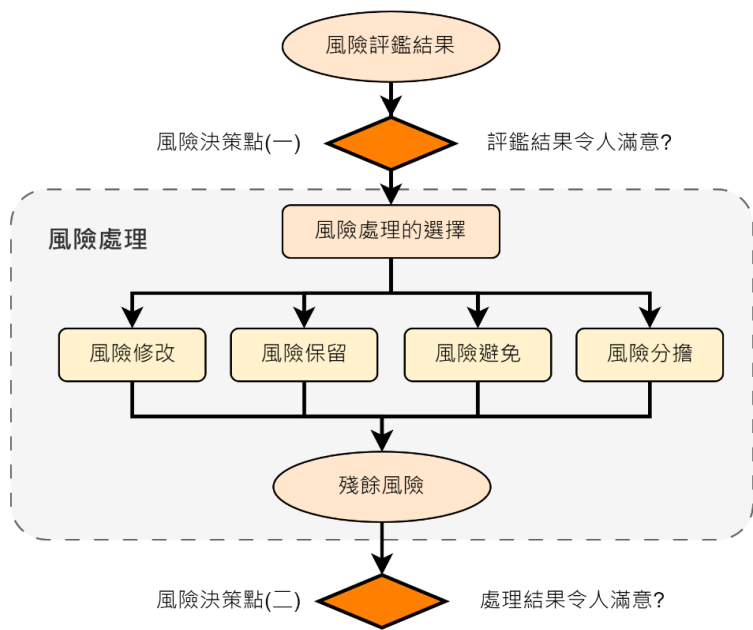


圖 14、風險處理的進行及選擇
(來源：蘇江村)

針對重要資料與資產，以下提供蘇江村 [17] 資訊安全控制層級，區分為管理面、技術面及實體面控制，細節內容說明如圖 15。

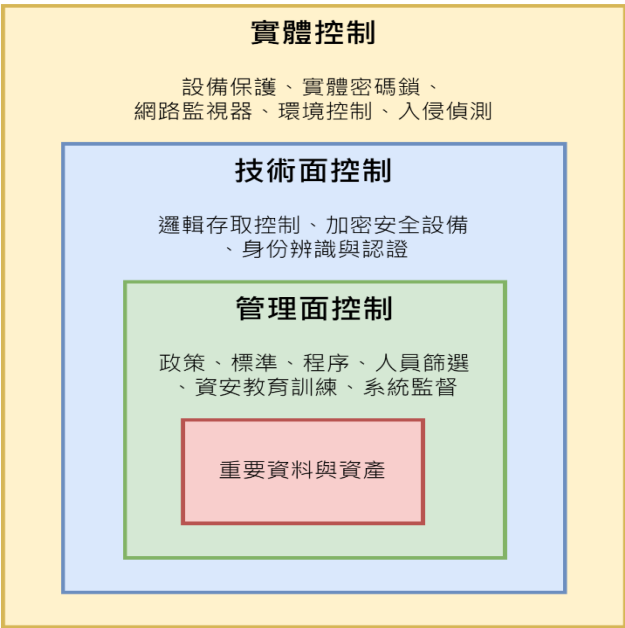


圖 15、資訊安全的控制層級
(來源：蘇江村)

根據雲端安全聯盟（Cloud Security Alliance, CSA）提供雲端控制矩陣 Cloud Controls Matrix（CCM）版本 4.0 工具 [37]，CCM 提供雲端運算安全指標的目錄，用來支持雲端供應商 CSP 內部治理、風險和合規性活動，為服務級別透明度提供有用的基準 [38]。雲端控制矩陣 CCM 所涵蓋的安全領域項目如下：

- 稽核與保證（Audit & Assurance - A&A）
- 應用程式與介面安全（Application & Interface Security - AIS）
- 業務持續管理與運營彈性（Business Continuity Management and Operational Resilience - BCR）
- 變更控制與配置管理（Change Control and Configuration Management - CCC）
- 密碼學、加密與金鑰管理（Cryptography, Encryption & Key Management - CEK）
- 資料中心安全（Datacenter Security - DCS）
- 資料安全與隱私生命週期管理（Data Security and Privacy Lifecycle Management - DSP）
- 治理、風險和合規（Governance, Risk and Compliance - GRC）
- 人力資源（Human Resources - HRS）
- 身份與訪問管理（Identity & Access Management - IAM）
- 互操作性與可移植性（Interoperability & Portability - IPY）
- 基礎架構與虛擬化安全（Infrastructure & Virtualization Security - IVS）
- 日誌記錄與監控（Logging and Monitoring - LOG）
- 安全事件管理、電子發現與雲端取證（Security Incident Management, E-Discovery, & Cloud Forensics - SEF）
- 供應鏈管理、透明度和負責任（Supply Chain Management, Transparency, and Accountability - STA）
- 威脅與弱點管理（Threat & Vulnerability Management - TVM）
- 通用端點管理（Universal Endpoint Management - UEM）

依據 CSA 提出雲端運算服務中最常見的 9 項安全威脅 [34]，提出相關的風險補救措施，搭配雲端控制矩陣 CCM 定期稽核，強化 CSA 資訊安全知識領域 [35]，整理說明如表 12。

表 12、CSA 雲端威脅及風險補救控制矩陣

CSA 雲端威脅	風險補救措施	CCM 控制矩陣	CSA 資安領域
資料洩漏和資料遺失	◎嚴格的 API 存取控制 ◎軟體開發生命週期安全控管 ◎持續監控系統活動 ◎定期備份重要資料 ◎建立緊急應變計劃	DSP-資料安全與隱私生命週期管理 IAM-身份與訪問管理 CEK-密碼學、加密與金鑰管理 LOG-日誌記錄與監控 SEF-安全事件管理、電子發現與雲端取證	D9：事件反應、通知和修正 D11：資料安全和加密 D12：身份、權限和存取管理
不當使用和存取	◎建立雲端安全策略保護資源 ◎正確的配置及變更控制 ◎審查第三方軟體安全及漏洞 ◎檢測 API 程式加密驗證	A&A-稽核與保證 SEF-安全事件管理、電子發現與雲端取證 LOG-日誌記錄與監控 CEK-密碼學、加密與金鑰管理	D3：法律問題、合約和電子查核 D11：資料安全和加密
不當的身份和存取管理	◎多因子身分驗證及金鑰控管 ◎定期更新強化應用程式安全 ◎持續監控避免資料外洩 ◎限制最小存取權限 ◎人員到離職存取權控管	GRC-治理、風險和合規 SEF-安全事件管理、電子發現與雲端取證 IAM-身份與訪問管理 LOG-日誌記錄與監控 HRS-人力資源	D4：合規性和稽核管理 D12：身份、權限和存取管理
虛擬化安全漏洞	◎更新系統最佳化安全基準 ◎使用加密通道傳輸資料 ◎安全弱點工具偵測並修正	IVS-基礎架構與虛擬化安全 CEK-密碼學、加密與金鑰管理 TVM-威脅與弱點管理	D8：虛擬化和容器化 D11：資料安全和加密
不當配置管理	◎應用程式可攜性資料通訊介面 ◎監控記錄應用程式安全事件 ◎實體安全儲存敏感個人資訊 ◎端點安裝修正	IPY-互操作性與移植性 LOG-日誌記錄與監控 DCS-資料中心安全 UEM-通用端點管理	D5：資訊治理 D7：基礎設施安全 D10：應用程式安全 D14：雲端相關技術

虛擬機器和服務的惡意使用	◎網路隔離限制不必要資源存取 ◎僅授權用戶才能存取虛擬機器 ◎日誌即時監控機制檢測不尋常 ◎定期弱點掃描加強預警防護 ◎建立事件管理即時回應舉證	IVS-基礎架構與虛擬化安全 DCS-資料中心安全 LOG-日誌記錄與監控 TVM-威脅與弱點管理 SEF-安全事件管理、電子發現與雲端取證	D8：虛擬化和容器化 D9：事件反應、通知和修正 D13：安全性作為服務
虛擬化基礎設施的共享風險	◎身分驗證加密傳輸並持續監控 ◎安全基準文件做最佳化調整 ◎雲端儲存符合端點的國際規範	IVS-基礎架構與虛擬化安全 DCS-資料中心安全 UEM-通用端點管理	D7：基礎設施安全 D8：虛擬化和容器化
不當的刪除管理	◎監控資料刪除政策與核准程序 ◎看變更核准文件做刪除程序 ◎資料刪除記錄日後能追蹤通報 ◎安全事件應變計畫及雲端蒐證	DSP-資料安全與隱私生命週期管理 HRS-人力資源 LOG-日誌記錄與監控 SEF-安全事件管理、電子發現與雲端取證	D3：法律問題、合約和電子查核 D6：管理層面和業務連續性 D9：事件反應、通知和修正
雲端服務供應商的安全能力	◎每年檢視 SSRM 責任共享矩陣 ◎定義存取流程驗證合理性 ◎資產管理表更新及漏洞補救 ◎評估安全流程和檢測威脅指標	STA-供應鏈管理、透明度和負責任 IPY-互操作性與可移植性 TVM-威脅與弱點管理 DCS-資料中心安全	D1：雲端運算概念和架構 D2：治理和企業風險管理 D13：安全性作為服務 D14：雲端相關技術

(本研究整理)

第四章 個案研究與實務探討

說明金融業導入雲端運算平台的優勢及數位化轉型需求，雲端創新服務應用 - 開放銀行 API 管理平台，金融業雲端資訊安全合規性及未來挑戰。

4.1 雲端運算平台的優勢及數位化轉型需求

相較於傳統 IT 的地端環境，雲端平台架構對於資訊安全領域有著先天優勢 [11]，原因說明如下：

1. **雲端服務供應商的專業性**：因為需要管理大規模的電腦設備，雲端服務供應商有專職的資安團隊，相較於一般中小企業組織更能提供專業的服務。
2. **整體架構穩定度**：雲端運算中的 IT 設備，通常有較高的一致性，有利於系統互通及維護，及提升整體穩定度。
3. **法規遵循性**：雲端供應商因應各種不同法規需求，確保本身於跨境營運時符合各國相關法律規範，通過各種認證。例如：ISO 27001、PCI DSS、SAS 70 等。
4. **營運持續**：虛擬環境中資源動態分配較為彈性，具備備援設計、災難復原、異地備援及資料還原等措施，大幅提升營運能力。
5. **資料集中管理**：以往散落在各地的電腦資訊，得以集中化管理、簡化存取控制措施。

傳統銀行被迫開發創造新的工作，科技的發展促使銀行服務無所不在。金融科技的革命進行中，在危機或轉機抉擇的時刻，如何使用雲端運算進行數位化轉型，強化核心競爭力要點：

1. **數位化轉型策略**：傳統銀行應該制定明確的數位化轉型策略，包括設定目標、確定所需的技術和資源，並建立相關的數位化轉型團隊。
2. **雲端運算科技的應用**：傳統銀行可以利用雲端運算科技來提升業務流程效率，例如使用雲端服務來存儲和管理大量的數據、提供彈性的計算能力，以及構建可擴展的系統架構。
3. **數據安全和隱私保護**：傳統銀行在使用雲端運算科技時需要確保數據的安全性和隱私保護。這包括選擇可信的雲端服務提供商，實施適當的數據加密和存取控制措施，以及遵守相關的法規和標準。
4. **數位金融創新**：傳統銀行可以與新創公司合作，利用其提供的雲端服務和數位技術來推動金融商品的創新和改進。這可以包括開發新的數位支付解決方案、提供個性化的金融服務，以及優化客戶體驗等。
5. **數位化客戶關係管理**：傳統銀行利用雲端運算科技建立強大的客戶關係管理系統，透過數據分析和智能化工具提供個性化服務，並改善客戶忠誠度。

4.2 雲端創新服務應用 - 開放銀行 API 管理平台

台灣金融監督管理委員會（金管會 FSC）於 2019 年 10 月開放銀行業 Open Banking API [39]，主旨在推動開放銀行業 API 的功能發展，提供更多金融產品和服務的資訊，API Management 能夠幫助企業應對更快速的創新與變革趨勢，讓使用者能夠更便利地存取和使用應用程式。

魔力象限是 Gartner 公司使用的評估和比較技術市場中各供應商表現的工具。它將供應商依照其「完整性」（Ability to Execute）和「視覺」（Completeness of Vision）這兩個維度來分類。「領導象限」代表了在市場上表現優越且具有影響力的供應商，在技術執行能力和對市場未來趨勢的洞察均表現出色。參考 2022 年 Gartner 完整生命週期 API 管理平台魔力象限（Magic Quadrant），其中 Google Apigee 居於「領導象限」[40]。因為 Apigee 已經連續 5 年獲得此項榮耀，所以本研究個案決定導入 Apigee APIM 創新服務的解決方案。

Google Apigee 提供私有雲、混合雲及公有雲三種版本，產品功能性較其他供應商豐富，並且具有極佳的易用性，是一個完整生命週期 API 管理平台，能夠協助 API 供應商設計、部署、監控，確保客戶 API 安全及妥善調度。特色包括：

- **全生命周期管理：**Apigee 提供完整的 API 管理生命週期，從設計到退役。
- **安全性與授權：**提供強大的安全性，如存取控制、身份驗證和數據加密。
- **分析和監控：**建分析工具和監控功能，可用於追蹤 API 使用情況、性能和問題排查。
- **開發者體驗：**支援開發者社群建立並管理 API，提供易於使用的工具和文件。
- **多雲支援：**可在公有雲、私有雲或混合雲環境中部署。

由於 2020 年金管會尚未正式開放銀行使用雲端服務，本研究個案前期採用 Google Apigee Edge for Private Cloud (On-premise) 建構私有雲 [41]，這個解決方案同時也支援混和雲 Apigee Hybrid 跟公有雲 Apigee Cloud 的架構 [42]，等待 2023 年金管會法規逐步開放之後，就能夠將地端私有雲環境移轉成為混和雲或公有雲繼續對外服務。

參考 Google Cloud 雲端運算的六個支柱，從各面向挑選三個重要項目考量內容，為架構師、開發人員、管理員提供基礎框架設計最佳實踐做法，本研究個案對於雲端運算基礎框架考量的規劃如表 13。

表 13、GCP 雲端運算基礎框架規劃

雲端運算六個支柱	基礎框架規劃考量內容
1.系統設計	◎就近選擇地理區域支持業務應用程式 ◎選擇和管理計算實例 ◎設計網路基礎設施
2.卓越營運	◎自動化部署 ◎設定監控警報和日誌紀錄 ◎管理容量和配額
3.安全隱私合規性	◎利用控制管理風險 ◎管理虛擬主機和容器安全 ◎管理合規性義務
4.可靠性	◎監控基礎設施和應用程式服務 ◎容錯及高可用性設計 ◎建立有效率的警報
5.成本最佳化	◎特定服務成本優化(計算、容器化) ◎資源影響成本策略 FinOps ◎監控雲端營運成本優化
6.效能最佳化	◎效能優化流程 ◎運算能力優化 ◎資料查詢分析優化

(本研究整理)

本研究個案採用以 API 為優先考量的方式來整合應用程式，讓合作夥伴和開發人員透過 API 存取實用資料和服務，建立新的數位管道和商業模式，根據不同的 API 定義，同時連結不同的周邊應用程式，提高開發人員的工作效率，縮短產品上市時間。考量 GCP 雲端運算平台服務的選擇策略，如表 14 說明。

表 14、GCP 雲端運算平台服務的選擇策略

選擇雲端運算服務	本研究個案應用與規畫方式
挑選雲端平台服務類型	Apigee Edge 私有雲的節點幾乎都安裝在客戶地端環境；Apigee Hybrid 混合雲的管理平台安裝在 Google 雲端，結合 Apigee 服務代管平台，運行平台 Kubernetes 容器化叢集客戶可安裝在地端，且符合 ISO 27001, PCI DSS 國際標準認證。
雲端運算效能與網路速度	選擇 GCP 台灣資料中心(asia-east1)，專用海纜 Google Faster 連接全球網路，搭配第三方監控 Nagios, Splunk, Bench 提供效能評估報告。
安全防護與保障資料	Apigee 從用戶端到後端，提供完整 API 開發安全機制，例如:SAML 驗證、API 金鑰、雙向傳輸安全 TLS 1.2、OAuth 2.0、JWT/JWS 安全性延伸模組、RBAC 角色存取權限控管模型。
彈性收費監控成本	Apigee UI Dashboard 視覺化呈現，讓 API 開發者得知服務狀況，搭配 API Monetization 營利能更具彈性，根據 API 服務使用量追蹤需求，選擇適合的計費方案，打造具競爭力的 API 產品。
善用周邊整合 API	搭配 API 文件指南 SDK 開發工具包，使用 RESTful API、SOAP API、Webhooks 等，整合周邊 API 身份驗證、請求回應格式參數調用，無縫整合 StackDriver 監控日誌，搭配 BigQuery 資料倉儲分析效能、監視健康狀態建議 API 改善。

(本研究整理)

本研究個案以開放式標準為基礎，考量地端雲端混合式並行的方式，控管 Kubernetes 叢集維護及處理 API 流量，整合 API 生命週期的開發人員入口網站資源，讓合作夥伴及開發人員能夠輕鬆、安全地存取 API。導入雲端服務的移轉方法，如表 15 說明。

表 15、導入雲端服務的移轉方法

雲端遷移策略	服務移轉方法
重定位（Relocate）	考慮以開放式標準為基礎的雲端代管服務，將地端虛擬主機服務，參考範本打包容器映像檔封裝軟體，就能移轉到 Kubernetes 容器化叢集，將虛擬主機的管理跟應用程式的生命週期管理做分離，將作業自動化並專注在應用程式開發。
更換平台（Replatform）	針對應用程式進行微幅調整與配置，Apigee Hybrid 利用地端跟雲端混合並行的方式，使用 Apigee API 平台進行 API 設計、實作和部署。
重構（Refactor）	將應用程式進行重新設計與開發，進行微服務化、容器化，以適應雲端環境，設計 API 生態系統互動模式及應用，針對流程和技術進行改造。

(本研究整理)



4.2.1 開放銀行法規的遵循

從英國開放銀行、歐洲 PSD2 (支付服務指令)，再到澳洲 CDR (消費者資料權)，要求金融機構必須遵守嚴格的高強度驗證及安全通訊規定。Apigee Open Banking APIx 是個加速器，能夠符合開放銀行法規遵循 (Compliance)，讓金融機構能以更簡單快速又安全的方式，短時間內導入開放銀行法規的 API，迅速抓住廣大的 API 經濟商機。

- 加快開放銀行法規遵循的速度
使用預先設定的 API Proxy 來驗證及保護金融通訊
- 擴展屬於合作夥伴與客戶的生態系統
透過 Apigee Open Banking APIx 開發人員入口網站，快速安全分享資料
- 同時促進內部與外部創新
運用預先整合的 OAuth 安全性架構，為內部應用程式或第三方供應商提供不同的存取模式

4.2.2 Apigee API 的安全機制

Apigee 從用戶端到後端，提供一連串完整的開發安全機制，確保 API 服務在每一個階段都能得到更高層級的保護。為此，Apigee 在連結用戶端上支援許多開箱即用的安全機制、在 API 開發上提供了威脅防護政策、在後端提供使用者權限控管 ACL 與警示，讓 API 開發者能夠建立更安全的 API 服務。

Apigee 使用 SAML 做為 New Edge UI 與開發人員入口網站服務的驗證機制，確保只有符合資格的使用者與應用程式能夠存取 API。透過雙向式傳輸層安全標準 (TLS) 1.2、API 金鑰及 OAuth 2.0，在使用者存取資料和系統時驗證使用者。使用 JWT 及 JWS 的進階安全性延伸模組，設定多重驗證與授權。採用角色存取控管模型 (RBAC)，為使用者建立專屬的安全身分並連結至識別資訊提供者。

4.2.3 Apigee Developer Portal 開發者網站

Apigee 提供全面性且可客製化的 Developer Portal，能讓 API 供應商建立屬於自己品牌的介面。互動式的說明文件使第三方開發者能在 Developer Portal 上快速找到符合自己需求的 API 產品，API 金鑰驗證讓 API 產品能夠兼具安全性，數據分析功能更優化 API 服務，Apigee Developer Portal 使第三方開發者更迅速且安全地使用 API 服務，進而創造 API 服務更多新的商機。Apigee 的部署機制包含上版、下版、過版機制，這些機制皆是 zero-downtime 部署，並且這些部署動作皆可以藉由 Apigee UI、Apigee API 來達成。荷蘭銀行 ABN [43] 客製化開發者網站 Apigee Developer Portal 的範例如圖 16。

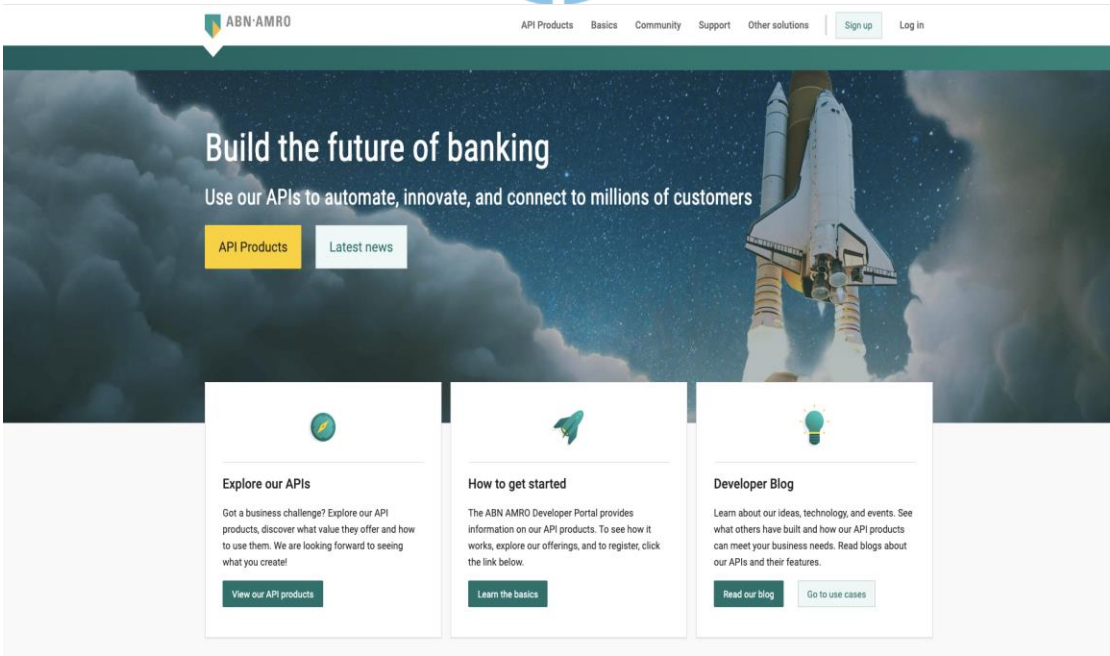


圖 16、荷蘭銀行 Apigee Developer Portal
(來源：荷蘭銀行 ABN)

4.2.4 Apigee API 監控管理機制

Apigee 提供 API 監控管理機制，能讓 API 開發者監控 API 流量且建立警報並在觸發異常警示後通知，讓 API 開發者在系統被影響之前能夠採取適當的行動。API 監控管理機制自動且全面的功能，能增加 API 可用性並降低平均診斷時間，讓 API 開發者更快速診斷並調查錯誤、效能、以及延遲問題。此功能需要啟用 Apigee 特定的 Java 服務或搭配第三方服務。

Apigee 允許您在事件失敗而發生錯誤時，將警報轉發到 syslog 或外部監視系統/工具，這些警報可以是系統級別或應用程序級別的警報/事件。視需要設定相關的閾值 Thresholds 若超過閾值就發出警報，並且能跟客戶既有監控系統 (例如: Nagios, Collectd, Graphite, Splunk, Sumologic, and Monit) 對接做觀測 [44]。

Apigee 利用 API Proxy 收集統計了用戶端到後端的詳細資料，讓這些資料能透過 Apigee UI Dashboard 視覺化呈現給 API 開發者，透過這些圖表能更便利的知道目前 API 服務的狀況，以及更迅速地進行問題診斷。另外，也可以使用 Apigee API 來下載資料供進一步的問題調查，整理測試結果的報表如圖 17。

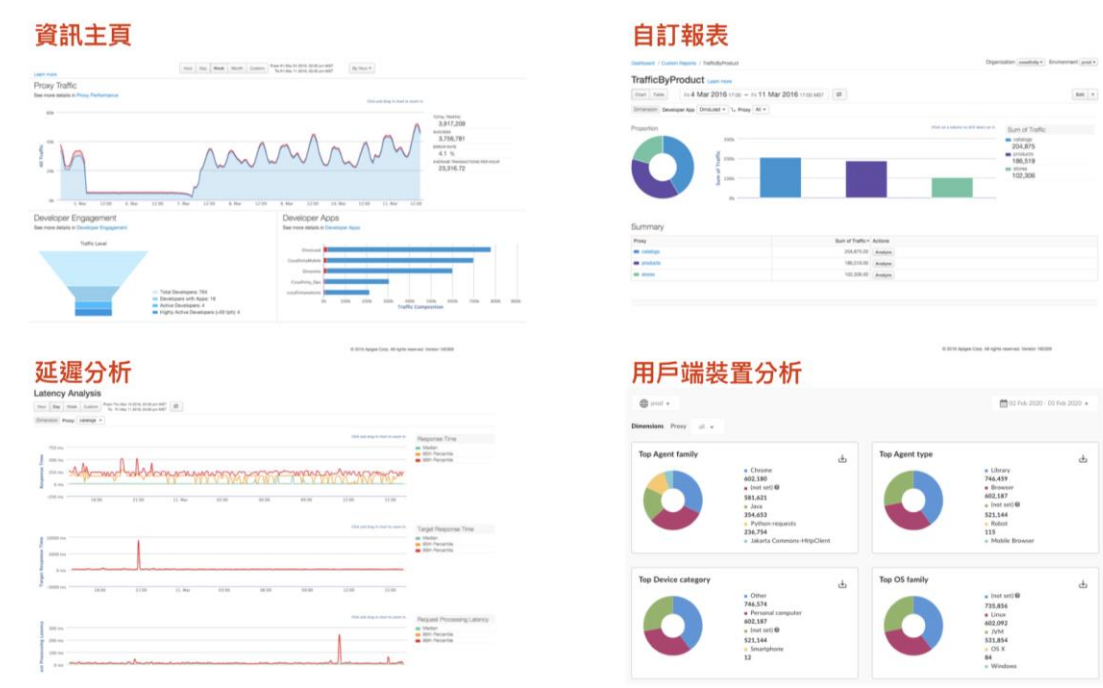


圖 17、Apigee API 開發生命週期圖表化呈現
(本研究整理)

4.2.5 Apigee API Monetization 營利收費

Apigee 提供了許多計費的方式，使用 API Monetization 營利收費 [45] 能更具彈性，如圖 18 所示區分為四種模型，讓第三方開發者可以根據 API 服務使用量的需求，選擇適合的計費方案。

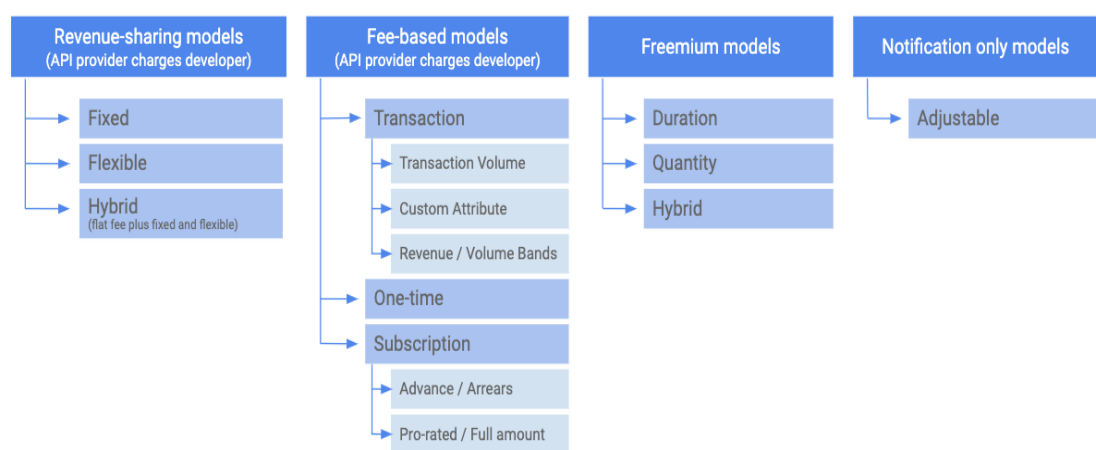


圖 18、使用 Apigee API 營利彈性計費的方式
(本研究整理)

另外 Apigee 也提供了 API 使用量的追蹤，讓 API 開發者能夠更了解 API 應用服務在市場的趨勢，讓組織可以有效地進行 API 的收費管理。特色說明如下：

- 多樣化的價格模型：Apigee 支援多種不同的價格模型，例如計次收費、訂閱制、按用量計費等，使組織能夠根據其業務需求選擇最適合的價格策略。
- 自動化的計費和結算：Apigee 可自動追蹤 API 的使用量，並根據事先設定的價格模型進行計費和結算，減輕了手動處理的工作量。
- 付款閘道支援：Apigee 整合了付款閘道，使得客戶可以方便地進行付款，並保護敏感的付款資訊。
- 報告和分析：提供即時的報告和分析工具，讓組織能夠追蹤 API 收入、客戶消費情況，並做出相應的調整。
- 彈性的價格設定：針對不同客戶或用途設定不同的價格，以滿足個別需求。
- 方便的整合：與現有的結算、CRM 系統等進行整合，實現無縫的業務流程。

4.2.6 Apigee Edge 私有雲系統元件及關聯

Apigee Edge [46] 提供不同種類的服務，包含 API Gateway Services、API Management Services、Developer Services、Analytics Services，各個元件之間的關聯圖，細部功能說明如圖 19。

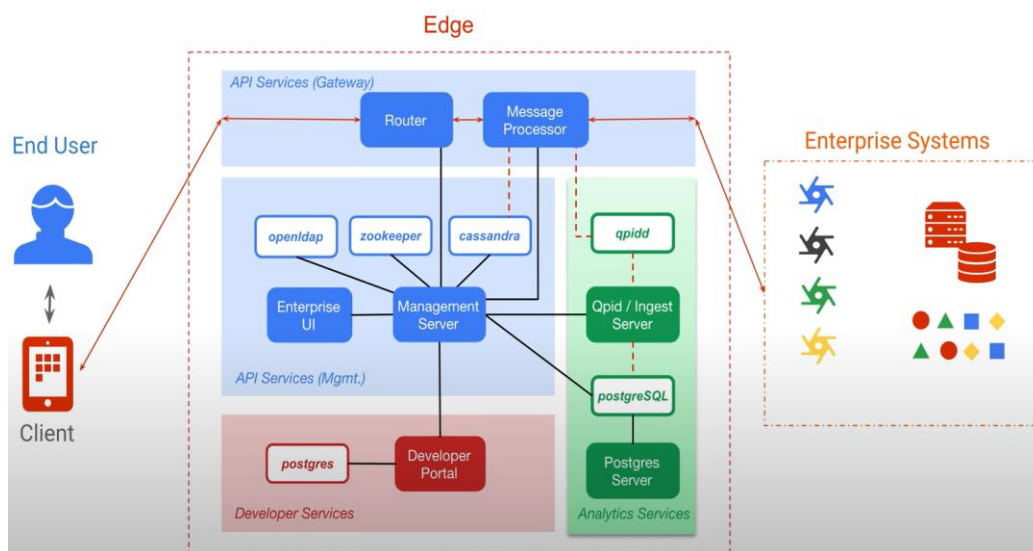


圖 19、Apigee Edge 元件關聯圖
(本研究整理)

- Router：路由器分派所有進來的 API 流量，終止 HTTP 請求、處理 TLS / SSL 流量，引導到適當的訊息處理器。
- Message Processor：訊息處理器評估傳入的請求，執行任何 Apigee 策略，並呼叫後端系統存取資料。
- Management Server：管理伺服器提供中央控管 API，用來和每個地端版安裝的元件進行溝通。
- Cassandra：Gateway 執行應用程式，儲存應用程式設定，分散式配額計數器、API 金鑰及 OAuth 權杖。
- ZooKeeper：各種 Apigee 組件的位置和配置的資料，並向不同的服務器通知設定變更。
- OpenLDAP：用來管理組織用戶和角色。
- QPID：管理分析數據的佇列系統。
- Postgres：管理 PostgreSQL 的分析資料庫，和 Developer Portal 開發人員用的 PostgreSQL 是分開的。

Apigee Edge 的架構當中提供 Gateway、Management Server、Developer Portal、Edge UI、Analytics Backend 等服務，前端可以搭配負載平衡 Enterprise Load Balancer，後端可以連接企業內部的系統。

4.2.7 Apigee Edge 私有雲叢集節點架構

正式環境建議採用叢集架構 [46] Clustered Installation for PROD (6+2 nodes for PROD in DC1)，準備另一組叢集做備援 Clustered Installation DR (6+2 nodes for DR in DC2)，於不同資料中心採用 VMware 虛擬主機安裝節點，整理主機功能如圖 20。



圖 20、Apigee Edge 雙備援資料中心叢集節點架構
(來源：Google Apigee Edge for Private Cloud)

安裝 Apigee Edge for Private Cloud，主機連外存取 Internet 網路防火牆需求 [47]。關於網路區段配置 Zoning 如圖 21，建議方式 Client (Internet) -> NLB (DMZ) -> API gateway (App Zone) -> Backend Services (App Zone) -> ESB/SOA (Internal Zone)，若有需要 API Gateway 也可以改放在 DMZ，搭配防火牆可自訂 Port Number [47]。

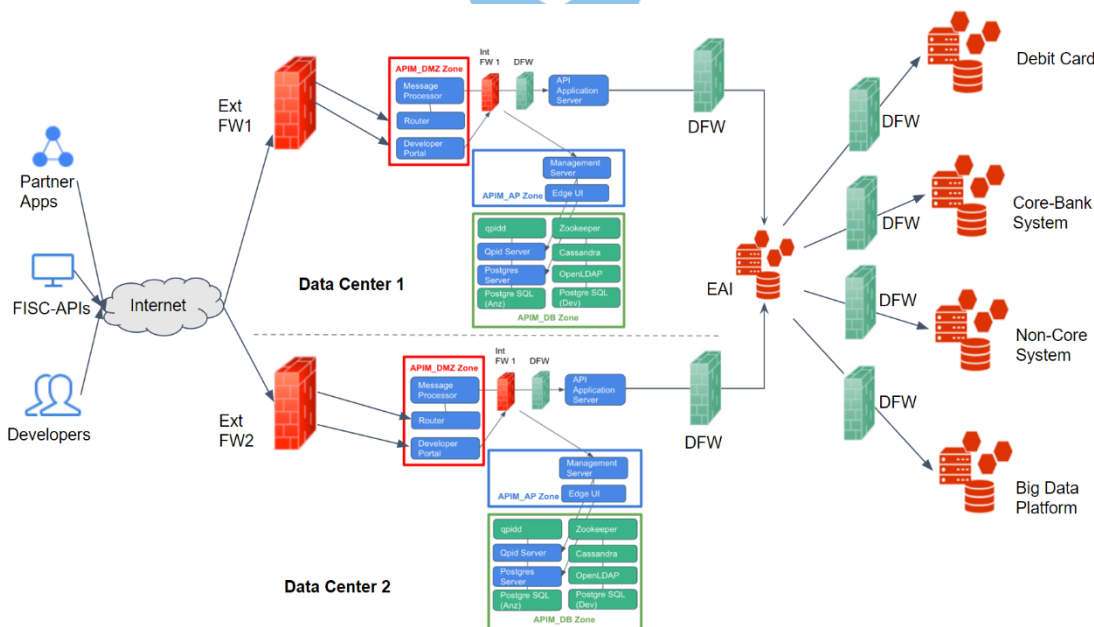


圖 21、正式環境 APIM 備援與周邊系統整合架構圖
(本研究整理)

本研究個案正式環境 PROD 跟備援環境 DR，分別坐落在兩個不同的資料中心，採用雙主動叢集服務架構 Active-Active Mode Cluster Services，其中的資料庫會自

動同步抄寫到另一資料中心 DC (PROD->DR)，搭配負載平衡 Load Balancer 分散流量到 Gateway 並導到後端服務 Backend Services。

當正式環境 PROD 有問題，仍可以將前端 Request 導到備援環境 DR，確保服務的高可用性，確保災難復原處理能夠正常運作。當虛擬主機發生問題時先重開機一次，如果重啟無法解決問題，系統管理員先詢問主管，經核准後才進入系統還原程序。透過既有的機制還原虛擬主機的作業系統 (例如：透過 VMware 磁碟快照還原 VM Guest)，透過網路能夠正常存取儲存設備內備份的資料，管理員依據系統維護手冊裡面的程序來進行還原。

4.2.8 Apigee Hybrid 混合雲系統架構

Apigee Hybrid [48] 由 Google Cloud 維護的雲端管理平台（Management plane），支持客戶自行安裝 Kubernetes 的運行平台（Runtime plane）所組成。結合 Google Cloud Platform 雲端平台服務做身分驗證、權限控管、監控和紀錄，應用程式透過運行平台能夠存取後端服務，提供 Apigee Hybrid 高階架構如圖 22。

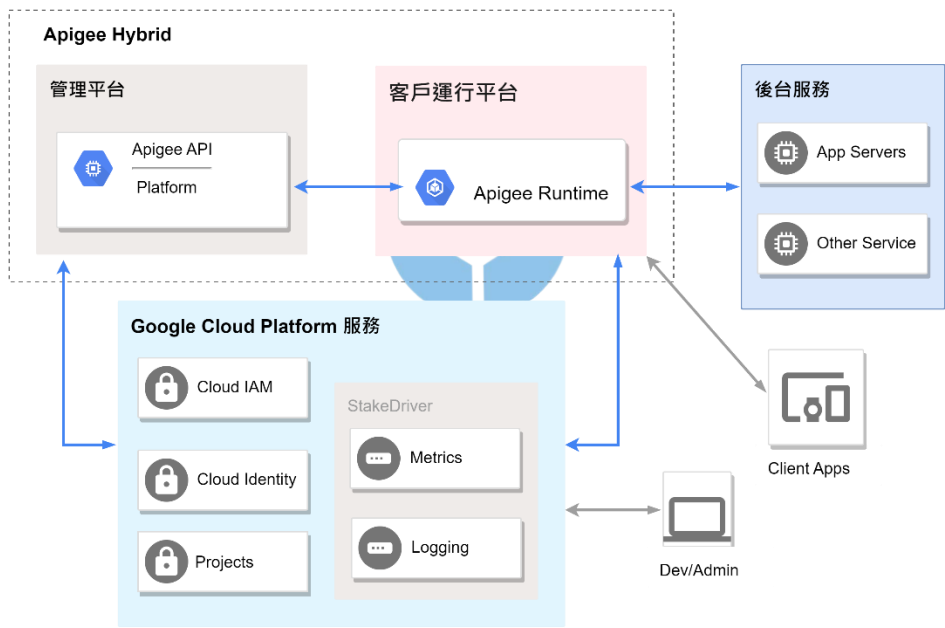


圖 22、Apigee Hybrid 高階架構圖
(來源：Google Apigee Hybrid)

- Apigee Hybrid 高階架構兩個主要平台說明：
- **管理平台 Management plane**：一組託管在雲端並由 Google 維護的服務，包括 UI、管理 API 和分析。
 - **客戶運行平台 Runtime plane**：在自行維護的 Kubernetes 叢集中設置一組容器化運行服務，所有 API 流量都會經過運行平台處理。您可以管理 Kubernetes 上的容器化叢集時，通過分階段部署、自動擴展和容器的運營優勢來提高敏捷性。

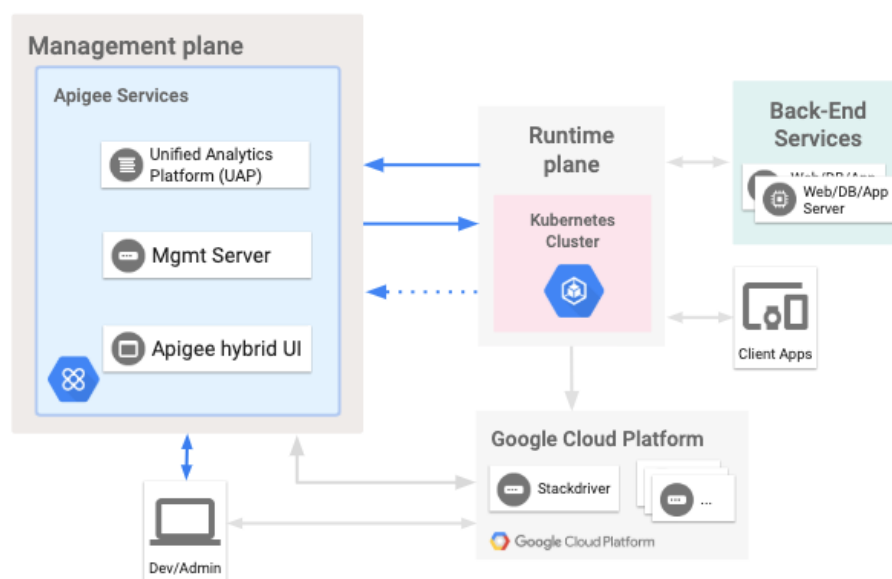


圖 23、Apigee Hybrid 管理平台架構圖
(來源：Google Apigee Hybrid)

Apigee Hybrid Management Plane [48]管理平台，主要元件說明如圖 23：

- **Apigee hybrid UI**：為開發人員提供建立和部署 API 代理程式、設定政策、建立 API 產品，及建立開發人員應用程式 UI，管理員可以用來監控部署的狀態。
- **Mgmt Server**：提供 Apigee API 程式化的介面用來管理組織和環境。
- **Unified Analytics Platform (UAP)**：接收並處理來自運行平台的分析部署狀態。

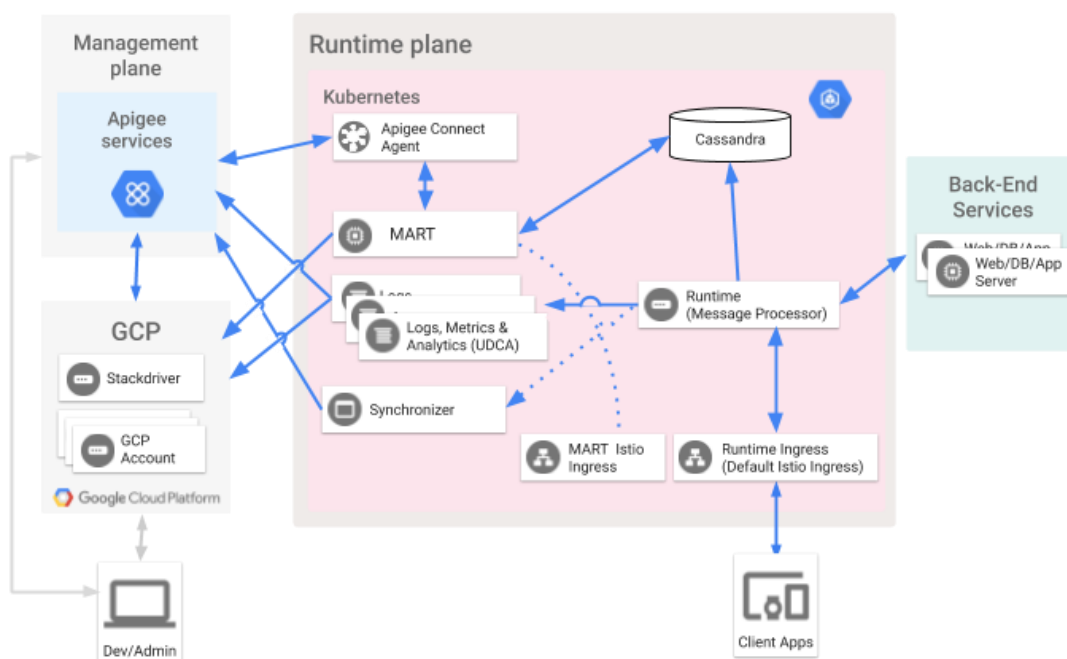


圖 24、Apigee Hybrid 客戶端運行平台架構圖
(來源：Google Apigee Hybrid)

Apigee Hybrid Runtime plane [48] 客戶運行平台，主要元件說明如圖 24：

- **Message Processors**：使用來自管理平台的動態更新，在運行平台上提供 API 請求處理和策略執行。
- **Synchronizer**：從管理平台擷取有關 API 環境的設定資料到運行平台。
- **Cassandra**：提供 Apigee 運行平台本地端資料儲存，例如 KMS、OAuth、KVM，還有快取功能。
- **Management API for Runtime data (MART)**：公開端點用來管理運行平台的資料，例如 KMS（API 密鑰和 OAuth 令牌）、配額、KVM 和 API 產品。
- **Universal Data Collection Agent (UDCA)**：提取分析和部署狀態資料，並發送到管理平台中的 UAP 服務，以便透過管理介面 UI 存取。

4.2.9 Apigee Hybrid 混合雲系統部署及高可用規劃

關於 Apigee Hybrid 混合式系統部署，須配合客戶提供地端環境資訊來進行。Apigee Hybrid 網路分區分隔模型範例如圖 25，分別說明如下：

1. 網路層

- HTTPS Proxy
- 靜態 IP
- 無需認證要求



2. 應用程式層

- 容器化應用程式：Apigee 混合式和客戶微服務應用程式
- 客戶微服務應用程式：
 - 不運行在服務網格 Service Mesh 中
 - 無狀態 Stateless
 - 需要符合 VMware 的標準 Anthos 叢集要求
- 除了 Cassandra（Apigee 混合式安裝的一部分）之外，叢集中沒有其他有狀態的服務

3. Apigee Edge 代理

- 開發環境 1000 QPS（最低測試配置）
- 20 個 API 代理

4. 環境區隔層

- 三個環境：開發/測試，暫存和生產（位於不同的網路中）

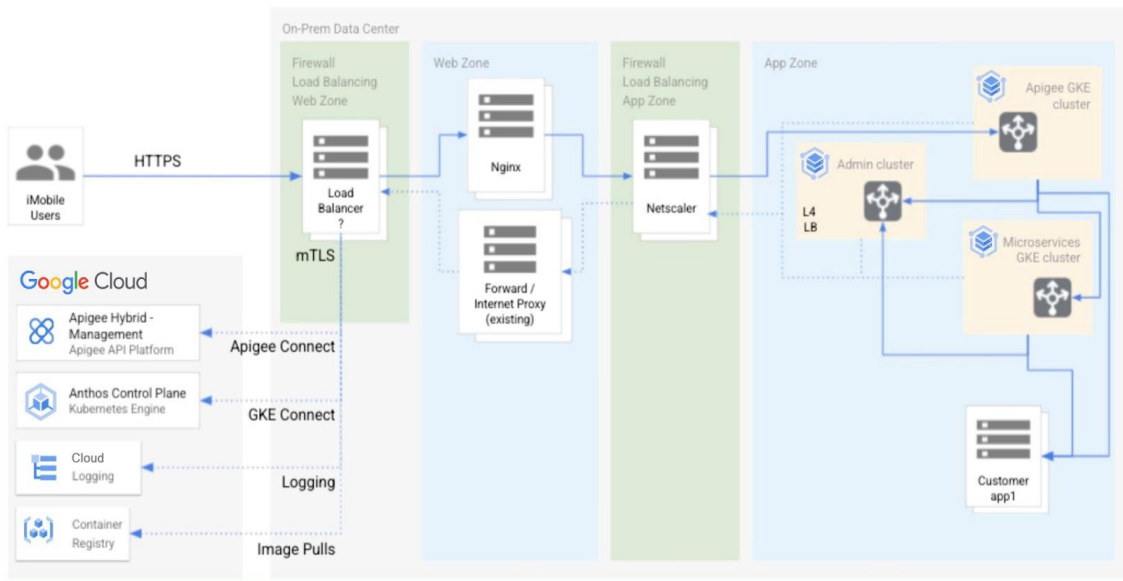


圖 25、Apigee Hybrid 網路分區分隔模型範例
(來源：Google Apigee Hybrid)

Apigee Hybrid 客戶運行平台考量多區域部署 [49]，架構說明如圖 26：

- **主動-主動**：需要多個地理位置部署及低延遲應用程式 API 回應，選擇距離客戶最近的多個地理位置混合部署。例如：美西、歐洲、亞太地區。
- **主動-被動**：當您有一個主要區域，另一個當成故障轉移或災難復原區域。

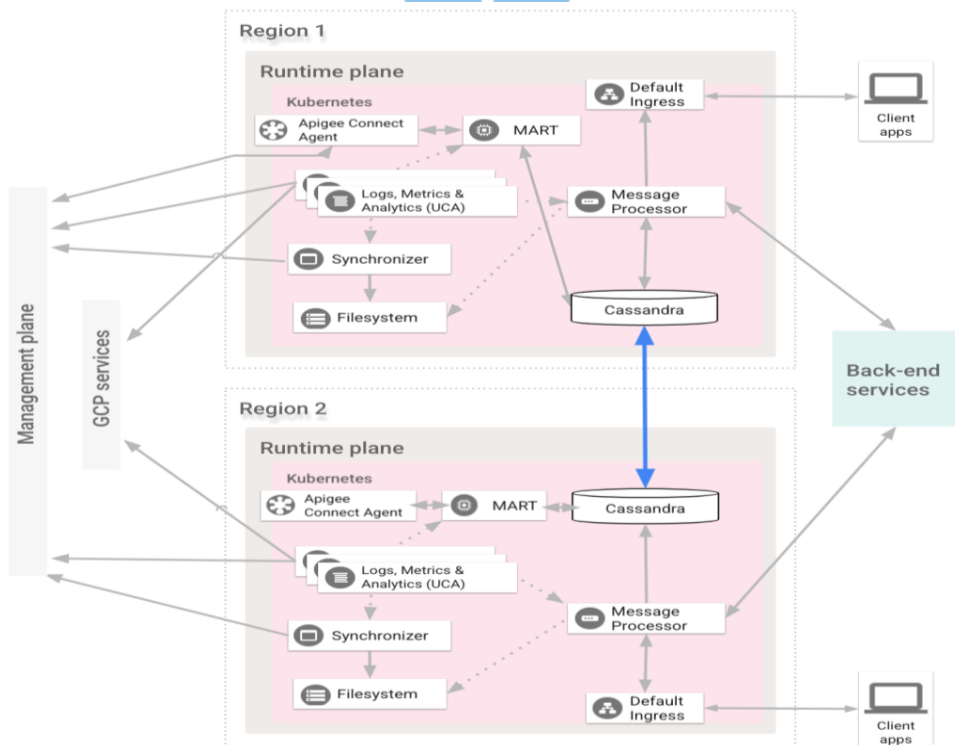


圖 26、Apigee Hybrid 客戶運行平台多地區架構圖
(來源：Google Apigee Hybrid Multi-region deployment)

若是部署 Apigee Hybrid 正式環境 PROD 最佳做法 [50]，建議選擇 Anthos Hybrid 部署模型或多叢集模型。管理控制平台應處於 HA 模式，因此至少需要 3 個節點。工作節點的最小節點配置為 6 個。如果是 Anthos 的混合部署，用戶叢集預設的負載平衡器 (Apigee LB) 將安裝在管理控制平面節點中，整理 Apigee Hybrid 正式環境多地區的部署模型如圖 27。

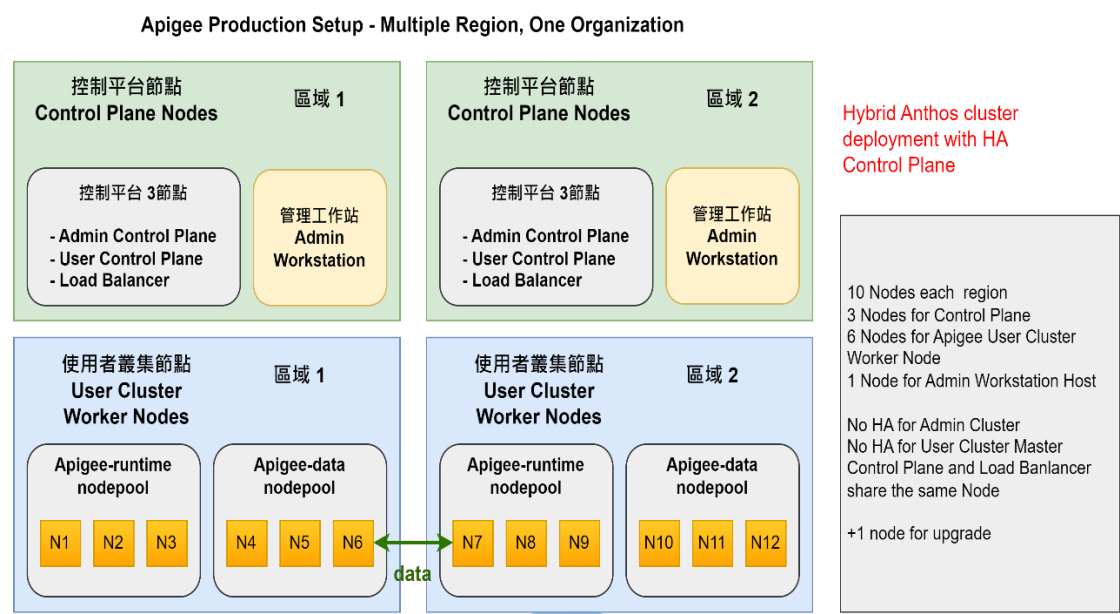


圖 27、Apigee Hybrid 正式環境多地區部署模型
(來源：Rajeshmi, Best Practice for Apigee Hybrid)

4.3 金融業資訊安全控管合規性

以下針對金融業研究個案 Apigee API 解決方案合規性治理、金管會法規遵循及國際標準合規程序、雲端安全聯盟國際標準合規性檢測工具分別加以說明。

4.3.1 Apigee API 合規性治理

API 治理 (Governance)適用於應用軟體開發流程控管，目前全球邁入雲端運算服務的新時代，公司內部或者外部有越來越多的業務合作，API 變成是行動應用程式與後端系統溝通及建構服務的核心，良好的合規性變得越來越重要。

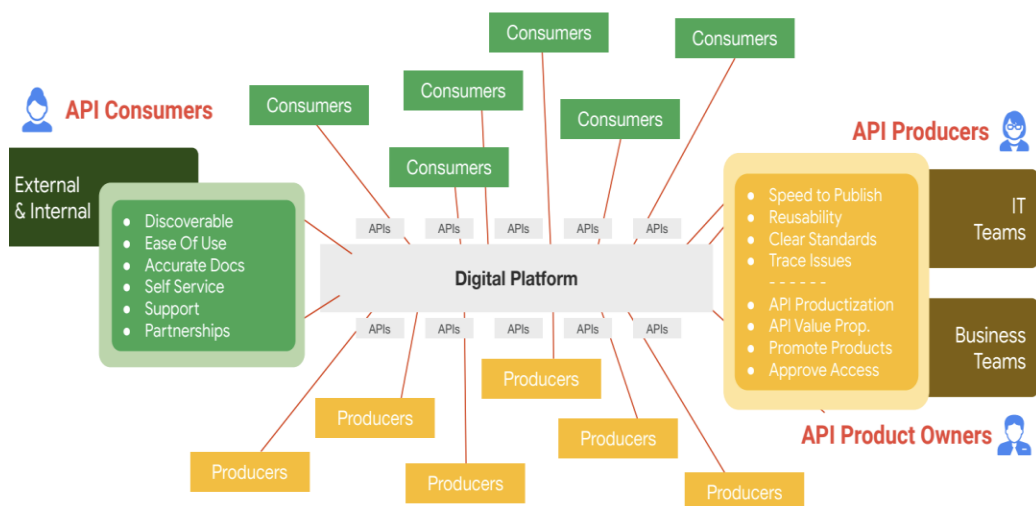


圖 28、API 治理架構及不同角色的考量
(來源：Google Apigee API Governance Reference)

參考 daviscean [51] 整理的 API Governance Reference，Google Apigee API 的治理架構如圖 28，考量幾個不同的角色說明如下：

- **API Consumer 消費者**：使用 API 的人，大多是使用 API 公司內部的開發者，或是外部廠商，也可能是獨立開發者。
- **API Producers 生產者**：提供 API 的人，通常是內部不同業務單位的開發者。
- **API Product Owner 產品負責人**：通常是內部不同業務單位 API 產品經理。
- **API 平台管理者**：管控 API 管理平台的管理者。

API 的治理程序分為三個步驟：

1. **發現**：理解現在 API 治理的成熟度。
2. **設計**：根據業務需求跟預期目標，訂製 API 治理的 PPT (People, Process, Technology)。
3. **實現**：根據執行計畫，一步一步實現。

通常會利用一連串的 Discovery Workshop，發現公司內 API 治理的成熟度。參考 Jacobs [52] 於 Google Cloud Blog 提出 Apigee API 產品心得，對比業界常用的「成熟度評分表」，可以快速檢視組織的成熟度。再根據 Org 結構，制定好相關 API Lifecycle (Design, Dev, Onboard, Updated, Retired) 的流程 Process，最後上述相關的設計決定，選定好技術設計細節。最後在執行階段，專案團隊輔助專家設定技術細節。

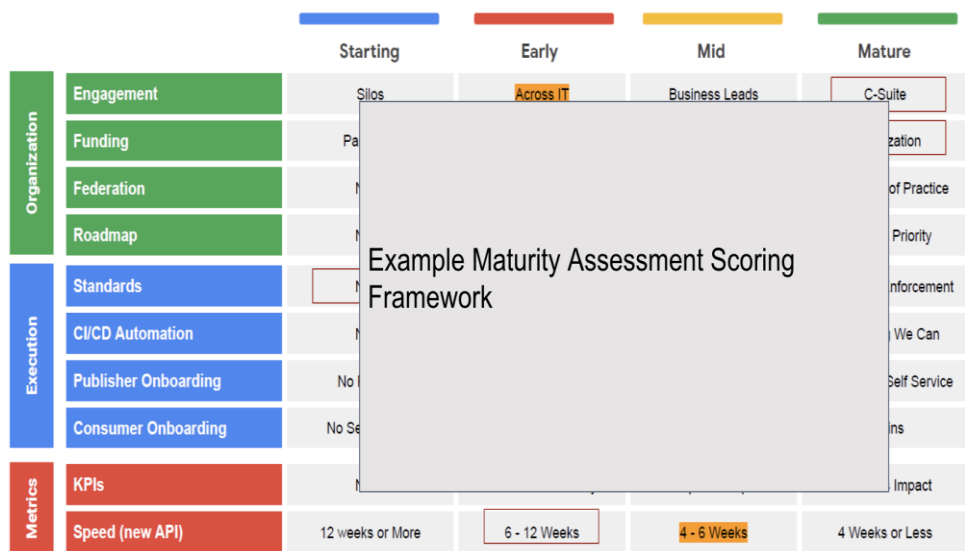


圖 29、API 治理的成熟度評分表範例
(來源：Jacobs, Google Cloud Blog)

API 治理的成熟度評分表範例如圖 29，分別說明如下：

1. **規劃 Engagement**：設計整體治理框架。
2. **平台 Platform**：在管理平台開發設計治理細節。
3. **維運 Operation**：運維管理的流程跟執行細節。
4. **開發者入口網站 Developer Portal**：提供一個良好的開放平台給 Developer (Both API Consumer and API Provider) 分享、協作。
5. **消費者 API Consumer**：使用 API 的角色。
6. **供應商 API Provider**：提供 API 的角色。

參考 Jacobs [52] 於 Google Cloud Blog 提出 Apigee API 產品心得，針對六個面向考量執行的細節，歸納 API 治理的活動範圍如圖 30。

- **規劃 Engagement**
- **平台 Platform**
- **維運 Operations**
- **開發者網站 Developer Portal**
- **消費者 API Consumers**
- **供應商 API Provider**

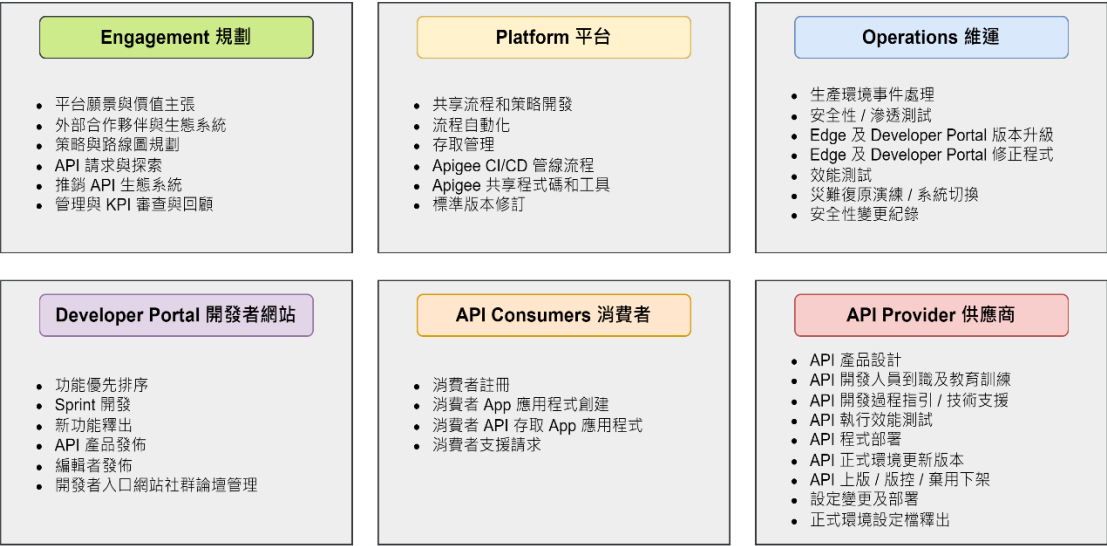


圖 30、API 治理的活動範圍
(來源：Jacobs, Google Cloud Blog)

4.3.2 金管會法規遵循及國際標準合規程序

金融業應該瞭解在台灣金融監督管理委員會（FSC）所發布適用於雲端運算的相關法規和標準、《資訊安全管理法》，考慮適用的國際標準，例如：ISO 27001（資訊安全管理系統）、27002（資安作業實施）、ISO 27005（資訊安全風險管理）、ISO 27017（雲端供應商安全控制）、ISO 27018（保護公有雲資料隱私）。建議依照以下的程序做準備 [53]：

1. **進行風險評鑑：**金融機構在進行雲端運算服務前，應該進行風險識別、分析及計算，評估可能的風險和潛在的法規遵循需求，列出對應的合規措施和法規遵循清單。
2. **確定合規措施：**根據風險評估結果，金融機構應該確定適用的合規措施，以確保雲端運算服務符合相關法規和標準要求。包括資料保護措施、風險評估和管理措施、存取控制、身份驗證等。
3. **建立法規遵循清單：**金融機構應該建立法規遵循清單，根據適用的法規和標準，列出遵循和對應的措施，確保實施雲端運算服務符合相關法規要求。
4. **執行監控和審查：**金融機構在使用雲端運算服務期間，應該持續監控和審查合規措施有效性和遵循情況，有助於日常運營中持續符合法規要求。
5. **進行內部培訓：**金融機構應該針對相關員工進行內部培訓，提高對法規遵循的認識和重要性，確保所有相關人員理解並遵守法規要求。

本研究個案根據 ISO 27001:2013 資訊安全管理系統規範，搭配制定 ISMS 的控管範圍，確認所涵蓋的內部資產及流程，確保政策符合組織的需求並受到管理高層支持與承認。提供 ISMS 控管需準備的相關參考文件，整理範例如表 16。

表 16、ISMS 控管文件範例

文件編號	文件名稱	機密等級	版本
ISMS-01	資訊安全政策	公開	Ver 1.0
ISMS-02	資訊安全手冊	內部使用	Ver 1.0
ISMS-03	文件與紀錄管理作業程序書	內部使用	Ver 1.0
ISMS-04	資訊安全組織及管理審查作業程序書	內部使用	Ver 1.0
ISMS-05	內部稽核作業程序書	內部使用	Ver 1.0
ISMS-06	矯正措施管理作業程序書	內部使用	Ver 1.0
ISMS-07	遵循性管理作業程序書	內部使用	Ver 1.0
ISMS-08	風險評鑑與管理程序書	內部使用	Ver 1.0
ISMS-09	績效管理作業程序書	內部使用	Ver 1.0
ISMS-10	適用性聲明書	內部使用	Ver 1.0
ISMS-11	第三方管理作業規範	內部使用	Ver 1.0
ISMS-12	人力資源安全作業規範	內部使用	Ver 1.0
ISMS-13	資訊資產作業規範	內部使用	Ver 1.0
ISMS-14	存取控制作業規範	內部使用	Ver 1.0
ISMS-15	通訊安全作業規範	內部使用	Ver 1.0
ISMS-16	作業安全作業規範	內部使用	Ver 1.0
ISMS-17	實體與環境安全作業規範	內部使用	Ver 1.0
ISMS-18	資訊系統獲取、開發與維護作業規範	內部使用	Ver 1.0
ISMS-19	營運持續管理作業規範	內部使用	Ver 1.0
ISMS-20	資安事件事故管理作業規範	內部使用	Ver 1.0
ISMS-21	存取權限審查表	內部使用	Ver 1.0
ISMS-22	營運持續計畫測試紀錄表	內部使用	Ver 1.0
ISMS-23	資安通報暨矯正措施單	內部使用	Ver 1.0
ISMS-24	第三方人員保密切結書	內部使用	Ver 1.0
ISMS-25	資訊需求單	內部使用	Ver 1.0
ISMS-26	ISMS 文件一覽表	內部使用	Ver 1.0
ISMS-27	資訊安全目標與績效評量表	內部使用	Ver 1.0
ISMS-28	風險處理計畫暨追蹤表	內部使用	Ver 1.0
ISMS-29	內部稽核檢查表	內部使用	Ver 1.0
ISMS-30	員工保密切結書	內部使用	Ver 1.0
ISMS-31	威脅弱點評估表	內部使用	Ver 1.0
ISMS-32	風險評估彙整表	內部使用	Ver 1.0

(本研究整理)

本研究個案進行的 APIM 專案過程中，依據專案文件規格配合客戶環境進行功能整合測試，確認 Apigee Edge 所產生的客製化報表能夠正常執行，提供 Apigee Custom Report 標準功能測試報告，如圖 31 所示。

測試紀錄表

☒ 標準功能測試	☐ 整合測試	☐ 使用者測試	☐ 其他_____
專案名稱	APIM專案	專案編號	
系統名稱	Apigee	作業名稱	執行報表
測試人員	i 賢	測試日期	2021年10月14日
測試覆核	i 渝	覆核日期	2021年10月15日

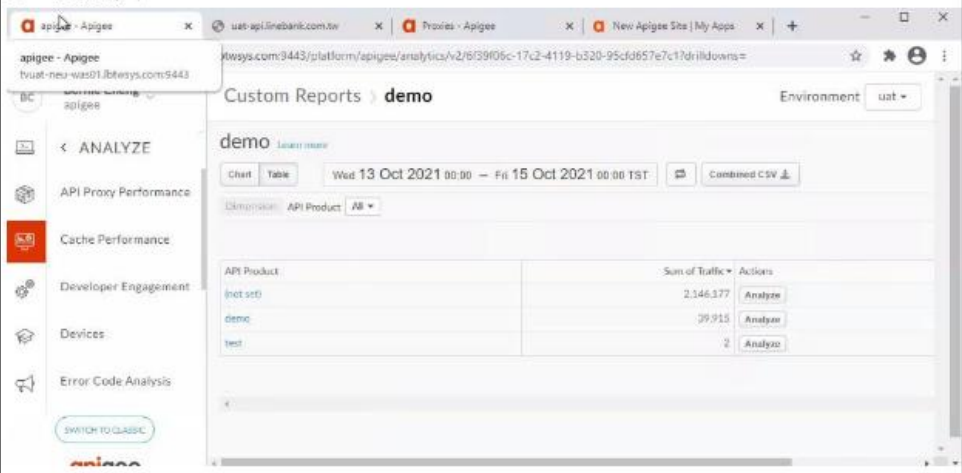
測試個案	執行報表	個案編號	
測試案例說明	開啟報表清單，確認是否有看到已設定的報表		
預期結果	有看到已設定的報表		
實際執行結果	1. 報表清單 		

圖 31、Apigee 標準功能測試報告
(本研究整理)

本研究個案根據 ISO/IEC 27001:2013 資訊安全風險分析，需要定義公司內資訊安全實施的範圍，公司內哪些單位及人員需要遵守，每年需要接受第三方稽核審查，ISO 證書內也會記錄相關的規範，提供法規遵循清單的範例如表 17。

表 17、法規遵循清單範例

項次	法規名稱	修正日期	適用	備註
1	個人資料保護法 https://law.moj.gov.tw/LawClass/LawHistory.aspx?pcode=I0050021	2015/12/30	是	
2	個人資料保護法施行細則 https://law.moj.gov.tw/LawClass/LawHistory.aspx?pcode=I0050022	2014/3/2	是	

3	著作權法 https://law.moj.gov.tw/LawClass/LawHistory.aspx?pcode=J0070017	2022/6/5	是	不得侵害著作權
4	專利法 https://law.moj.gov.tw/LawClass/LawHistory.aspx?pcode=J0070007	2022/5/4	是	修正條款與資安無關
5	營業秘密法 https://law.moj.gov.tw/LawClass/LawHistory.aspx?pcode=J0080028	2020/1/15	是	2020 年 1 月 15 公告之修正與資安無關
6	資通安全管理法與細則 (修訂子法) https://law.moj.gov.tw/LawClass/LawAll.aspx?pcode=A0030297&kw=%e8%b3%87%e9%80%9a%e5%ae%89%e5%85%a8%e7%ae%a1%e7%90%86%e6%b3%95 https://law.moj.gov.tw/LawClass/LawAll.aspx?pcode=A0030303	2021/8/23	否	108 年 1 月 1 號實施，本研究個案，並不屬於資通安全法所定義之特定非公務機關，因此並不適用

(本研究整理)

驗證機構的稽核小組，應充分瞭解有關客戶組織中的 ISMS 設計、風險評鑑和處理 (包括確定控制項)、資訊安全政策及目的。要求客戶展現資訊安全相關風險評鑑是否於 ISMS 範圍相關且運作正常，確認客戶有關鑑別、檢查和評估資訊安全相關風險的程序，及其實施結果是否與客戶的政策、目的和目標一致。以下提供蘇江村 [17] 整理，依據資產資訊安全權責單位，配合輸入、處理、輸出流程，產出相關的報表，風險評鑑的稽核流程如圖 32。

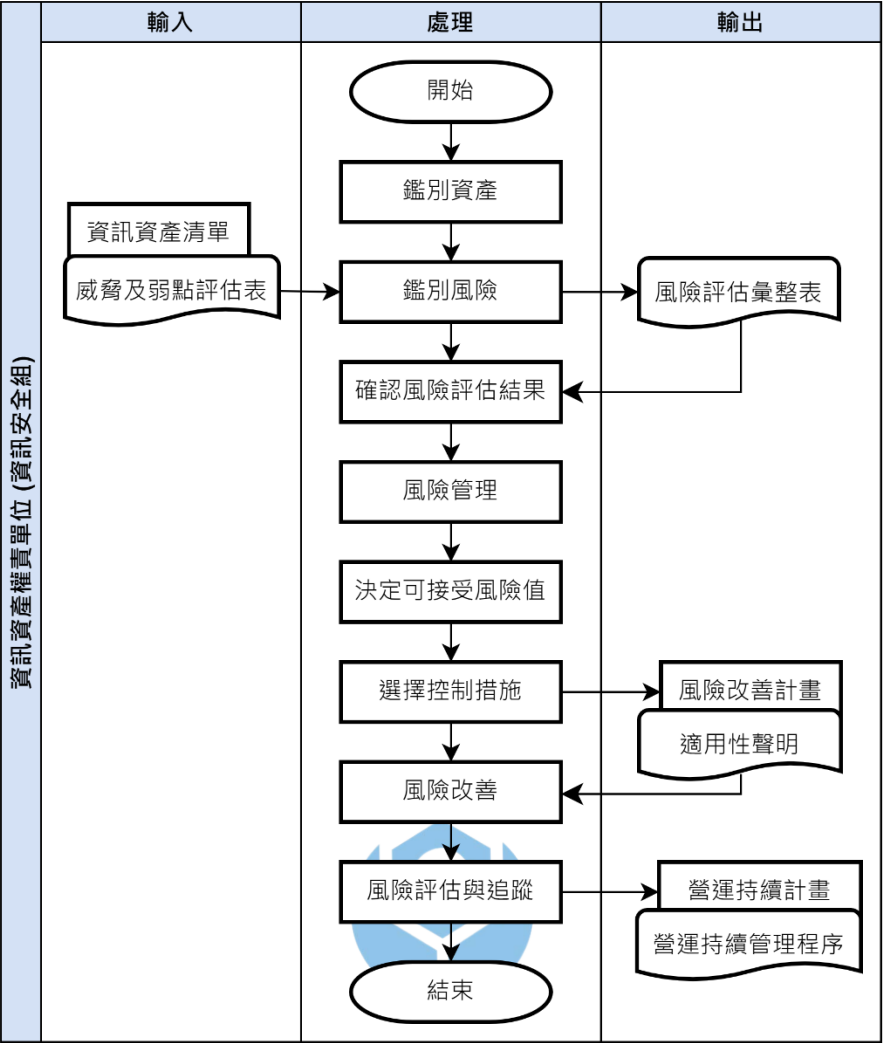


圖 32、風險評鑑稽核流程圖
(來源：蘇江村)

資訊安全風險追蹤管理是確保組織能有效應對資訊安全風險，並持續改進安全措施的重要措施。依據其中的四個重要的方向進行說明：

- **監控與追蹤：**持續監控組織的資訊系統和流程，及時偵測任何可能的安全事件或風險。這包括使用安全監控工具來察覺異常活動、實施入侵偵測系統和防火牆來保護網路，以及建立日誌記錄來追蹤和回顧系統活動。組織可以快速響應潛在的風險，並採取適當的應對措施，以降低損害和恢復正常運作。
- **風險改善失效：**當發現資訊安全風險時，組織應立即採取相應的改善措施。然而，有時候改善措施可能無法完全解決問題，或者風險可能在後續的變化中再次出現。組織應及時重新評估風險，找出改善措施失效的原因，並尋找更有效的方法來處理風險。
- **評鑑持續改善：**組織定期對資訊安全措施進行評估，以確定其有效性和適用性。這包括進行風險評估、安全性能評估和測試，以及收集來自各方面的反

饋意見。組織確保其安全措施持續符合最新的風險和威脅，不斷改進環境的資訊安全控管相關設定。

- **風險重新評估：**組織的環境和業務需求隨著時間做調整，可能會導致資訊安全風險的變化。透過風險重新評估，組織可以確定新的風險，並確保現有的安全措施仍然足夠應對風險，資訊安全策略措施與變化的風險環境保持一致。

4.3.3 雲端安全聯盟國際標準合規性檢測工具

雲端安全聯盟 CSA 提供 Cloud Controls Matrix (CCM) 版本 4.0 的 Excel 檢測工具 [54]，CCM 符合產業公認的安全性標準、規定及控制措施架構，例如：ISO 27001、PCI DSS、HIPAA、AICPA SOC 2、NERC CIP、FedRAMP、NIST 等。建議內部人員定期檢視雲端、地端環境，配合外部稽核檢視各種可能的資安風險並驗證合規性要求。如何使用 CCM 4.0 工具定期檢查雲端環境如圖 33、用來稽查 ISO/IEC 27000 國際認證標準合規性如圖 34，相關的檢測程序說明如下：

1. 下載 CCM 版本 4.0 Excel 工具：從 CSA 官方網站下載 Cloud Controls Matrix (CCM) 版本 4.0 的 Excel 工具。該工具包含了 197 個控制目標，結構化分為 17 個領域，涵蓋了雲端技術的所有關鍵方面。
2. 內部稽核：根據 CCM 中的控制目標，組織內部可以進行稽核，以確保各項控制措施的有效實施和遵從。這可以通過內部稽核團隊或專業機構進行，並根據 CCM 中的控制目標進行評估和驗證。
3. 外部稽核：除了內部稽核外，可以選擇由第三方獨立機構或合規性專家進行外部稽核，他們可以根據 CCM 中的控制目標和標準進行評估和驗證。
4. 實施控制措施：根據 CCM 中的控制目標，組織應該實施相應的控制措施，以確保符合合規性要求，包括技術、操作和管理上的措施，以保護雲端環境的安全性和資料的保密性。
5. 監控和評估：組織應該建立監控機制，定期評估和測試已實施的控制措施的有效性，包括日誌分析、漏洞掃描、風險評估等活動，以確保合規性能夠持續達到要求。

CCM™ CLOUD CONTROLS MATRIX v4.0.8				Typical Control Applicability and Ownership				
Control Domain	Control Title	Control ID	Control Specification	IaaS	PaaS	SaaS	Phys	Network
Audit & Assurance	Audit Management Process	A&A-05	Define and implement an Audit Management process to support audit planning, risk analysis, security control assessment, conclusion, remediation schedules, report generation, and review of past reports and supporting evidence.	Shared	Shared	Shared	TRUE	TRUE
Audit & Assurance	Remediation	A&A-06	Establish, document, approve, communicate, apply, evaluate and maintain a risk-based corrective action plan to remediate audit findings, review and report remediation status to relevant stakeholders.	Shared	Shared	Shared	TRUE	TRUE
Application & Interface Security - AIS								
Application & Interface Security	Application and Interface Security Policy and Procedures	AIS-01	Establish, document, approve, communicate, apply, evaluate and maintain policies and procedures for application security to provide guidance to the appropriate planning, delivery and support of the organization's application security capabilities. Review and update the policies and procedures at least	Shared	CSC-Owned	Shared	TRUE	TRUE

圖 33、使用 Cloud Controls Matrix 4.0 檢查雲端環境
(本研究整理)

CCM CLOUD CONTROLS MATRIX v4.0.8									
				ISO/IEC 27001:2013, 27002:2013, 27017:2015, 27018:2019			ISO/IEC 27001:2022, 27002:2022		
Control Domain	Control Title	Control ID	Control Specification	Control Mapping	Gap Level	Addendum	Control Mapping	Gap Level	Addendum
Interoperability & Portability - IPY									
Interoperability & Portability	Interoperability and Portability Policy and Procedures	IPY-01	Establish, document, approve, communicate, apply, evaluate and maintain policies and procedures for interoperability and portability including requirements for: a. Communications between application interfaces b. Information processing interoperability c. Application development portability d. Information/Data exchange, usage, portability, integrity, and persistence Review and update the policies and procedures at least annually.	27001: 5.1	Partial Gap	Missing specification(s) in ISOs: Requirement of communications between application services (APIs)	27001: 5.1	Partial Gap	Missing specification(s) in ISOs: 'at least annually (Review)'.
				27001: 5.2			27001: 5.2		
				27001: 7.3			27001: 7.3		
				27001: 7.4			27001: 7.3		
				27001: 7.5			27001: 7.4		
				27001: 9.1			27001: 7.5		
				27001: 9.3			27001: 9.1		
				27001: A.14.1.1			27001: 9.3		
				27017: 14.1.1			27001: A.5.1		
				27001: A.14.1.2			27001: A.5.4		
				27002: 14.1.2			27001: A.5.23		
				27017: 14.1.2			27001: A.8.25		
				27001: A.14.2			27001: A.8.26		
27002: 14.2	27001: A.8.27								
27001: A.14.2.1	27001: A.5.37								
Interoperability & Portability	Application Interface Availability	IPY-02	Provide application interface(s) to CSCs so that they programmatically retrieve their data to enable interoperability and portability.	No Mapping	Full Gap	The full V4 control specification is missing from the ISOs and has to be used to close the gap.	27001: A.5.33	Partial Gap	Recommend that the full CCM control specific ISO controls cover in part but inadequately the
							27001: A.8.26		
Interoperability & Portability	Secure Interoperability and Portability Management	IPY-03	Implement cryptographically secure and standardized network protocols for the management, import and export of data.	27001: A.18.1	No Gap	N/A	27001: A.5.19	No Gap	N/A
				27001: A.15.1.1			27001: A.5.23		
				27002: 15.1.1			27001: A.5.31		
				27017: 15.1.1			27001: A.5.32		
							27001: A.5.33		
	27001: A.5.34								

圖 34、使用 CCM 4.0 稽查 ISO/IEC 27000 國際認證合規性
(本研究整理)

本研究個案根據雲端安全聯盟（CSA）提供雲端控制矩陣（CCM）版本 4.0 工具 [37]，參考 CCM 版本 4.0 實施指南 [55]，以本研究個案開放銀行 API 管理平台應用為例，說明導入 GCP 雲端運算服務可能遇到的關鍵風險指標 [56]，雲端供應鏈中哪些參與者應該實施哪些安全控制，如何使用 CCM 控制矩陣、搭配 CCM 控制項目保護雲端環境，達到國際標準合規性 [57]，彙整雲端風險控管矩陣及國際標準範例整理如表 18。

表 18、關鍵風險 CCM 雲端控制矩陣項目及國際標準合規性

關鍵風險指標	CCM 控制矩陣	CCM 控制項目範例	國際標準合規
惡意濫用雲端	DCS-資料中心安全 LOG-日誌記錄與監控 TVM-威脅與弱點管理	DCS-03:安全區域策略程序 DCS-07:控制存取點 DCS-11:未授權存取回應訓練 LOG-01:日誌監控策略與程序 LOG-05:稽核紀錄監控與回應 LOG-13:故障與異常報告 TVM-01:威脅與漏洞管理策略 TVM-02:惡意軟體防護規範 TVM-06:滲透測試	ISO 27001 ISO 27002 ISO 27017 ISO 27018 NIST 800-53 NIST CSF v1.1 PCI DSS v3.2.1
不安全的 API 存取	AIS-應用程式與介面安全 CEK-密碼學、加密與金鑰管理	AIS-01:應用程式介面安全規範及程序 AIS-05:自動應用程式安全部署 AIS-06:應用程式脆弱性修復 CEK-01:加密與金鑰管理策略 CEK-06:加密變更成本效益分析 CEK-08:雲端供應商金鑰的管理能力(用途/保存/啟用/銷毀)	ISO 27001 ISO 27002 ISO 27017 ISO 27018 NIST 800-53 NIST CSF v1.1 PCI DSS v3.2.1
內部破壞	BCR-業務持續管理與運營彈性 STA-供應鏈管理、透明度和負責任	BCR-01:業務連續性管理策略 BCR-02:風險評估影響分析 BCR-09:災難復原回應計畫 STA-01:共享安全責任模型(SSRM)策略與程序 STA-08:供應鏈風險管理 STA-13:供應鏈合規性審查	ISO 27001 ISO 27002 ISO 27017 ISO 27018 NIST 800-53 NIST CSF v1.1 PCI DSS v3.2.1
共用隔離失敗	DCS-資料中心安全 IVS-基礎架構與虛擬化安全	DCS-05:資產分級與分類 DCS-09:安全區域授權 DCS-10:監控系統 IVS-01:虛擬化基礎安全性策略 IVS-04:作業系統安全強化與基準控制 IVS-05:隔離正式與非正式環境	ISO 27001 ISO 27002 ISO 27017 ISO 27018 NIST 800-53 NIST CSF v1.1 PCI DSS v3.2.1
資料遺失	DSP-資料安全與隱私生命週期管理 CEK-密碼學、加密與金鑰管	DSP-01:安全與隱私的策略程序 DSP-06:資料擁有權和管理權 DSP-17:敏感資料保護 CEK-04:加密演算法 CEK-09:加密與金鑰管理稽核	ISO 27001 ISO 27002 ISO 27017 ISO 27018 NIST 800-53

	理	CEK-21:金鑰清單管理	NIST CSF v1.1 PCI DSS v3.2.1
帳號服務綁架	IAM-身份與訪問管理 TVM-威脅與弱點管理	IAM-01:身分和存取管理政策 IAM-09:特權存取角色隔離 IAM-07:使用者存取變更與撤銷 TVM-03:漏洞修補措施排程 TVM-05:外部資源函式庫漏洞 TVM-10:漏洞管理指標	ISO 27001 ISO 27002 ISO 27017 ISO 27018 NIST 800-53 NIST CSF v1.1 PCI DSS v3.2.1
廠商管理疏失	GRC-治理、風險和合規 STA-供應鏈管理、透明度和負責任	GRC-01:治理計畫策略與程序 GRC-02:風險管理計畫 GRC-06:合規治理責任模型 STA-02:共享安全責任模型(SSRM)供應鏈 STA-07:供應鏈清單 STA-19:基本服務合約協議	ISO 27001 ISO 27002 ISO 27018 NIST 800-53 NIST CSF v1.1 PCI DSS v3.2.1
供應商綁定	IPY-互操作性與可移植性 STA-供應鏈管理、透明度和負責任	IPY-01:互動性與可移植性策略 IPY-02:應用程式介面可用性 IPY-04:資料可移植性約定義務 STA-03:共享安全責任模型指南 STA-12:供應鏈服務協議合規性 STA-09:供應鏈資料安全評估	ISO 27001 ISO 27002 ISO 27017 NIST 800-53 NIST CSF v1.1 PCI DSS v3.2.1
合規性風險	GRC-治理、風險和合規 SEF-安全事件管理、電子發現與雲端取證	GRC-04:策略例外流程 GRC-05:訊息安全計畫 GRC-07:訊息系統監管對應 SEF-01:安全事件管理規章 SEF-05:事件回應指標矩陣 SEF-08:監管機關聯絡人清單	ISO 27001 ISO 27002 ISO 27017 ISO 27018 NIST 800-53 NIST CSF v1.1 PCI DSS v3.2.1

(本研究整理)

第五章 結論與建議

說明金融業導入雲端運算的策略與合規性研究結論與建議，實務管理意涵及未來展望研究方向。

5.1 研究結論與建議

金融科技不斷地創新發展、競爭者持續挑戰，根據巴塞爾銀行監理委員會（Basel Committee on Banking Supervision, BCBS）的報告 [58]，金融科技對銀行核心服務的創新領域有重要影響，其中包括存放款及籌資服務、支付結算清算服務以及投資管理服務等三大領域如圖 35。

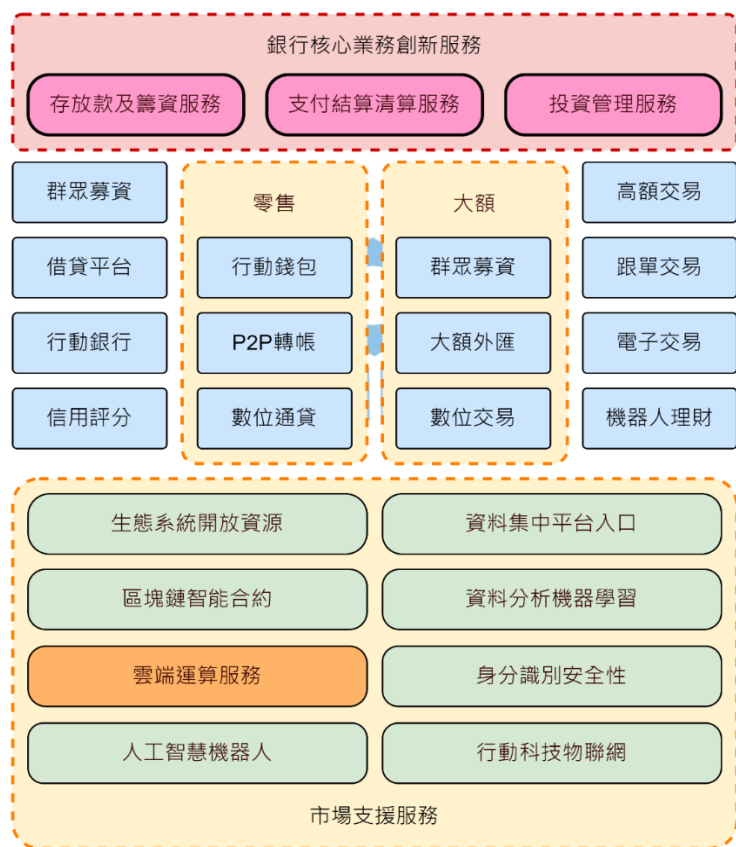
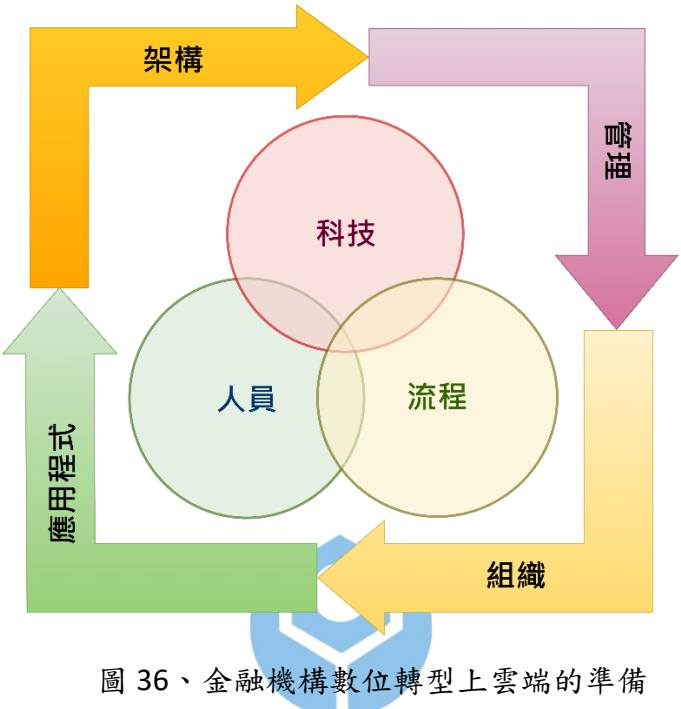


圖 35、金融科技運用於銀行核心業務之創新服務
(來源：BCBS)

台灣的金融業向來以穩健發展著稱，因為擔心金融監管單位採取嚴格審查。2019 年對銀行保險業使用雲端服務法令規範出現，2020 年開放純網銀申請，，2022 年金融資安行動方案 2.0，2023 年雲端資訊服務委外作業規範修訂，金管會對於金融機構上雲政策趨於明朗化。在法令開放之前，許多金融單位只在內部架設私有雲測試，引進虛擬化、大數據分析、機器學習、行動化金融商品。隨著法令逐漸開放，出現開放銀行 API、區塊鏈、物聯網、混合雲服務應用。

雲端運算創新服務金融商品，要配合金管會規範及國際認證標準，制定適當的管理控制措施，及減輕風險的影響，融入企業的日常運作決策當中，採用 CCM 雲端控制矩陣審視關鍵風險及合規性。參考顏勝豪 [59] 提出「金融業於雲端轉型過程中應用系統大規模上雲策略」，台灣金融機構想要透過數位轉型使用雲端資源，建議上雲前的準備如圖 36，其中三種核心項目要點，包含：技術、流程、人員。四種雲端策略規劃包含：管理、組織、應用程式、架構。



(來源：顏勝豪)

三種核心項目要點：

- **科技**—現有基礎架構是否能與雲端平台相容，評估是否需要進行必要的升級。
- **流程**—檢視內部流程，審查配合遷移雲端的能力，優化工作流程並提高效率。
- **人員**—安排員工培訓以熟悉雲端技術與安全實踐，提升雲端管理的專業知識。

四種雲端策略規劃：

- **管理**—制定雲端採用策略，國際標準資訊安全規範，配合內部外部稽核治理，遵守金管會法令合規性，進行有效的雲端資源管理及監控。
- **組織**—高層支持成立雲端業務推廣辦公室，設置跨職能雲端營運團隊，強調角色和職責分工技術小組，解決雲端實施的各種整合問題。
- **應用程式**—評估現有應用程式的雲端相容性，規劃雲端資料遷移及同步模式，設計系統整合測試及演練計畫，解決資料完整性並執行校能調校優化。
- **架構**—連接雲端跟地端的網路，規劃分層區段防火牆配置，多因子身分驗證存取金鑰、加密資料傳輸，確認混合雲應用系統相依性，最小存取權限控管。

5.2 實務管理意涵

金融科技持續發展，銀行商業模式、商品結構、行銷通路及作業處理都需要調整變化，由於金融科技不斷創新，其技術複雜性與交易瞬間完成，銀行恐將面對未知風險 [60]。未來銀行可能面臨管理面的風險，包含策略與獲利風險、作業風險、法遵風險、外包風險、網路通訊風險及流動性風險等，整理說明如表 19。

表 19、未來銀行可能面臨的風險類型

風險類型	風險內容說明
策略獲利風險	大型科技公司進入金融服務行業可能對傳統銀行的策略和盈利能力產生影響。這些科技公司擁有龐大的客戶基礎、信息訪問權限和多元化的業務模式，這可能導致銀行在市場份額和盈利能力方面面臨挑戰。
作業風險	科技公司進入金融服務可能面臨作業風險，例如系統故障、技術漏洞或數據安全問題。這些風險可能對金融交易和客戶資料的安全性和可靠性造成威脅。
法遵風險	大型科技公司需要遵守金融監管機構的法規和要求。如果這些科技公司未能遵守相關法規，可能面臨合規風險，可能受到罰款或其他監管措施。
外包風險	科技公司可能將某些業務功能外包給其他供應商或合作夥伴。如果外包方無法提供高品質的服務或存在風險，可能對科技公司的業務運營和服務造成不利影響。
網路通訊風險	隨著科技公司在金融服務領域的參與增加，網路安全風險變得更加突出。這些科技公司需要採取適當的措施來保護客戶資料和系統安全，以防範駭客攻擊、數據洩露或其他網路安全威脅。
流動性風險	科技公司在金融服務領域擴大業務可能面臨流動性風險。如果科技公司在金融市場上迅速擴張或遇到資金壓力，這可能對其流動性和資金管理產生負面影響。

(本研究整理)

有鑒於金融科技所帶來的挑戰，銀行系統的演變牽涉到服務客戶的方法、消費行為模式、客戶的喜好都跟著改變。如何幫助本國銀行進行金融數位化轉型，打造現代化敏捷式銀行，以客戶為中心提供永續營運的服務，持續提升競爭力，提供五個面向的因應策略如表 20。

表 20、本國銀行面對金融挑戰的因應策略與數位化轉型

因應策略	數位化轉型內容
彈性經營組織文化	因應外來的挑戰，金融機構應調整經營策略，將數位轉型納入核心戰略，並建立支持數位轉型的組織文化，積極採用數位金融科技，提升客戶體驗，並推動內部流程的自動化。
金融科技人才	銀行或金控單位需積極吸引、培養留住具備數位金融科技專業技能的人才。透過專業知識培訓和升遷發展機會，建立具有數位創新思維的高素質團隊。因應實體分行縮減，提早規劃人員在職訓練，進行配置調整與數位化學習。
金融服務供應商	應該積極尋求與金融科技供應商合作，整合優質的數位解決方案，提升金融服務的效率和品質。強化實體與虛擬通路，建立穩固的策略合作夥伴關係，共同開發面對市場變化，提供即時多元化的金融商品服務。
風險控管與消費者保障	推進數位轉型產生新的服務及商業模式，金控單位必須加強風險控管機制，確保數據和客戶資訊的安全。同時須重視消費者保障，提供安全穩健和可靠的金融服務，保障個資隱私、贏得客戶的信任。
提升市場競爭力	金控單位應密切關注市場動態和技術發展，不斷優化業務流程和服務模式，以保持競爭優勢。利用既有品牌價值與多元通路，注重創新科技應用，推出符合市場需求的新型金融產品和服務，提升市場佔有率。

(本研究整理)

5.3 未來展望

財團法人台灣駭客協會於「2023 年金融資安合規管理與法遵新趨勢報告」[61]，提醒企業應建立主動防禦（Proactive Cybersecurity）的觀念，能夠在資訊安全領域採取主動、預防性的措施，以情資主導超前部署、支持零信任的資訊安全解決方案，值得將來持續研究探討，建議不同階段的措施如下：

- **增加安全樣態**：評估和提高整體系統的安全性，包括強化密碼、強化身份驗證機制、定期更新和修補系統漏洞、配置防火牆和入侵防禦系統等。增加安全樣態可減少攻擊面，降低系統受到攻擊的風險。
- **主動入侵評估**：企業可以進行主動的入侵評估，模擬真實攻擊場景，發現系統和應用程式中的弱點和漏洞。透過入侵評估，企業可以及早發現並修復安全漏洞，提高安全性。
- **網路安全設計**：規劃網路架構安全設計，包括設計網絡拓撲、隔離關鍵資源和實施網路安全策略等，才能確保網絡的穩健性和安全性。
- **可見性 IR 準備**：企業需要建立完整的安全事件響應計劃（Incident Response），確保在發生安全事件時，能夠及時反應和處理。建立可見性是關鍵，包括即時監控和日誌管理等，以及建立恢復和應對安全事件的計劃。
- **紅隊攻防演練**：紅隊攻防演練是指模擬真實的攻擊情況，由專業的紅隊攻擊者進行模擬攻擊，企業的藍隊則負責對抗這些攻擊。透過這樣的演練，企業可以了解自身應用程式、產品的強弱點，提高應對攻擊的能力。
- **供應鏈資訊安全**：企業需要關注供應鏈中的資安風險，包括供應商、第三方合作夥伴等。建立供應鏈資安機制，確保整個供應鏈環節的安全，以免遭受攻擊。

隨著雲端運算架構持續演進，資安即服務（Security as a Service, SecaaS）[4] 提供企業或雲端業者，依據雲端使用者付費的概念以低成本提供服務，讓中小企業或大型企業不需要購買昂貴的資安管理軟硬體產品，也能夠取得專業的資安管理雲端服務。雲端運算服務的複雜性以及多樣的法規遵循標準，使得企業或雲端服務業者需要仰賴資安即服務廠商的專業能力，Gartner 預測資安即服務的市場營收將以指數型曲線成長。資安即服務 SecaaS 可提供的服務，例如：身分認證與存取服務、資料洩漏保護服務、網站安全服務、電子郵件安全服務、安全評估服務、入侵偵測服務、資訊安全與事件管理服務、加密服務、持續營運管理及災難復原服務、網路安全服務等。

Bank 4.0 銀行服務無所不在 [1]，近年來 FinTechs 及 BigTechs 崛起，填補傳統金融服務的缺口，新型態多元商業活動不斷地發展，改變傳統金融中介模式。為了迎向 Open Banking 時代，打造金融場景生態圈，應用程式的生命週期也跟著調整，資訊安全的攻防措施需要與時俱進。例如：資訊安全政策、安全管理制度、資料加密傳輸、資料隱私保護、存取控制、事件管理等。

臺灣中央銀行已成立研究小組密切關注金融科技發展，督促財金公司建構行動支付監管設施，調整純網銀的管理機制，金管會的政策持續更新，金融機構提供對應的控制措施來應對風險，進行智能化監控主動偵測，才能確保地端跟雲端環境的安全，機動式地調整內部及外部政策，維持金融商品及服務的競爭力。

參考文獻

- [1] Brett King 著，孫一仕/周群英/林凱雄譯 (2018/11)。Bank 4.0 金融常在，銀行不再？台北市：金融研訓院。
- [2] 王綱 (2021/10)。銀行業與保險業運用雲端服務與個人資料保護之合規研究。國立政治大學法學院碩士在職專班碩士學位論文。
- [3] 王宏仁 (2016/02/15)。【iThome 2016 年 CIO 大調查－企業雲端投資總論】。檢自 <https://www.ithome.com.tw/article/103821> (2023/07/15)。
- [4] 黃正傑 (2016/12)。雲端運算應用與實務(第二版)。台灣新北市：全華圖書。
- [5] Peter Mell, Timothy Grance(2011)。The NIST Definition of Cloud Computing: Recommendations of the National Institute of Standards and Technology (Special Publication 800-145)。
- [6] 金融監督管理委員會(2020/8/27)。金融科技發展路徑圖。檢自 <https://www.fsc.gov.tw/websitedowndoc?file=chfsc/202012241229310.pdf&filedisplay=1090827%E9%87%91%E8%9E%8D%E7%A7%91%E6%8A%80%E7%99%BC%E5%B1%95%E8%B7%AF%E5%BE%91%E5%9C%96%E5%A0%B1%E5%91%8A%E6%9B%B8.pdf>。
- [7] Financial Stability Institute(2020)。Policy responses to fintech: a cross-country overview。Retrieved from <https://www.bis.org/fsi/publ/insights23.pdf>。
- [8] 金融資安行動方案 2.0 版 (2022/12/27)。金融監督管理委員會。檢自 https://www.fsc.gov.tw/ch/home.jsp?id=96&parentpath=0,2&mcustomize=news_view.jsp&dataserno=202212270001&dtable=News。
- [9] 預告修正「金融機構作業委託他人處理內部作業制度及程序辦法」草案 (2023/03/08)。金融監督管理委員。檢自 https://www.fsc.gov.tw/ch/home.jsp?id=133&parentpath=0,3&mcustomize=lawnotice_view.jsp&dataserno=202303080001&dtable=NoticeLaw。
- [10] 金融機構運用新興科技作業規範(2017/8/31)。值根法律網。檢自 <https://www.rootlaw.com.tw/LawArticle.aspx?LawID=A040390041060000-1060831> (2023/7/6)。
- [11] 黃振楠/林永修/王瑞祥編著(2013/02)。資訊安全與法律特訓教材。台北市：松崗資產管理。
- [12] ISO/IEC 27001 Information security management systems。Retrieved from <https://www.iso.org/standard/27001> (2023/7/11)。

- [13] ISO/IEC 27017 雲端服務之資安控制措施。bsi。檢自
<https://www.bsigroup.com/zh-TW/security-controls-for-cloud-services-isoiec-27017/>
(2023/8/28)。
- [14] ISO/IEC 27018:2019。Information technology — Security techniques — Code of practice for protection of personally identifiable information (PII) in public clouds acting as PII processors。Retrieved from <https://www.iso.org/standard/76559.html>
(2023/7/11)。
- [15] ISO/IEC 27005:2022。Information security, cybersecurity and privacy protection — Guidance on managing information security risks。Retrieved from <https://www.iso.org/standard/80585.html> (2023/7/30)。
- [16] ISO 31000:2018。Risk management — Guidelines。Retrieved from <https://www.iso.org/standard/65694.html> (2023/7/30)。
- [17] 蘇江村。資安風險評鑑標準介紹－桃園市政府地政局。檢自
https://www.land.tycg.gov.tw/userfiles/Files/morefile1_423_5336_431.pdf
(2023/7/31)。
- [18] 卓建全 (2021/3/8)。雲端部署模型 (Cloud deployment model)。檢自
<https://ithelp.ithome.com.tw/articles/10255732> (2023/7/31)。
- [19] NIST SP 500-292。Fang Liu, Jin Tong, Jian Mao, Robert Bohn, John Messina, Lee Badger and Dawn Leaf (2011/09)。NIST Cloud Computing Reference Architecture. Recommendations of the National Institute of Standards and Technology。Retrieved from <https://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication500-292.pdf>
(2023/7/2)。
- [20] NIST SP 800-39。Joint Task Force Transformation Initiative (2011/03)。Managing Information Security Risk: Organization, Mission, and Information System View。Retrieved from <https://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication800-39.pdf> (2023/7/2)。
- [21] NIST Releases Supplemental Materials for SP 800-53 and SP 800-53B: Control Catalog and Control Baselines in Spreadsheet Format (2021/1/26)。Retrieved from <https://csrc.nist.gov/News/2021/control-catalog-and-baselines-as-spreadsheets>
(2023/7/2)。
- [22] NIST SP 800-125 (2011/01)。Karen Scarfone, Murugiah Souppaya, Paul Hoffman。Guide to Security for Full Virtualization Technologies。Retrieved from <https://csrc.nist.gov/publications/detail/sp/800-125/final> (2023/7/2)。

- [23] Cloud Special Interest Group-PCI Security Standards Council(2018/04) 。
Information Supplement: PCI SSC Cloud Computing Guidelines 。 Retrieved from
[https://docs-prv.pcisecuritystandards.org/Guidance%20Document/Virtualization%20and%20Cloud/PCI SSC Cloud Guidelines v3.pdf](https://docs-prv.pcisecuritystandards.org/Guidance%20Document/Virtualization%20and%20Cloud/PCI%20SSC%20Cloud%20Guidelines%20v3.pdf) (2023/7/2) 。
- [24] 廖文華/張志勇/蒯思齊(2021/2/25) 。雲端運算概論。台灣台北市：五南圖書。
- [25] Google Cloud Architecture Framework (2022/07/12) 。 Retrieved from
<https://cloud.google.com/architecture/framework> (2023/7/2) 。
- [26] Jerry (2021/11/04) 。iKala Cloud 技術部落格－企業上雲端前五大評估要點整理。
檢自 <https://ikala.cloud/enterprise-cloud-migration/> (2023/7/2) 。
- [27] T 客邦 (2016/07/01) 。Google 的跨太平洋海底電纜「Faster」7/1 上線。檢自
<https://technews.tw/2016/07/01/google-trans-pacific-undersea-cable-will-be-tomorrow-on-the-line/> (2023/7/2) 。
- [28] Richard Watson (2021/12/3) 。Migrating Applications to the Cloud: Rehost, Refactor, Revise, Rebuild, or Replace? 。Gartner Research 。 Retrieved from
<https://www.gartner.com/en/documents/1485116> (2023/7/8) 。
- [29] Jonathan Allen (2021/11/30) 。7 Strategies for Migrating Applications to the Cloud, introducing AWS Mainframe Modernization and AWS Migration Hub Refactor Spaces 。 Retrieved from
<https://aws.amazon.com/tw/blogs/enterprise-strategy/new-possibilities-seven-strategies-to-accelerate-your-application-migration-to-aws/> (2023/8/22) 。
- [30] Matt Tanner (2022/8/10) 。What is Cloud Migration? How does it affect a company? 。 Retrieved from <https://www.arcion.io/blog/on-premise-to-cloud-migration> (2023/7/8) 。
- [31] Sudip Sengupta & Shmuel Danan (2023) 。NetApp, The 7 Rs of Cloud Migration: 7 Strategies Explained 。 Retrieved from <https://bluexp.netapp.com/blog/aws-cvo-blg-strategies-for-aws-migration-the-new-7th-r-explained> (2023/7/8) 。
- [32] Google Cloud 安全基礎藍圖。檢自
<https://cloud.google.com/architecture/security-foundations> (2023/7/2) 。
- [33] Al-Safwani, N, Hassan, S. and Katuk, N. (2014) 。“A Multiple Attribute Decision Making for Improving Information Security Control Assessment” 。International Journal of Computer Applications 89, 19-24 。
- [34] The Notorious Nine : Cloud Computing Top Threats in 2013 。Cloud Security

Alliance。Retrieved from <https://cloudsecurityalliance.org/artifacts/the-notorious-nine-cloud-computing-top-threats-in-2013/> (2023/7/9)。

[35] Security Guidance for Critical Areas of Focus in Cloud Computing 4.0。Cloud Security Alliance。Retrieved from <https://cloudsecurityalliance.org/artifacts/security-guidance-v4/> (2023/7/9)。

[36] What is cloud security?。Google Cloud。Retrieved from <https://cloud.google.com/learn/what-is-cloud-security> (2023/7/9)。

[37] The CSA Cloud Controls Matrix (CCM) is a cybersecurity control framework for cloud computing。Retrieved from <https://cloudsecurityalliance.org/research/cloud-controls-matrix/> (2023/8/4)。

[38] Almeida, L. and Respicio, A. (2018)。“Decision Support for Selecting information Security Controls”。Journal of Decision System 27, 173-180。

[39] 張舒婷 (2019/10)。「攜手 TSP 業者發展開放銀行，財金公司封面故事: 開放銀行篇」。檢自 <https://www.fisc.com.tw/Upload/ec11fae2-91f9-405f-8ded-24949edfb833/TC/9903.pdf> (2023/07/12)。

[40] Vikas Anand (2022/11/19) 。Apigee named a leader in the 2022 Gartner Magic Quadrant for Full Life Cycle API Management。Retrieved from <https://cloud.google.com/blog/products/api-management/apigee-is-a-leader-in-the-gartner-mq-for-api-management> (2023/7/21)。

[41] Apigee Edge for Private Cloud 簡介。檢自 <https://docs.apigee.com/private-cloud/v4.50.00/overview> (2023/7/21)。

[42] What is Apigee?。Retrieved from <https://cloud.google.com/apigee/docs/api-platform/get-started/what-apigee> (2023/7/21)。

[43] ABN AMRO Developer Portal。Retrieved from <https://developer.abnamro.com/> (2023/7/21)。

[44] Apigee Edge for Private Cloud Monitoring best practices。Retrieved from <https://docs.apigee.com/private-cloud/v4.50.00/monitoring-best-practices> (2023/7/22)。

[45] Apigee Edge Monetization overview。Retrieved from <https://docs.apigee.com/api-platform/monetization/basics-monetization> (2023/8/29)。

[46] Apigee Edge for Private Cloud Installation topologies。Retrieved from <https://docs.apigee.com/private-cloud/v4.19.06/installation-topologies> (2023/7/22)。

- [47] Apigee Edge for Private Cloud Port requirements 。 Retrieved from <https://docs.apigee.com/private-cloud/v4.50.00/port-requirements> (2023/7/22) 。
- [48] What is Apigee hybrid? 。 Retrieved from <https://cloud.google.com/apigee/docs/hybrid/v1.10/what-is-hybrid> (2023/7/21) 。
- [49] Apigee Hybrid Multi-region deployment 。 Retrieved from <https://cloud.google.com/apigee/docs/hybrid/v1.10/multi-region.html> (2023/7/21) 。
- [50] Rajeshmi (2023/1/4) 。 Best Practices for Designing Apigee Topology and Sizing for Anthos Deployment 。 Retrieved from <https://www.googlecloudcommunity.com/gc/Cloud-Product-Articles/Best-Practices-for-Designing-Apigee-Topology-and-Sizing-for/ta-p/506612> (2023/7/21) 。
- [51] davissean, API Governance Reference 。 Retrieved from <https://www.googlecloudcommunity.com/gc/Cloud-Product-Articles/API-Governance-Reference/ta-p/78755> (2023/8/20) 。
- [52] Jacobs, The API Product Mindset 。 Google Cloud Blog 。 Retrieved from <https://cloud.google.com/blog/products/api-management/the-api-product-mindset> (2023/8/20) 。
- [53] Anwer, M. and Gill, A. (2020) 。 Developing an Integrated ISO 27001 and GDPR based Information Privacy Compliance Requirements Model, ACIS 2020 Proceedings 20 。
- [54] Cloud Controls Matrix and CAIQ v4 (2021/6/7) 。 Cloud Security Alliance 。 Retrieved from <https://cloudsecurityalliance.org/artifacts/cloud-controls-matrix-v4/> (2023/7/22) 。
- [55] CCM v4.0 Implementation Guidelines (2021/9/13) 。 Cloud Security Alliance 。 Retrieved from <https://cloudsecurityalliance.org/artifacts/ccm-v4-0-implementation-guidelines/> (2023/8/20) 。
- [56] 林宜隆 (2016/11/6) 。 大數據應用時代：雲端安全化及雲端鑑識化之新思維與新趨勢。人事月刊第 375 期。檢自 <https://www.dgpa.gov.tw/uploads/dgpa/files/201701/3c9ad5ea-9a35-4517-beff-952d94fef2b0.pdf> (2023/7/12) 。
- [57] 周旺瑩 (2021/05) 。 AHP 和 TOPSIS 方法在選擇隱私控制措施的應用-以臺灣金融機構為例。國立臺灣科技大學資訊管理系 EMBA 碩士在職專班碩士學位論文。
- [58] Sound Practices: Implications of fintech developments for banks and bank supervisors (2017/08) 。 Basel Committee on Banking Supervision 。 Retrieved from <https://www.bis.org/bcbs/publ/d415.pdf> (2023/7/12) 。

[59] 顏勝豪 (2022/8/22)。金融業於雲端轉型過程中應用系統大規模上雲策略。國泰金控。檢自 https://s.itho.me/ccms_slides/2022/8/2/ce5ab67f-8ac1-48b9-ae92-96c77fa56bd1.pdf (2023/7/22)。

[60] 謝人俊/林耀傑 (2020/05)。數位金融環境下銀行經營型態的演變與對策。中央銀行金融業務檢查處。檢自 <https://www.tpefx.com.tw/uploads/download/tw/8.%20The%20evolution%20and%20countermeasures%20of%20bank%20management%20pattern%20in%20the%20digital%20financial%20environment.pdf> (2023/7/22)。

[61] 王仁甫。2023 年金融資安合規管理與法遵新趨勢。財團法人台灣駭客協會 (HITCON)。

